

Auditoría Financiera basada en Evaluación de Riesgo

Facilitadores:

Julio R. Jolly Moore

Oswaldo Lau C.

Suhhel Nuñez

Román Poveda



Contraloría General de la República de Panamá

Abril 2010

Auditoría Financiera basada en Evaluación de Riesgo

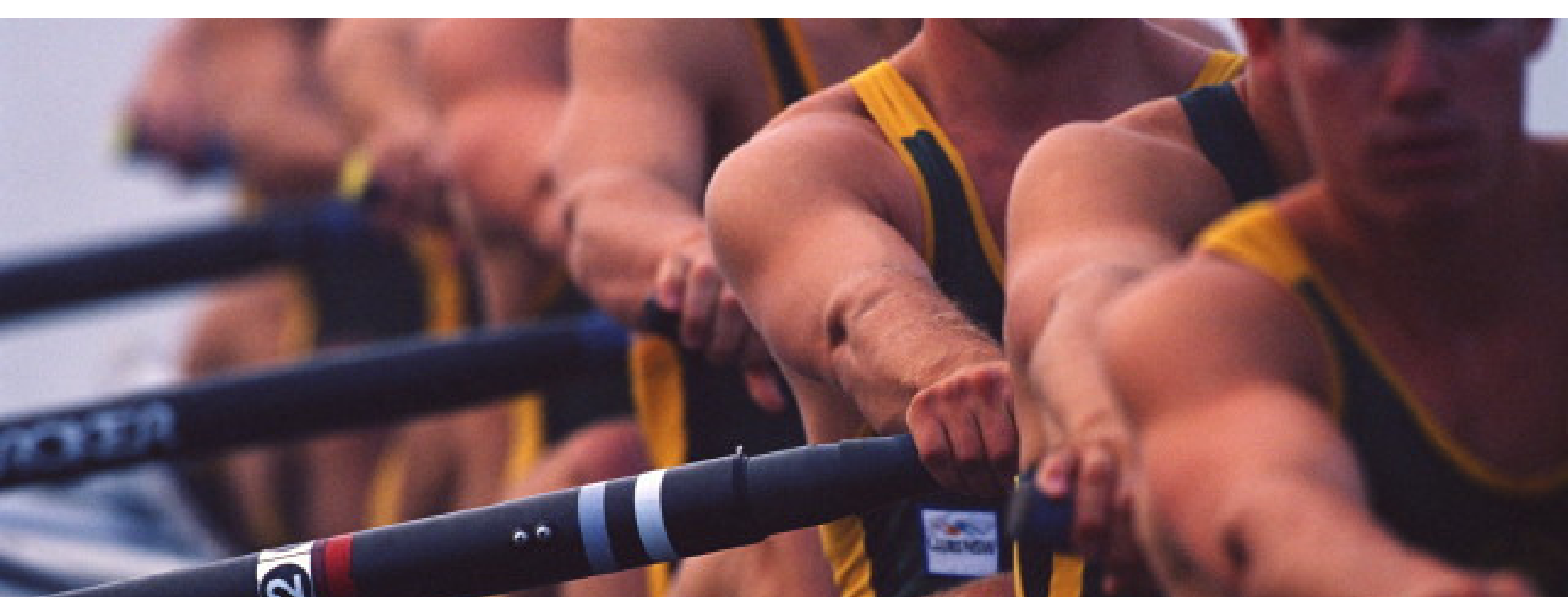


AGENDA

- 1** - Evolución y Nuevo Enfoque de Auditoría Interna
- 2** - COSO ERM dentro del proceso de Administración de Riesgos
- 3** - Auto Evaluaciones de Riesgos y Controles en Auditoría Interna
- 4** - Guía para el desarrollo de un programa de Auditoría Interna basada en Riesgos
- 5** - Consideraciones de Auditorías de TI basadas en Riesgos
- 6** - Narrativas, procesos y matrices de riesgo dentro de Auditoría Interna

Contraloría General de la República de Panamá

Abril 2010



Evolución y Nuevo Enfoque de la Auditoría

Nuevas expectativas del auditor interno

Comité de Auditoría

- Evitar sorpresas
- Efectividad de costos

- Mejores evaluaciones de riesgos
- Enfoque a los aspectos importantes
- Comunicación clara de los temas importantes
- Interacción directa y frecuente

Gerencia

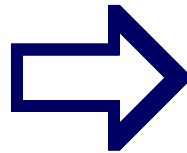
- Más resultados con menos gastos
- Retorno de la inversión tangible
- Evitar sorpresas

- Recomendaciones reales y con planes de acción
- Asistencia con iniciativas de administración de riesgos.

Nuevas habilidades del auditor

PRESENTE

- Control
- Evaluación de Control
- Detective
- Auditorías operacionales
- Imposición
- Independencia
- Conocimiento de Auditoría
- Conciencia de Control



FUTURO

- Conocimiento de riesgos
- Auto Evaluaciones
- Prevención
- Auditorías estratégicas
- Valor agregado
- Conocimiento del negocio
- Habilitador de cambio
- Consiente sobre riesgos

Características del auditor del Siglo 21

- Orientación a trabajos basado en riesgos
- Perspectiva global sobre sus trabajos
- Experiencia en Gobierno Corporativo
- Conocedor de nuevas tecnologías
- Visión de negocio
- Pensamiento creativo
- Solución de problemas
- Fuerte sentido de ética

La **Auditoría Interna** es una actividad independiente y objetiva de aseguramiento y consulta, concebida para agregar valor y mejorar las operaciones de una organización. Ayuda a una organización a cumplir sus objetivos aportando un enfoque sistemático y disciplinado para evaluar y mejorar la eficacia de los procesos de gestión de riesgos, control y gobierno.

Fuente: Insituto de Auditores Internos - IIA.



Rol de Auditoría Interna

- Según la norma **2010 Planificación** de los “**Estándares para la Práctica Profesional de la Auditoría Interna**” el auditor debe *“establecer planes basados en los riesgos, a fin de determinar las prioridades de la actividad de auditoría interna. Dichos planes deberán ser consistentes con las metas de la organización”*.
- Según la norma **2010.A1** de los “**Estándares para la Práctica Profesional de la Auditoría Interna**” los planes de trabajo de *“la actividad de auditoría interna debe estar basado en una evaluación de riesgos, realizada al menos anualmente”*.

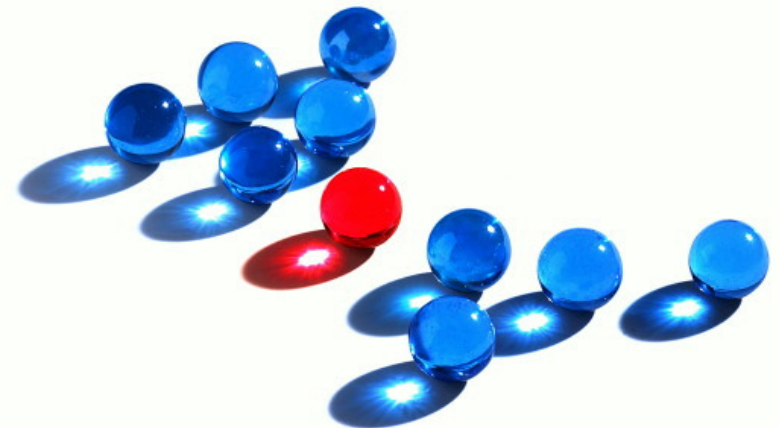
El rol de la auditoría en Administración de Riesgo

- La Alta Dirección tiene la responsabilidad primaria de identificar y administrar los riesgos, así como de la implementación de ERM de una manera estructurada, consistente y coordinada.
- La Junta Directiva, o su equivalente, tiene la responsabilidad general de monitorear los riesgos y obtener aseguramiento que son administrados de manera aceptable.
- Auditoría Interna debe evaluar la eficacia y eficiencia de la implementación de COSO ERM en la organización.

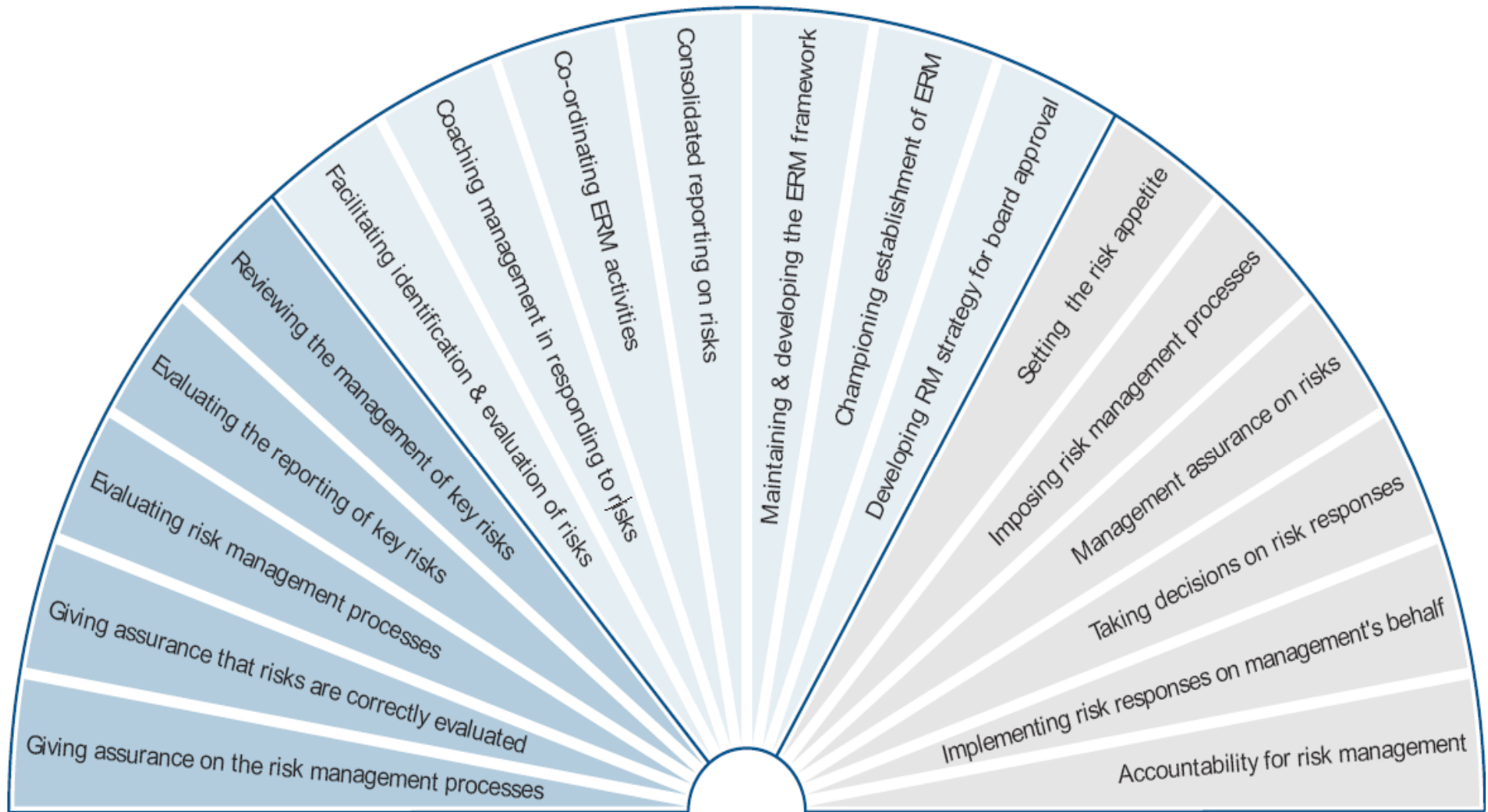
El rol de la auditoría en Administración de Riesgo

El papel central del Auditor Interno en ERM es el de proporcionar aseguramiento a la Junta Directiva y la Alta Dirección sobre la efectividad de las actividades de ERM que ayudan a asegurar que los riesgos claves son administrados de manera apropiada y que el sistema de control interno está operando eficientemente.

Fuente: IIA -- The Role of Internal Audit in Enterprise-wide Risk Management - Sept 2004



El rol de la auditoría en Administración de Riesgo



**Core internal audit roles
in regard to ERM**

**Legitimate internal audit
roles with safeguards**

**Roles internal audit
should not undertake**

Roles principales de auditoría interna en relación a administración de riesgos.

- Proporcionar seguridad sobre el proceso de administración de riesgos.
- Proporcionar seguridad que los riesgos son bien evaluados.
- Evaluar el proceso de administración de riesgo.
- Evaluar los reportes de riesgos claves.
- Revisar la administración de riesgos claves.

Roles legítimos que auditoría puede hacer, *con precaución*

- Facilitar la identificación y evaluación de riesgos.
- Entrenar a la Gerencia para responder a riesgos.
- Coordinar actividades de administración de riesgos.
- Consolidar la información de los reportes.
- Mantener y desarrollar el marco de administración de riesgos.
- Coordinar la implementación de ERM.
- Desarrollar una estrategia de administración de riesgo para la Junta Directiva.

Roles que auditoría interna NO DEBE realizar

- Fijar el apetito a riesgo.
- Imponer procesos de administración de riesgo.
- Administrar el aseguramiento (“assurance”) de riesgos.
- Tomar decisiones en respuestas a riesgos.
- Implementar respuestas a riesgos por parte de la Gerencia.
- Responsabilidad por la administración de riesgos.

¿Cuál es el papel del Control Interno en la Gestión integral de Riesgos?

Dentro de un sistema de Gestión Integral de Riesgos, el **Control Interno tiene un papel muy importante en la:**

- Evaluación de la **efectividad** de los procesos de **gestión de riesgos** en el contexto de las mejores prácticas de la industria.
- Aseguramiento de que las prácticas e infraestructura de gestión de riesgos están **en línea con la estrategia** de negocio
- Implantación y **difusión de la cultura** de la **autoevaluación** continua de riesgos y controles
- **Integración** del modelo de control interno en todas las **áreas y unidades de negocio** de la Entidad.
- Identificación de mejoras a corto y medio plazo en la gestión de riesgos para un mejor **posicionamiento competitivo**.
- Análisis y **evaluación de los modelos** cualitativos y cuantitativos de medición de riesgos.
- Transmisión de **transparencia y confianza** a los grupos de interés (mercado, inversores, agencias de rating, supervisores,...)
- Aseguramiento del **cumplimiento normativo** interno y externo.

GRACIAS

Auditoría Financiera basada en Evaluación de Riesgo

Contraloría General de la República de Panamá

Abril 2010

Facilitadores:

Julio R. Jolly Moore

Oswaldo Lau C.

Suhhel Nuñez

Román Poveda





COSO ERM dentro del proceso de administración de riesgos

INTRODUCCIÓN

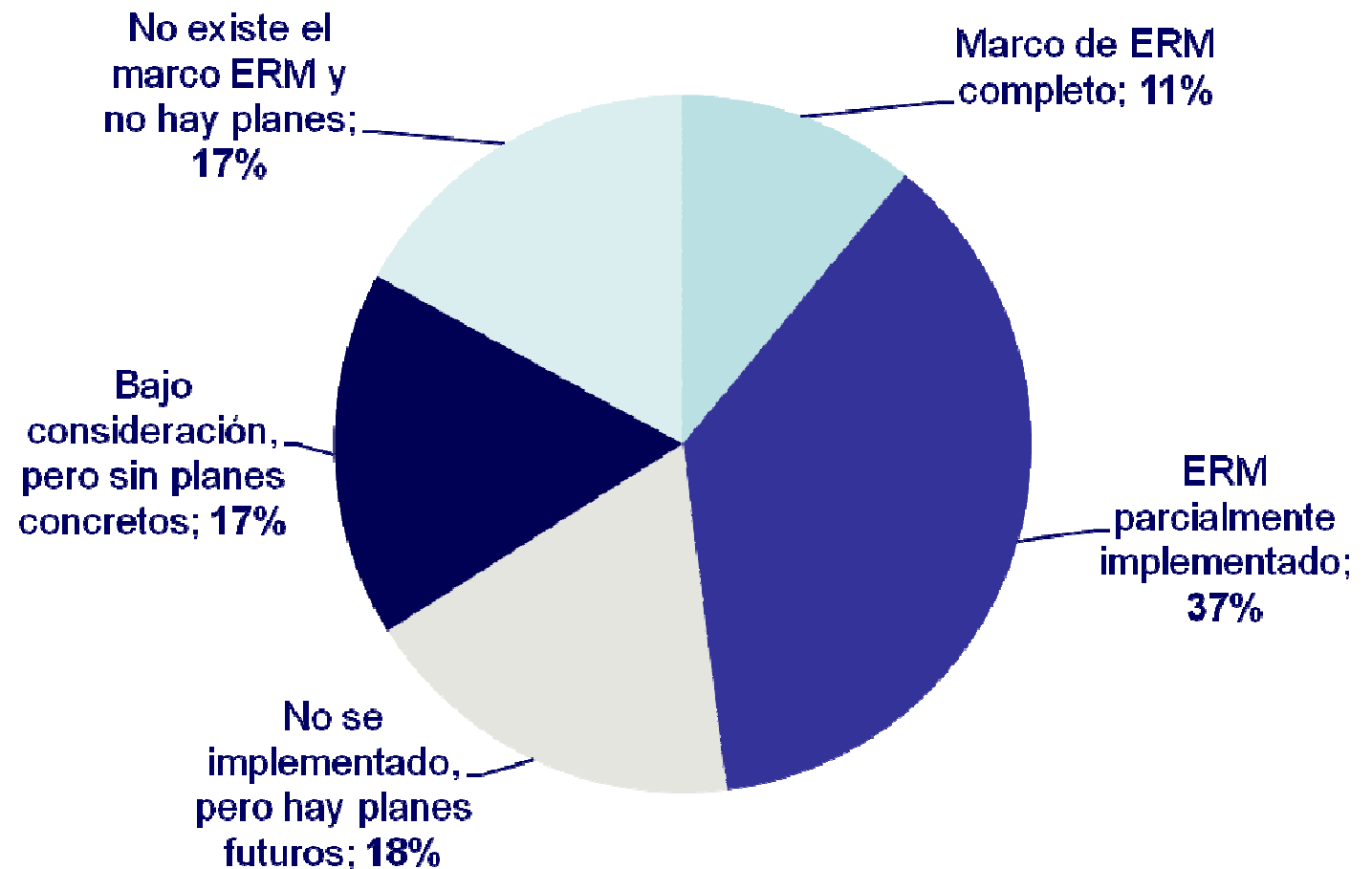


ANTECEDENTES



Nivel de implementación de ERM

Encuesta de IIA – Publicada en la revista “Internal Auditor”



As Enron burned, directors 'toasted marshmallows over the flames'



El entorno empresarial actual

- **Recientes escándalos financieros** y caída de grandes empresas: **pérdida de confianza** del entorno.
- **Crecientes expectativas** y presión sobre la gestión de los negocios por parte **de los grupos de interés**.
- Mayores demandas de **ética, buen gobierno, transparencia y responsabilidad social**.
- Desarrollo de **nuevos marcos regulatorios**.
- Importancia creciente de **la marca y de otros intangibles** como fuente de ventaja competitiva (difíciles de imitar).
- Acceso inmediato a información vía **Internet**.



Estos aspectos no son todos nuevos, pero sí lo es el requerimiento de una nueva estrategia que proteja proactivamente el valor de la marca y los intereses de los stakeholders en este entorno.

Esta nueva estrategia pasa por una Gestión integral de los riesgos y una integración del Control interno en todos los procesos y unidades de negocio.

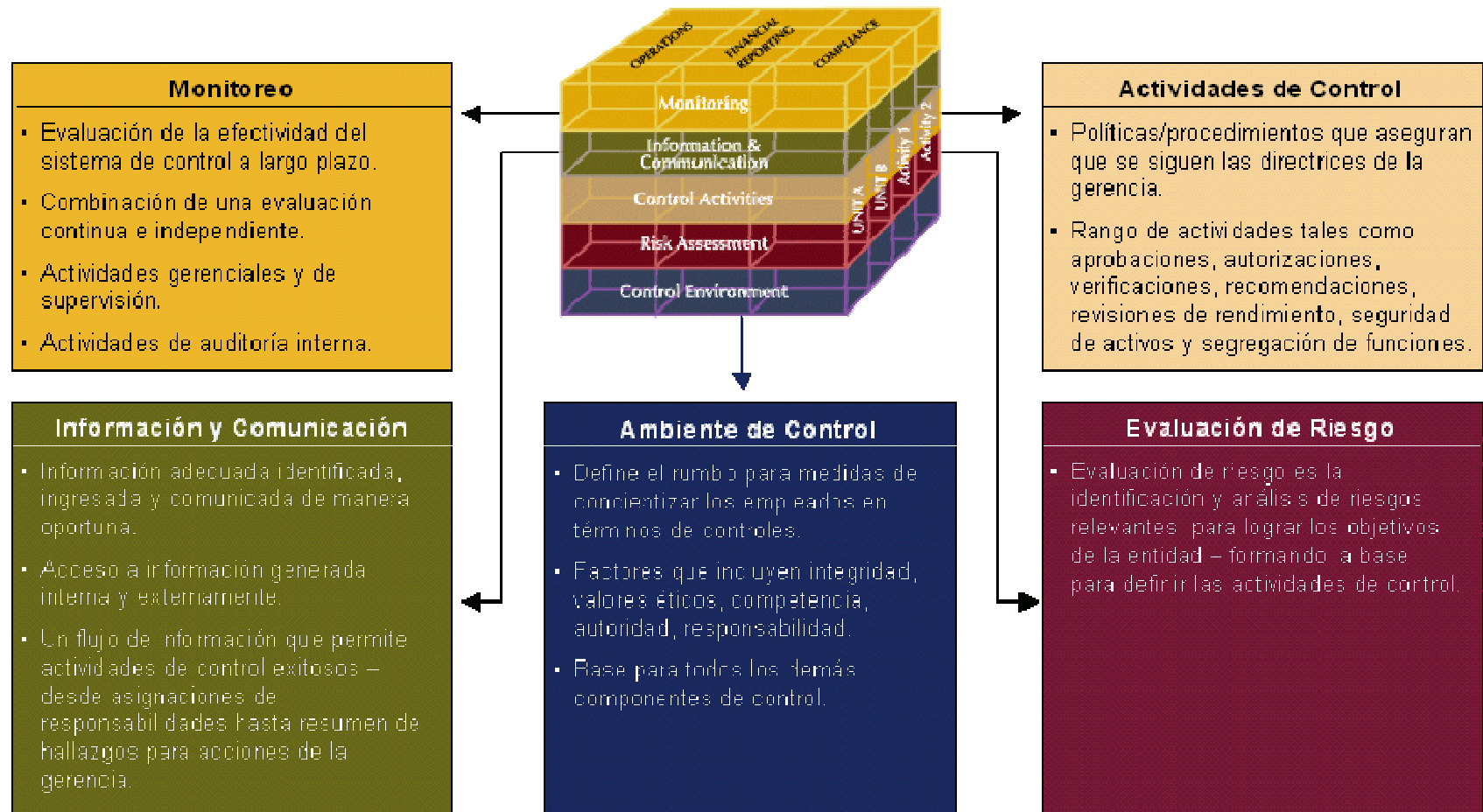


Marco de Referencia Aceptado Mundialmente

Antecedentes - COSO

- El Committee of Sponsoring Organizations of the Treadway Commission (COSO, 1985), formado por representantes de la American Accounting Association, American Institute of Certified Public Accountants, Financial Executives International, Institute of Management Accountants y The Institute of Internal Auditors, se ha constituido como un elemento fundamental dentro de las organizaciones para la consecución de sus objetivos a través de la definición de un marco común de control interno.
- Hace más de una década, el Committee of Sponsoring Organizations of the Treadway Commission (COSO) emitió el Control Interno – Marco Integrado, para ayudar a compañías y otras entidades a evaluar y mejorar sus sistemas de control interno. Desde ese momento, dicho marco fue incorporado a las políticas, normativas y regulaciones, utilizado por miles de compañías para controlar mejor sus actividades en su progreso hacia el logro de sus objetivos.

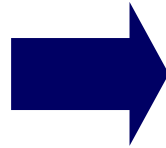
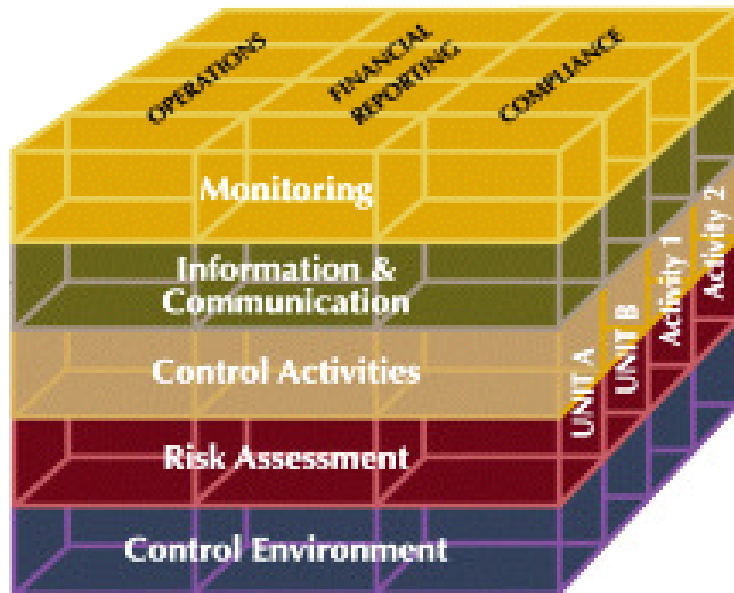
Marco de Referencia Integrado de Control Interno



Fuente: COSO Internal Control by Committee of Sponsoring Organizations of the Treadway Commission (COSO).

De COSO a COSO ERM

COSO



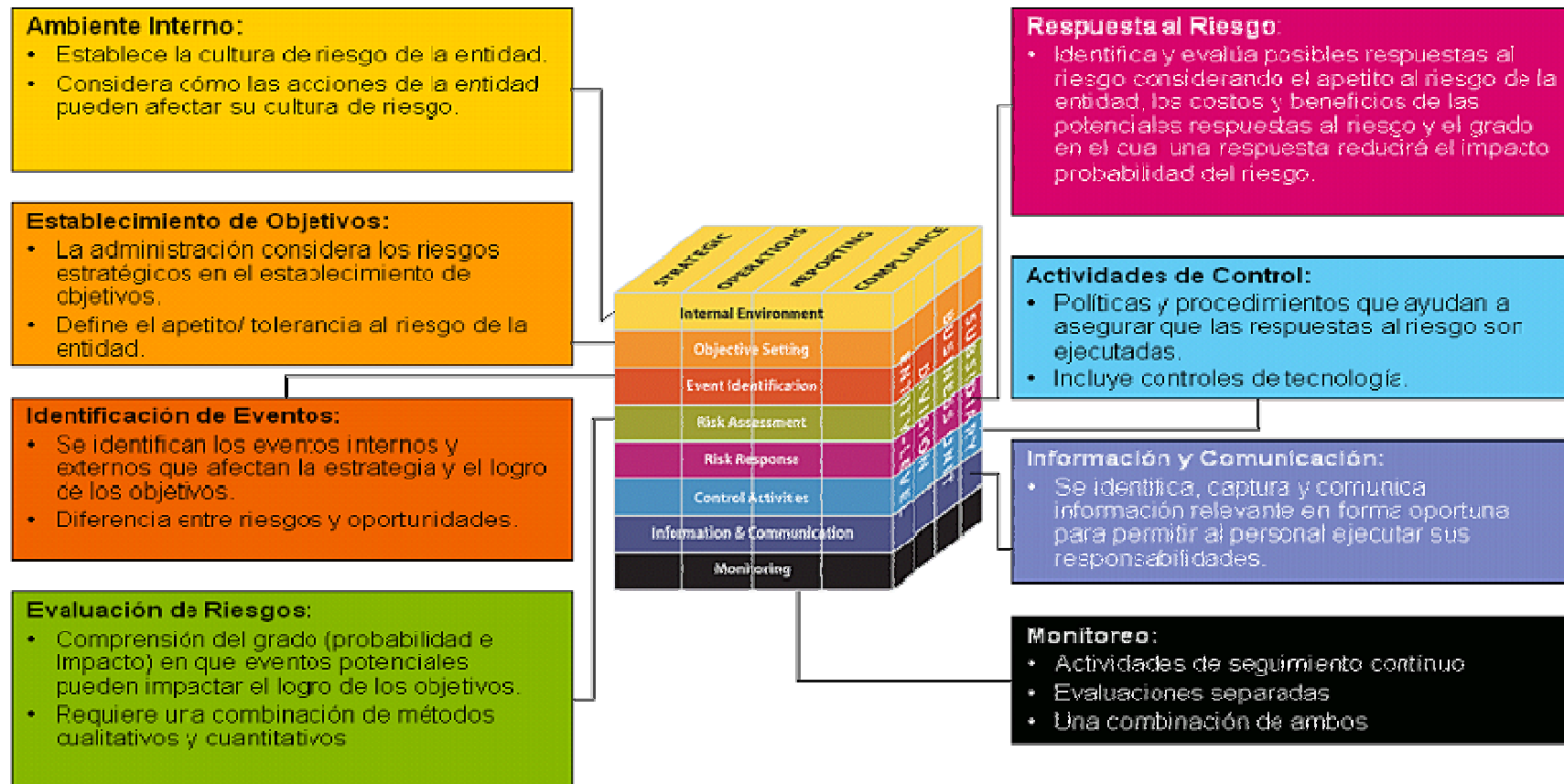
COSO ERM



Antecedentes - COSO ERM

- A causa de escándalos mercantiles en Estados Unidos nació la Ley Sarbanes-Oxley de 2002. Esta ley amplía el requisito de siempre, en virtud del cual, las sociedades anónimas deben mantener sistemas de control interno, exigiendo que la Dirección certifique la eficacia de dichos sistemas y que el auditor acredite la misma.
- COSO ERM, entró en vigor en el año 2005 con la finalidad de proveer un marco de control interno enfocado a la Administración del Riesgo.

Marco Integrado de Gestión del Riesgo Empresarial



Fuente: COSO Internal Control by Committee of Sponsoring Organizations of the Treadway Commission (COSO).

COSO ERM

Es un proceso efectuado por la Junta Directiva de una organización, la administración y otro personal, diseñado para proporcionar un aseguramiento razonable con respecto al logro de los objetivos en las siguientes categorías:

- la efectividad y eficiencia de las operaciones
- la confiabilidad de la Información Financiera
- el cumplimiento con las leyes y los objetivos aplicables

La primera categoría se trata del logro de los objetivos básicos del negocio. La segunda se refiere a la confiabilidad de la información financiera (tanto interna y como externa) que es utilizada por los que son encargados de tomar decisiones. La tercera se trata del cumplimiento con las leyes, regulaciones, y políticas.

ERM - Gestión de Riesgo Corporativo

“...La gestión de riesgos corporativos es un proceso efectuado por el consejo de administración de una entidad, su dirección y restante personal, aplicable a la definición de estrategias en toda la empresa y diseñado para identificar eventos potenciales que puedan afectar a la organización, gestionar sus riesgos dentro del riesgo aceptado y proporcionar una seguridad razonable sobre el logro de los objetivos...”

Fuente: COSO Enterprise Risk Management – Integrated Framework. 2004. COSO.



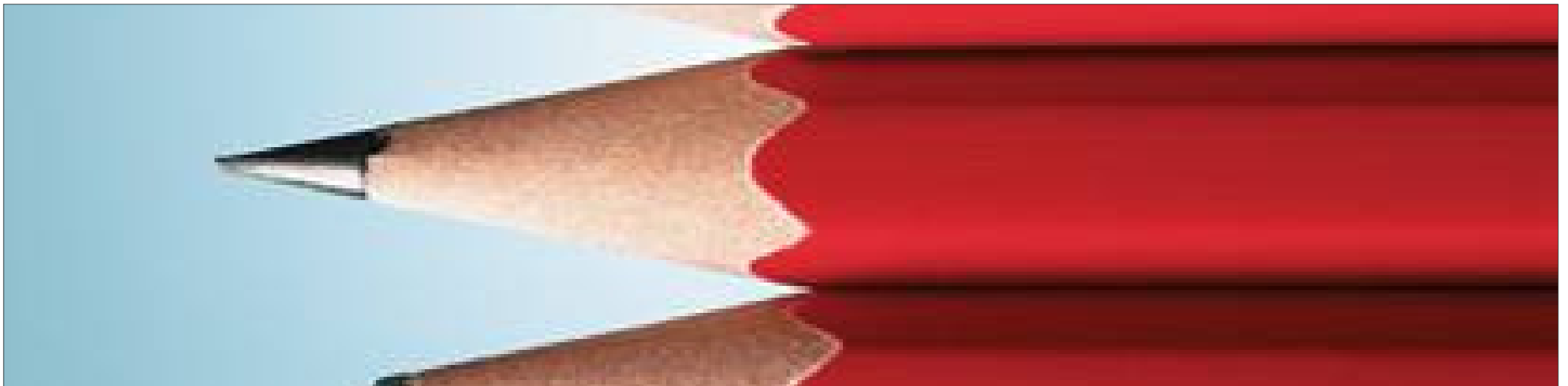
Principios fundamentales COSO ERM

- Cada entidad, sea para obtener ganancias o no, existe para generar valor para sus grupos de interés.
- El valor es creado, preservado, o erosionado por decisiones gerenciales en todas las actividades, desde establecer estrategias hasta operar la organización día a día.



ERM soporta la creación de valor al facilitar la gestión para:

- Tratar de manera efectiva los eventos futuros que generarán incertidumbre.
- Responder de manera tal que se reduzca las opciones de eventualidades negativas o pérdidas y se incremente las opciones de crecimiento.



Estructura de COSO ERM

Objetivos de la Entidad:

- Estratégicos.
- Operacionales.
- Información.
- Cumplimiento.



Actividades a todos los niveles de la organización:

- Nivel de entidad.
- Divisiones o subsidiarias.
- Unidades de negocio.
- Filial (Departamento, Procesos).



Componentes de COSO ERM - Los componentes se dirigen al alcanzar uno o más de los objetivos organización. COSO ERM está compuesto por los siguientes:

- Ambiente Interno.
- Establecimientos de Objetivos.
- Identificación de Eventos.
- Evaluación del Riesgo.
- Respuesta a Riesgos.
- Actividades de Control.
- Información y Comunicación.
- Monitoreo y Supervisión.





Componentes de COSO ERM

Componentes de COSO ERM

- Conforme al modelo del COSO, un sistema de controles internos es un proceso que se compone de varios componentes correlacionados.
- Todos son aplicables a las organizaciones de cualquier tamaño o tipo, pero las organizaciones pueden aplicarlos de diversas maneras.



Ambiente Interno

- La Dirección fija una filosofía respecto al riesgo y determina el riesgo aceptado. El ambiente interno establece la base de cómo el personal de la organización debe percibir y afrontar el control y el riesgo. El núcleo de cualquier negocio está constituido por sus personas - con sus atributos individuales, incluyendo integridad, valores éticos, competencia - y el entorno en el que actúan.

Establecimiento de Objetivos

- Los objetivos deben existir antes de que la dirección pueda identificar los eventos potenciales que afectan a su consecución. La gestión de riesgos corporativos asegura que la Dirección haya establecido un proceso para fijar objetivos y que los objetivos seleccionados apoyan la misión de la entidad y se alinean con ella, además de ser consistentes con el riesgo aceptado.

Identificación de Eventos

- Deben identificarse los eventos potenciales que pueden tener un impacto en la organización. Esto implica la identificación de posibles acontecimientos internos o externos que afectan a la consecución de objetivos, diferenciándolos según su procedencia, e incluye la distinción entre los que representan riesgos u oportunidades o ambas circunstancias a la vez. Las oportunidades se reenvían hacia la estrategia de la dirección o a los procesos para fijar objetivos.

Evaluación de Riesgos

- Los riesgos identificados se analizan para formar una base que determine cómo deben gestionarse y se asocian a los objetivos a los que pueden afectar, evaluándose desde la doble perspectiva de riesgo inherente y residual y considerando tanto su probabilidad como su impacto.

Respuestas a los Riesgos

- El personal identifica y evalúa las posibles respuestas a los riesgos: evitar, aceptar, reducir, transferir o compartir. La Dirección selecciona un conjunto de acciones para poner en línea los riesgos con sus tolerancias respectivas y el riesgo aceptado por la entidad.

Actividades de Control

- Las políticas y procedimientos se establecen y ejecutan para asegurar que se llevan a cabo eficazmente las respuestas a los riesgos seleccionados por la Dirección.

Información y Comunicación

- La información relevante se identifica, capta y comunica de un modo y en un plazo que permita a las personas desarrollar sus responsabilidades. Hace falta información a todos los niveles de una entidad para identificar, evaluar y responder a los riesgos. También puede darse una comunicación eficaz en sentido amplio, cuando fluye en todas direcciones dentro de la entidad. El personal debe recibir comunicaciones claras sobre su papel y responsabilidades.

Monitoreo y Supervisión

- Toda la gestión de riesgos corporativos se supervisa, realizando en ella las modificaciones que sean necesarias. De este modo, se puede reaccionar dinámicamente y cambiar si varían las circunstancias. Esta supervisión se lleva a cabo a través de actividades permanentes de la dirección, evaluaciones independientes de la gestión de riesgos corporativos o una combinación de ambas actuaciones.

¿Qué es Administración de Riesgos?

Establecer las políticas y procedimientos para administrar y mitigar los riesgos que podrían afectar los objetivos de la organización, asegurando que los riesgos sean continuamente evaluados y analizados para mantener los riesgos a un nivel aceptable, de acuerdo al apetito a riesgo establecido por la Alta Dirección.



Algunos indicadores de riesgos:

- Nuevos competidores.
- Nuevas exigencias del mercado.
- Nuevas tecnología.
- Mayor necesidad de gobierno corporativo.
- Alianzas estratégicas.
- Globalización de la economía mundial.
- Incremento en las demandas de las Gerencias.

Alcance de COSO ERM

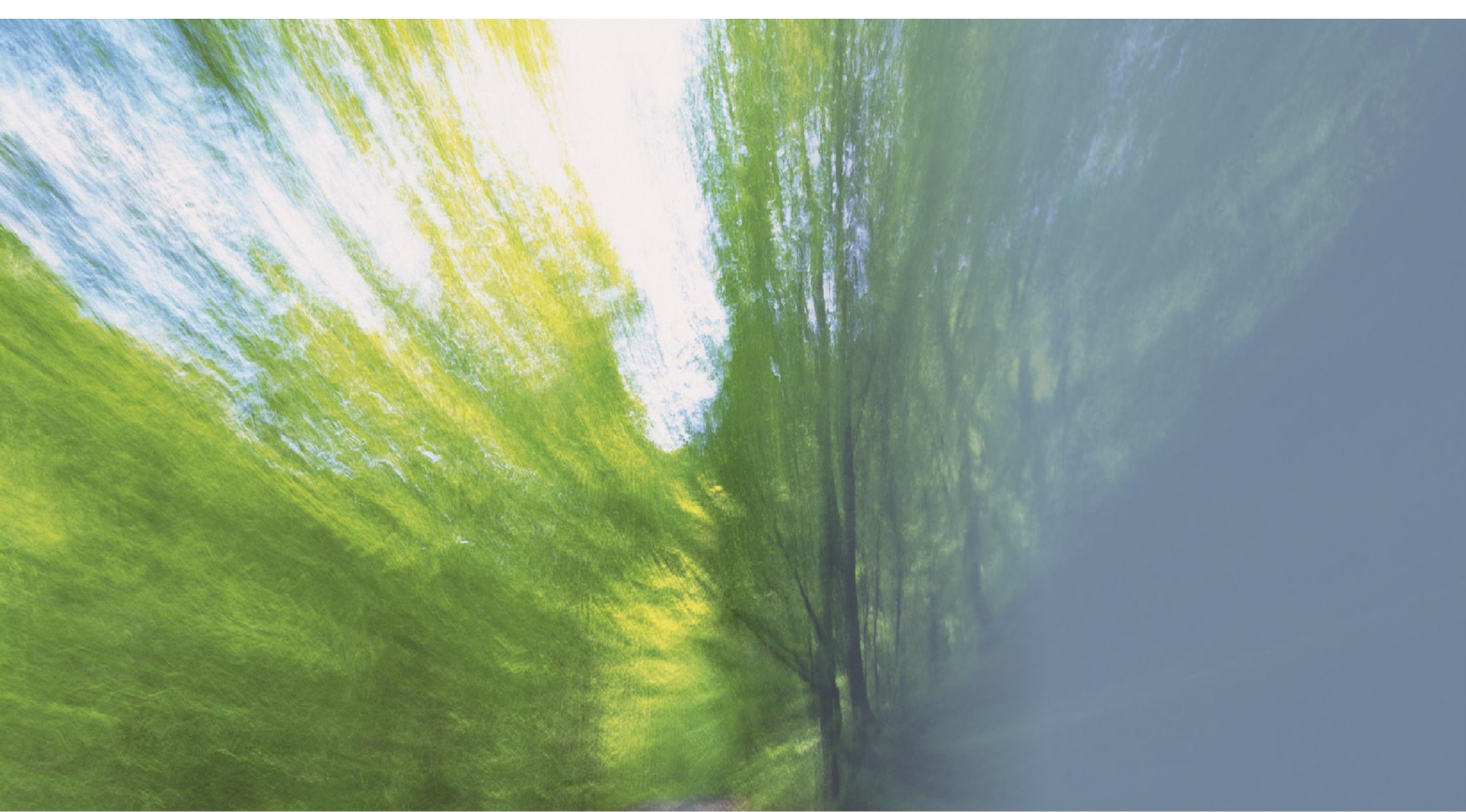
- Su alcance depende del tamaño de la empresa
- Determina el grado de alineación del apetito a riesgo con la estrategia de la organización.
- Mejora el proceso para tomar decisiones en cuanto a riesgos.
- Ayuda a reducir las pérdidas y las “sorpresas”.
- Ayuda a tomar ventaja de oportunidades de negocio.

Limitaciones de COSO ERM

- Independientemente de la efectividad de su implementación, COSO ERM, solamente puede brindar seguridad razonable, no absoluta sobre el logro de los objetivos de la organización.
- Todo sistema de control interno tiene limitaciones inherentes. De no aplicar el buen juicio en la toma de decisiones, el proceso puede fallar y conllevar a brechas debido a errores.
- Dos o más personas en colusión pueden tener la capacidad para obviar o evitar controles.
- Al establecer controles se debe reflejar el hecho de que no existen recursos ilimitados y que los beneficios de los controles deben ser considerados de acuerdo a sus costos.

Beneficios de COSO ERM

- Aumenta las posibilidades de alcanzar los objetivos estratégicos del negocio mediante una buena administración de los riesgos.
- Consolida los diferentes reportes de riesgos a nivel de la Junta Directiva.
- Incrementa el entendimiento de riesgos claves y sus más amplias implicaciones.
- Identifica y comparte riesgos alrededor del negocio.
- Crea mayor enfoque de la gerencia en asuntos que realmente importan.
- Mayor enfoque interno en hacer lo correcto y en la forma correcta.
- Incrementa la posibilidad que los cambios por iniciativas puedan ser alcanzados.
- Capacidad de tomar mayor riesgo por mayores recompensas.
- Más información sobre riesgos tomados y decisiones realizadas.



Técnicas para la Aplicación



Ambiente Interno

Ambiente Interno

El ambiente interno abarca el talante de una organización, que influye en la conciencia de sus empleados sobre el riesgo y forma la base de los otros componentes de la gestión de riesgos corporativos, proporcionando disciplina y estructura. Los factores del ambiente interno incluyen la filosofía de gestión de riesgos de una entidad, su riesgo aceptado, la supervisión ejercida por el consejo de administración, la integridad, valores éticos y competencia de su personal y la forma en que la dirección asigna la autoridad y responsabilidad y organiza y desarrolla a sus empleados.

Fuente: COSO Internal Control by Committee of Sponsoring Organizations of the Treadway Commission (COSO).

Características del Ambiente Interno

- Sirve de base para todos los otros componentes de gestión de riesgos.
- Proporciona disciplina y estructura.
- Influye en el establecimiento de estrategias y objetivos.
- Incide en el funcionamiento de las actividades de control, sistemas de información y comunicación.

Importancia del Ambiente Interno

Se ve influido por la historia y cultura de una entidad y comprende muchos elementos, incluyendo los valores éticos de la entidad, la competencia y desarrollo del personal, la filosofía de la dirección para gestionar riesgos y la forma de asignar la autoridad y responsabilidad. El consejo de administración es una parte crítica del ambiente interno e influye de modo significativo en sus otros factores.

¿Cuáles son los principales aspectos que comprende?



Filosofía de Administración de Riesgos

Conjunto de creencias y actitudes compartidas que caracterizan cómo se contempla el riesgo en la organización, desde el desarrollo e implantación de la estrategia hasta sus actividades cotidianas.

Esta filosofía se refleja en casi todo el quehacer de la alta gerencia para administrar la entidad y se plasma en declaraciones de políticas, las comunicaciones orales y escritas y la toma de decisiones.

Filosofía de Administración de Riesgos

Consideraciones - Declaración de Filosofía de Administración de Riesgo

La administración de riesgos corporativos proporciona a nuestras organizaciones capacidades superiores para identificar, evaluar y administrar todo el espectro de riesgos y posibilitar que el personal de todos los niveles mejore su comprensión y administración del riesgo.



***La filosofía debe
potenciarse con acciones
diarias.***

Filosofía de Administración de Riesgos

Consideraciones – Encuesta sobre Cultura de Riesgo

Permiten obtener un mayor conocimiento sobre el grado de integración de la filosofía de administración de riesgos en la cultura de la entidad.

ABC Company - Risk Assessment Survey (Top 5 Inherent Risks)

3. Risk 1 of 5

6. Describe a risk that threatens the business objectives of your area of responsibility:

7. What is the likelihood that, if unmitigated, this risk could occur?

☐ Probable - Highly likely to happen in the next 1 - 2 years

☐ Possible - Possible to happen in the next 1- 2 years

☐ Unlikely - Unlikely to happen in the next 1 - 2 years

8. What would be the consequence of this risk occurring?

☐ Catastrophic - Seriously threatens the viability of the organization's strategic objectives

☐ Damaging - Substantial effect on the achievement of strategic objectives

☐ Minor - Noticeable effect on strategic objectives, consequence would effect efficiency

[<< Prev](#) [Next >>](#)

Estructura tradicional de filosofía y políticas para la administración de Riesgos.



Filosofía de Gestión de Riesgos

- El conjunto de creencias y aptitudes compartidas que caracterizan cómo la organización considera el riesgo en todo lo que hace, lo cual es muy cercano a la cultura de riesgo.
- La filosofía de administración de riesgos/cultura de riesgo dependen mucho de:
 - La historia de la entidad.
 - El nivel de madurez y desarrollo organizacional (número de años en operación).
 - Tamaño
 - Localización
 - Principios de control gerencial y estilo operativo.
- La política de Riesgo y el Apetito al Riesgo reflejan la filosofía de administración de riesgos de la organización.

Ejemplo de una filosofía de gestión de riesgos

Visión para la Administración de Riesgos:

- Las unidades de negocios de las organizaciones consideran los riesgos inherentes en sus estrategias en orden para lograr sus objetivos de negocios y corporativos, para entregar al accionista un retorno adecuado. Las organizaciones están desarrollando e implantando un enfoque común y sistemático para la Administración de Riesgos a través de todas las unidades de negocio. Tal enfoque incrementa la conciencia del riesgo, asegura una administración de riesgos apropiada y proporciona transparencia de los perfiles de riesgos de los negocios, habilitando la comparación y adición de nuevos riesgos.
- Las unidades de negocios participan activamente y administran sus riesgos, tomando ventaja de las oportunidades y conteniendo potenciales amenazas en línea con su tolerancia al riesgo. Las unidades de negocio enfrentan los riesgos internos y externos constantemente y el negocio proactivamente.

Ejemplo de una filosofía de gestión de riesgos

Visión para la Administración de Riesgos:

- Utiliza las experiencias aprendidas a través del conocimiento compartido.
- Enfrenta la ambigüedad, incertidumbre y el incremento de la complejidad.
- Prioriza, toma decisiones y logra soluciones de manera oportuna.
- Reconoce y actúa a medida que las oportunidades se presentan.
- Asegura los resultados en un ambiente de negocios cambiante.

¿Cómo evaluar la filosofía de gestión de riesgos?

- **Encuesta de Cultura de Riesgo**

- Una medida de referencia de la cultura y prácticas de riesgo de la organización.
- Validar directo con el personal si la estrategia es comprendida y está alineada.
- Un punto de inicio para desarrollar un marco de Administración de Riesgos de negocio robusto.
- Proporciona una vista de los riesgos empresariales y que tan preparada está la organización para moverse hacia una administración de riesgos y controles continúa.
- La Dirección envía el mensaje de que piensa seriamente en mejorar la administración de riesgos a los empleados.

Política de administración de riesgo – actividades relacionadas:

- Crear, confirmar y actualizar una política de administración de riesgos organizacional que defina los conceptos claves de riesgos definidos por la dirección, sus roles y responsabilidades.
- Incorporación de principios de administración de riesgos en las políticas existentes que manejan actividades organizacionales específicas.
- Creación de políticas que manejen áreas específicas tales como riesgo de crédito o eventos específicos.
- Creación de una política formal escrita que documente el comportamiento actual que no esté documentado.

Ejemplo de Política de Administración de Riesgos

- Es política de la organización ABC buscar oportunidades que involucren algún nivel de riesgo para lograr los resultados económicos y operativos, y cumplir las expectativas de nuestros accionistas. Nuestra política es dar una completa y debida consideración al balance entre riesgos y recompensas de forma tal que soporten el logro de nuestras metas organizacionales.
- ABC aplicará y utilizará un marco de administración de riesgos consistente para la administración del cumplimiento.
- Los riesgos son definidos como eventos futuros inciertos que podrían influenciar el logro de los objetivos de ABC incluyendo objetivos económicos, reputacionales y de cumplimiento.
- El apetito al riesgo es definido por ABC como la selección conciente de riesgos que la organización tomará. Las actividades o negocios (y sus riesgos asociados) que ABC debería tomar o no.
- La tolerancia al riesgo se define en ABC como la sensibilidad a la exposición al riesgo.

Ejemplo de Política de Administración de Riesgos

- Nuestra política respecto a las metas del grupo es que cualquier evento futuro incierto o circunstancias las cuales podrían influenciar el logro de esas metas serán identificadas, analizadas, respondidas y monitoreadas para proteger a ABC de pérdidas, incertidumbre y pérdidas de oportunidad.
- A la aplicación de esta política se le dará la máxima prioridad.
- La política es soportada por:
 - Técnicas analíticas diseñadas para asistir en la identificación y evaluación de los riesgos.
 - Procesos de respuestas diseñados para optimizar el perfil de riesgo al que está expuesto ABC.
 - Un conjunto de indicadores de desempeño y técnicas de comunicación que aplican a través de ABC para asegurar asignación de responsabilidades y el monitoreo y medición de los resultados esperados y las excepciones a todos los niveles de ABC.

Apetito de Riesgo

- Es el nivel de riesgo, considerando un entorno amplio, que una empresa está dispuesta a aceptar para lograr sus objetivos de negocio.
- Refleja la filosofía de gestión de riesgo de la empresa e impacta a su vez en su cultura y estilo operacional.
- Ayuda a la alta gerencia a seleccionar una estrategia coherente con el riesgo aceptado.
- Puede expresar de un modo cualitativo (alto, moderado o bajo) o cuantitativo (ingresos económicos y metas de crecimiento alineados que los riesgos aceptados).

Apetito de Riesgo– Algunas Preguntas Claves

- ¿Qué riesgos la organización tomaría en nuevas iniciativas?
(por ejemplo: nuevas líneas de productos)
- ¿Qué riesgos la organización acepta por objetivos de competencia?
(por ejemplo: ganancia neta vs. participación de mercado)

Junta Directiva

- Es una parte crítica del ámbito interno e influye de modo significativo en sus elementos.
- La Junta Directiva debe ser activa y poseer una adecuada experiencia dirección y conocimientos técnicos de la industria y de otro tipo, al igual que la visión necesaria para llevar a cabo responsabilidades de supervisión.
- Debe estar preparada para cuestionar y fiscalizar las actividades de la Alta Gerencia, presentar enfoques alternos y actuar frente a prácticas ilícitas.
- Para que el ámbito interno sea eficaz, la Junta Directiva debería estar conformada en su mayoría por consejeros externos e independientes.
- Para que la Junta Directiva sea eficaz debe asegurar que la Alta Gerencia mantenga una adecuada gestión de riesgos corporativos.

Integridad y Valores Éticos

- Muy importante dentro del ámbito interno de una empresa e inciden directamente sobre el diseño, administración y seguimiento de los otros componentes de la gestión de riesgos corporativos.
- Los códigos formales de conducta corporativa son importantes por ser una declaración proactiva de las posiciones de la empresa frente a las cuestiones éticas , de cumplimiento y regulatorias.
- Los códigos formales de conducta corporativa deber comunicados formalmente y presentados de forma clara y precisa a todos el personal para garantizar su adecuada aplicación.
- Una aplicación efectiva en la empresa incluyendo al nivel más alto (CEO y alta gerencia) contribuirá positivamente a que los miembros de la empresa hagan lo correcto, tanto desde el punto de vista legal como moral.

Integridad y Valores Éticos

Ejemplo – Canales de comunicación

Los canales ascendentes de comunicación permiten al personal aportar información de manera efectiva y confidencial.

Identificación del denunciante

Identificación de la identidad de la persona que denuncie irregularidades

Canales abiertos de comunicación

Anonimato Parcial

Se conoce al denunciante pero no se divulga su identidad

Opción más utilizada. Cuenta con canales de comunicación bajo el control de unidades de gestión de ética y conducta

Anonimato Total

Conservación del anonimato absoluto de quien denuncie irregularidades

Cuenta con canales de comunicación confidenciales para conservar el anonimato

Fax, buzón de voz, números telefónicos directos y correo electrónico

Integridad y Valores Éticos

Ejemplo – Aspectos de Estructura del Código de Conducta

El código de conducta abarca temas importantes dentro de la empresa tales como:

- Conflictos de interés
- Regalos y gratificaciones
- Transparencia
- Recursos corporativos
- Responsabilidad Social



Competencia del Personal

- La competencia del personal refleja los conocimientos y habilidades necesarios para que realice las funciones que se le asignen.
- La Alta Gerencia establece los niveles de competencia para funciones específicas y los transforma en conocimientos y habilidades requeridos.



Estructura Organizativa

- La estructura organizativa de una empresa establece la base para planificar, ejecutar, controlar y supervisar las actividades del personal.
- Las empresas desarrollan una estructura organizativa centralizada y descentralizada de acuerdo a su tamaño y la naturaleza de sus negocios.
- Las empresas deben organizarse de tal manera que permitan una administración de riesgos corporativos eficaz, desarrollar sus actividades eficientemente y alcanzar sus objetivos.

Asignación de Autoridad y Responsabilidad

- La asignación de autoridad y responsabilidad determina el nivel hasta el que los individuos y equipos están autorizados y animados a utilizar su iniciativa para tratar los temas y resolver problemas, así como los límites de dicha autoridad.
- La delegación de autoridad significa traspasar el control central de algunas decisiones de negocio hacia niveles inferiores (por ejemplo: vender pólizas de seguro con descuentos, aprobar préstamos bancarios, otorgar licencias de operación, etc).
- El ámbito interno se ve muy influenciado por el grado de responsabilidad reconocido por los individuos y como estos se animan a aplicar iniciativas individuales dentro de límites de sus funciones.

Normas para Recurso Humano

- Contratación, orientación, formación, evaluación, tutoría, promoción, compensación y adopción de acciones de evaluación de desempeño transmiten mensajes al personal sobre los niveles esperados de la empresa en relación a la de integridad, conducta ética y competencia profesional.
- Las políticas de formación pueden potenciar los niveles esperados de rendimiento y conducta mediante la comunicación de los roles y responsabilidades futuras y la inclusión de prácticas
- Los traslados y ascensos impulsados por evaluaciones periódicas de desempeño muestran el compromiso de la empresa con la promoción de su personal cualificados.
- El personal de estar preparados para enfrentarse a nuevos retos a medida que los objetivos de negocios y riesgos cambian en la empresa.

Algunos atributos necesarios para la medición del ambiente interno en la organización:

- Liderazgo
- Responsabilidad social
- Valores éticos
- Estrategia
- Motivación
- Recursos
- Gratificaciones
- Conflicto de interés
- Filosofía de la organización
- Misión
- Visión
- Capacitaciones
- Delegación de funciones

Ejemplo de posibles preguntas que pueden integrarse en una encuesta del ambiente interno en la organización:

- La Dirección tiene el conocimiento y experiencia necesaria para identificar los controles claves en su área?
- Las responsabilidades y autoridad fueron delegadas al personal a cargo tomando en cuenta los niveles de competencia y experiencia del mismo?
- El recurso humano asignado es suficiente?
- El personal esta apropiadamente entrenado?
- La gerencia asigna las responsabilidades para la acción apropiadamente?



Caso Práctico - Ambiente Interno

Casos Prácticos #1

¿Cuáles de los factores que presentamos a continuación deben estar establecido dentro de una Organización como parte del Ambiente Interno?

- a.** Filosofía de administración de riesgo.
- b.** Riesgo aceptado.
- c.** Valores éticos.
- d.** Objetivos de información.

Casos Prácticos #2

¿De qué depende la filosofía de administración de riesgos?

- a.** Principios de control gerencial y estilo operativo.
- b.** Margen de ventas.
- c.** Historia de la entidad.
- d.** Lealtad de los empleados.



Establecimiento de Objetivos

Establecimiento de los objetivos

Los objetivos se establecen a nivel estratégico, estableciendo con ellos una base para los objetivos operativos, de reporte y de cumplimiento. Cada entidad se enfrenta a una gama de riesgos procedentes de fuentes externas e internas, y una condición previa para la identificación efectiva de eventos, la evaluación de sus riesgos y la respuesta a ellos es fijar los objetivos, que tienen que estar alineados con el riesgo aceptado por la entidad, que orienta a su vez los niveles de tolerancia al riesgo de la entidad.

Bases para el establecimientos de objetivos:

- El análisis de objetivos es ahora con frecuencia parte del marco de Referencia para la administración de riesgos.
- Los objetivos de negocios deben ser fácilmente entendibles y medibles, pero tienen diferentes grados de importancia y prioridad.
- Fuentes incluyen: planes de negocios, metas de desempeño, etc.
- Los objetivos de negocios pueden también ser categorizados.
- Los objetivos son establecidos a nivel estratégico, estableciendo una base para los objetivos operacionales, de reporte y de cumplimiento.
- El establecimiento de objetivos es una condición previa para la identificación de eventos, la evaluación de riesgos y la respuesta al riesgo efectiva (el contexto contra el cual evaluar eventos y riesgos).

Bases para el establecimientos de objetivos:

- Los objetivos son establecidos a nivel estratégico, estableciendo una base para los objetivos operacionales, de reporte y de cumplimiento.
- Los objetivos son alineados con el apetito al riesgo de la entidad el cual indica los niveles de tolerancia al riesgo para la entidad.
- La definición de objetivos debe fluir (efecto cascada) a través de la entidad.
- La definición de objetivos depende de:
 - El tipo de negocio;
 - La industria;
 - Preferencias;
 - Juicios;
 - El estilo administrativo.

Objetivos Estratégicos

Considerando la posibilidad de alcanzar los objetivos estratégicos, la dirección debe identificar los riesgos asociados a una gama amplia de elecciones estratégicas y considerar sus implicaciones empleando diferentes técnicas de identificación y evaluación de riesgos.

Objetivos Relacionados

Constituyen un factor crítico de éxito el establecimiento de objetivos adecuados que apoyen a la estrategia seleccionada, correspondiente a todas las actividades de la entidad, y estén en línea con ella.

Establecimiento de los objetivos

Interrelación entre misión/visión con los objetivos estratégicos y relacionados



Etapas en la evaluación del proceso de establecimientos de objetivos

Una gestión de riesgo empresarial contribuye a que la gerencia tenga un proceso que alinee los objetivos estratégicos con la misión de la entidad asegurando que la estrategia seleccionada y los objetivos seleccionados sean consistentes con el apetito al riesgo de la entidad

- **Etapas 1:**
 - Identificar el personal clave de la entidad y sus indicadores de valores claves.
- **Etapas 2:**
 - Identificar la visión, misión y los objetivos estratégicos de la entidad.
- **Etapas 3:**
 - Verificar si los objetivos estratégicos están alineados y balanceados con el personal clave, preferencias e indicadores de valores.
- **Etapas 4:**
 - Identificar la estrategia de la entidad.

Etapas en la evaluación del proceso de establecimientos de objetivos

- **Etapas 5:**
 - Determinar el apetito al riesgo y evaluar si está alineado con la estrategia.
- **Etapas 6:** (condición: los objetivos son claros y consistentes).
 - Identificar los objetivos de la entidad.
 - Nota 1: debe ser tan simple y claro como sea posible.
 - Nota 2: debe estar basado en los valores de los indicadores claves para los personal claves'.
- **Etapas 7:**
 - Categorizar los objetivos por el personal clave, aspectos del “balanced score card” u otra clasificación aplicable.
- **Etapas 8:**
 - Determinar la tolerancia del riesgo por tipo de objetivo y evaluar si está alineado con el apetito al riesgo de la entidad.

Etapas en la evaluación del proceso de establecimientos de objetivos

- **Etaapa 9: (opcional)**
 - Identificar si los factores críticos de éxito y los indicadores de desempeño han sido establecidos.
 - Verificar si los mismos están alineados con los objetivos y los indicadores claves de valor.
- **Etaapa 10: (opcional)**
 - Priorizar los objetivos por impacto al negocio a corto y a largo plazo.
 - Balancear las diferentes necesidades e intereses de los diferentes personal clave y seleccionar.
 - Dibujar una matriz de objetivos.
 - Nota 3: Relacionar los objetivos a los procesos (dependiendo del nivel en la organización: entidad, procesos, actividad) (condición: claro y consistente esquema de proceso jerárquico).

Tolerancia al riesgo

Niveles aceptables de desviación relativa a la consecución de objetivos. Operar dentro las tolerancias al riesgo proporciona a la dirección una mayor confianza en que la entidad permanece dentro de su riesgo aceptado, que, a su vez, proporciona una seguridad más elevada de que la entidad alcanzará sus objetivos.

Características:

- Es el nivel aceptable de variación alrededor de los objetivos.
- La tolerancia al riesgo es medible, preferiblemente en las mismas unidades de los objetivos relacionados.
- Al establecer la tolerancia al riesgo la gerencia considera la importancia relativa de los objetivos relacionados.
- La tolerancia al riesgo se alinea con el apetito al riesgo.



Caso Práctico – Establecimiento de Objetivos

Caso Práctico

¿Cuál de siguientes objetivos estratégicos se alinea a la visión de la Organización ABC?

- **Visión:** Convertirnos en el proveedor líder y de confianza de servicios financieros para las familias de la región, contribuyendo de este modo al desarrollo de las comunidades en que operamos.
 - a. Extender la red de oficinas hacia nuevas áreas que correspondan con su grupo demográfico objetivo.
 - b. Reducir la red de oficinas al 50% de su tamaño actual, reforzando de manera significativa sus servicios por Internet y de atención telefónica.
 - c. Mantener la red de oficinas y subcontratar las operaciones existentes por Internet y de atención telefónica a una compañía de menor costo.



Identificación de Eventos

Identificación de eventos

La dirección identifica los eventos potenciales que, de ocurrir, afectarán a la entidad y determina si representan oportunidades o si pueden afectar negativamente a la capacidad de la empresa para implantar la estrategia y lograr los objetivos con éxito. Los eventos con impacto negativo representan riesgos, que exigen la evaluación y respuesta de la dirección. Los eventos con impacto positivo representan oportunidades, que la dirección reconduce hacia la estrategia y el proceso de fijación de objetivos. Cuando identifica los eventos, la dirección contempla una serie de factores internos y externos que pueden dar lugar a riesgos y oportunidades, en el contexto del ámbito global de la organización.

Factores externos que influyen en la identificación de eventos

- **Económicos:** Cambios de precios, disponibilidad de capital.
- **Mediambientales:** Inundaciones, incendios y terremotos que provocan daños a las instalaciones.
- **Políticos:** Elección de gobiernos con nuevos programas políticos, leyes y normas que influyen en la apertura en el acceso a mercados extranjeros o impuestos mayores o menores.
- **Sociales:** Cambios demográficos, costumbres sociales, actividades terroristas, que tienen como resultado cambios en la demanda de productos y servicios.
- **Tecnológicos:** Nuevos medios de comercio electrónico, que generan una mayor disponibilidad de datos.

Factores internos que influyen en la identificación de eventos

- **Infraestructura:** Apoyo a los centros de atención a clientes reducen el tiempo de inactividad del equipo y se mejora la satisfacción del cliente.
- **Personal:** Accidentes laborales, actividades fraudulentas causan pérdidas de personal disponible o monetarias, daños de imagen y paros en la producción.
- **Procesos:** Modificación de eventos sin adecuados protocolos provocan pérdidas de cuota de mercado, ineficiencia e insatisfacción y pérdidas de clientes.
- **Tecnología:** Fallos de seguridad, potenciales caídas de los sistemas dan lugar a atrasos en la producción e incapacidad para continuar las operaciones del negocio.

Técnicas de identificación de eventos:

- Investigación de escritorio
- Entrevistas
- Talleres
- Encuestas
- Inventarios de eventos
- Análisis de flujo de procesos
- Indicadores de los eventos
- Metodologías de eventos de pérdida

Importancia de la categorización de eventos:

- Entendimiento de las relaciones entre eventos.
- Obtención de mejor información para la evaluación de riesgos.
- La dirección puede determinar mejor las oportunidades y riesgos.
- Permite a la dirección considerar la totalidad de los esfuerzos aplicados a su identificación.



Caso Práctico – Identificación de Eventos

Caso práctico #1

- **Qué son eventos críticos y cómo se relacionan a los riesgos?**

Los eventos tienen un impacto negativo y positivo. Los de impacto negativo representan riesgos y los de impacto positivo representan oportunidades.

- **Mencione algunas herramientas, técnicas y métodos se utilizan para identificar eventos claves.**

- a. Talleres de trabajo y entrevistas
- b. Encuestas
- c. Análisis de flujo del proceso

- **Cómo se asegura la calidad del proceso de identificación de eventos?**

Al utilizar las técnicas y herramientas para identificar eventos, así como la experiencia y experiencia de los miembros del equipo.

Caso práctico #2

Cómo usted categoriza los eventos que se presentan a continuación?

- Movimientos en precios, tarifas o índices asociados al valor de la moneda, tasas de interés y precios de la materia amenazan el valor de los activos de la Organización ABC.
 - a. Fuente Externa / Económico**
- Un terremoto, tormenta o fuego da lugar a daños materiales y responsabilidad a terceras partes.
 - b. Fuente Externa / Ecológico**
- Modificaciones a la leyes y regulaciones que rigen a la industria.
 - c. Fuente Externa / Político**
- Dificultad para atraer y mantener personal en cantidad suficiente.
 - d. Fuente Interna / Personas**
- Carencia de información/reportes para manejar con eficacia la organización.
 - e. Fuente Interna / Tecnología**



Evaluación de Riesgos

Evaluación de riesgos

La evaluación de riesgos permite a una entidad considerar la amplitud con que los eventos potenciales impactarán en la consecución de objetivos. La dirección evalúa estos acontecimientos desde una doble perspectiva – probabilidad e impacto- y normalmente usa una combinación de métodos cualitativos y cuantitativos. Los impactos positivos y negativos de los eventos potenciales deben examinarse, individualmente o por categoría, en toda la entidad. Los riesgos se evalúan con un doble enfoque: riesgo inherente y riesgo residual.

Diferencia entre Riesgo Inherente y Riesgo Residual

Riesgo Inherente

Es aquel al que se enfrenta una entidad en ausencia de acciones de la dirección para modificar su probabilidad e impacto.

Riesgo Residual

Es el que permanece después de que la dirección desarrolle sus respuestas a los riesgos.

Técnicas de Evaluación de riesgos

- **Cualitativas:** Se usan en actividades más complejas y sofisticadas, para complementar las técnicas cualitativas. (Ejemplo: Benchmarking, modelos probalísticos y no probalísticos.)
- **Cuantitativas:** Exigen mayor grado de esfuerzo y rigor. Dependen mucho de la calidad de los datos y resultan más relevantes para riesgos con un historial conocido.



Caso Práctico – Evaluación de Riesgos

Caso práctico

- **Cuál es la diferencia entre Riesgo Inherente y Residual?**

El Riesgo Inherente es aquel al que se enfrenta una entidad en ausencia de acciones de la dirección para modificar su probabilidad o impacto. El Riesgo Residual es el que permanece después de que la dirección desarrolle sus respuestas a los riesgos.

- **Cómo priorizaría los riesgos y cuál es la relación con el apetito al riesgo y la tolerancia al riesgo de la organización?**

Los riesgos pueden ser priorizados mediante técnicas cualitativas y cuantitativas a través de diferentes escalas de medición. Los resultados obtenidos pueden determinar si los mismos están de acuerdo al apetito y tolerancia al riesgo que la organización esta dispuesta a aceptar.



Respuesta a Riesgos

Respuesta a los riesgos

Una vez evaluados los riesgos relevantes, la dirección determina cómo responder a ellos. Las respuestas pueden ser las de evitar, reducir, compartir y aceptar el riesgo. Al considerar la respuesta, la dirección evalúa su efecto sobre la probabilidad e impacto del riesgo, así como los costos y beneficios, y selecciona aquella que sitúe el riesgo residual dentro de las tolerancias al riesgos establecidas. La dirección identifica cualquier oportunidad que pueda existir y asume una perspectiva del riesgo globalmente para la entidad o bien una perspectiva de la cartera de riesgos, determinando si el riesgo residual global concuerda con el riesgo aceptado por la entidad.

Categorías de respuestas a los riesgos:

- **Evitar:** Implica el cese de una línea de producto, frenar la expansión hacia un nuevo mercado geográfico o la venta de una división.
- **Reducir:** Implica a realizar acciones para reducir la probabilidad o el impacto del riesgo o ambos conceptos a la vez.
- **Compartir:** Trasladando o compartiendo una parte del riesgo. Las técnicas comunes incluyen la contratación de seguros o la externalización de una actividad.
- **Aceptar:** No se emprende ninguna acción que afecte la probabilidad o el impacto del riesgo

Consideraciones para determinar a respuesta a los riesgos

- Considerar los efectos de las respuestas potenciales sobre la probabilidad y el impacto del riesgo y qué opciones de respuesta están en línea con las tolerancias al riesgo de la entidad.
- Tomar en cuenta los costos y beneficios de las respuestas potenciales.
- Considerar las posibles oportunidades para alcanzar los objetivos de la entidad, lo que va más allá del tratamiento de un riesgo concreto.



Caso Práctico – Respuestas a los Riesgos

Caso Práctico #1

- Una organización sin ánimo de lucro identificó y evaluó los riesgos generados por el suministro directo de servicios médicos a sus miembros y decidió no aceptar los riesgos correspondientes, decidiendo facilitar en su lugar un servicio de referencia a terceros.

¿Cuál de las siguientes respuestas al riesgo, fue utilizada?

- a. Aceptar
- b. Reducir
- c. Compartir
- ☒ d. Evitar

Caso Práctico #2

- Mediante la aprobación de sus asociados, la Organización ABC adquirió una nueva flota de autos para los cobradores y así apuntar a uno de los objetivos de reducir los niveles de morosidad en la cartera de préstamos a través de una campaña de cobros más fuerte. Sin embargo, evaluó que la mayoría de los cobradores tienen poca experiencia conduciendo autos indicando un alto riesgo de accidentes. Para esto la gerencia tiene las siguientes opciones:
 - Incluir a los cobradores en escuelas de manejo de autos.
 - Contratar pólizas de automóvil, accidentes personales y de vida para los cobradores.
 - No hacer nada y apostar a la poca experiencia de los cobradores.

Qué tipo de respuesta al riesgo representa cada una de estas opciones?

- a. Reducir
- b. Compartir
- c. Aceptar



Actividades de Control

Actividades de control

Las actividades de control son las políticas y procedimientos que ayudan a asegurar que se llevan a cabo las respuestas de la dirección a los riesgos. Las actividades de control tienen lugar a través de la organización a todos los niveles y en todas las funciones. Incluyen una gama de actividades tan diversas como aprobaciones, autorizaciones, verificaciones, conciliaciones, revisiones del funcionamiento operativo, seguridad de los activos y segregación de funciones.

¿Cómo las actividades de control apoyan a las respuesta al riesgo?

- **Prevención:** Para frenar ciertas transacciones antes de ejecución
- **Detección:** Para identificar otras transacciones oportunamente.
- **Informáticos y manuales:** Aseguran la captación correcta de la información y procedimientos de autorización y aprobación de las decisiones por parte de personas responsables.

Políticas y procedimientos

Las actividades de control comúnmente integran dos componentes:

- Política: Establece lo que debe hacerse.
- Procedimientos: Cómo debe hacerse.

Comunicación de las políticas y procedimientos:

- Verbal: Son eficaces cuando la política lleva años en vigor y constituya una práctica bien comprendida y una interacción estrecha junto con la supervisión del personal
- Escrito: Con evaluaciones o actualizaciones periódicas.

Controles de Sistemas de Información

- Los controles de tecnología de información incluyen controles sobre la administración de la tecnología, la infraestructura, administración de seguridad, aplicaciones, adquisición, desarrollo y mantenimiento. Estos controles aplican a todos los sistemas desde el servidor principal hasta las estaciones de trabajo.
- Los controles de aplicación están diseñados para asegurar la totalidad, exactitud, autorización y validez de transacciones de datos y su procesamiento. Los mismos incluyen un diverso tipo de aprobaciones, autorizaciones, verificaciones, reconciliaciones, revisiones, seguridad de activos y segregación de funciones.

Ejemplos de establecimiento de actividades de control:

- Para reducir el riesgo de crear dos veces a un asegurado dentro del sistema, el Jefe del departamento de Afiliación debe revisar el reporte de inconsistencias diario y firmar como señal de aprobación.
- Con el objetivo de que los programas desarrollados por el departamento de informática sean transferidos al ambiente de producción, los mismos deben ser aprobados y autorizados por el Director de Informática.



Caso Práctico – Actividades de control

Caso Práctico

Con relación al componente anterior Respuesta al Riesgo, la Organización SCC se basó en la tolerancia al riesgo y el costo de compartir con una aseguradora y decidió adquirir seguros con coberturas de automóvil, vida y accidentes personales para los cobradores.

¿Qué actividades de control y quiénes deberían asegurar la implementación de la respuesta al riesgo?

- a. Asociados de la Organización a través de la información presentada en la Asamblea General.
- b. Gerencia de Recursos Humanos, por medio de revisión de los beneficios otorgados a los empleados de la organización.
- c. Consejo de Vigilancia a través del Departamento de Auditoría Interna. El cual debe revisar periódicamente las coberturas de la empresa, así como su cumplimiento con las condiciones del acuerdo con la aseguradora.



Información y Comunicación

Información y comunicación

La información pertinente se identifica, capta y comunica de una forma y en un marco de tiempo que permiten a las personas llevar a cabo sus responsabilidades. Los sistemas de información usan datos generados internamente y otras entradas de fuentes externas y sus salidas informativas facilitan la gestión de riesgos y la toma de decisiones informadas relativas a los objetivos.

Información

- La información viene de varias maneras internas y externas, y de manera cualitativa y cuantitativa. El reto para la gerencia es el procesar y definir grandes cantidades de datos en información utilizable de una manera segura.
- El diseño de sistemas de información y la adquisición de tecnologías es importante para la estrategia de la organización, y las opciones en relación a la tecnología puede ser crítica para alcanzar los objetivos.

Comunicación

- La comunicación juega un rol mucho más amplio, como por ejemplo lidiar con las experiencias y responsabilidades de los individuos y grupos. La comunicación puede tomar varias formas como manuales de políticas, memorando, e-mails, tableros de noticias o webcast.
- La comunicación debe crear conciencia sobre la importancia y relevancia de ERM, comunicar el apetito al riesgo de la organización y su tolerancia a riesgos, apoyar a hablar un lenguaje común de riesgo.

Ejemplos de herramientas para la comunicación:

- Difusión mediante correos electrónicos.
- Boletines corporativos.
- Cartas de la Junta Directiva.
- Memos de la Dirección
- Páginas de internet e intranet
- Carteles o murales

A magnifying glass with a film strip as a handle, symbolizing investigation and communication. The magnifying glass is positioned over a document, and the film strip handle is visible on the right side. The background is a light blue gradient.

Caso Práctico – Información y comunicación

Caso práctico

Se están estudiando a nivel gubernamental la posibilidad de hacer modificaciones a la ley que rige la industria y por consiguiente la Gerencia General de la Organización ABC, necesita enviar información relacionada a sus empleados (alrededor de 150 empleados) sobre dichos cambios en la ley para que sea analizado y verificar el impacto que pueda ocasionar a los objetivos de la Organización .

Qué vehículos de comunicación consideraría utilizar?

- a. Difusión a través de correos electrónicos.
- b. Boletines corporativos.
- ☒ c. Encuentros personales periódicos entre las gerencias o comités de la Organización.
- d. Convocar a una Asamblea General.



Monitoreo y Supervisión

Monitoreo y supervisión

La gestión de riesgo corporativo se supervisa – revisando la presencia y funcionamiento de sus componentes a lo largo del tiempo, lo que se lleva a cabo mediante actividades permanentes de supervisión, evaluaciones independientes o una combinación de ambas técnicas.

Revisiones continuas

- El monitoreo continuo ocurre en el curso de las operaciones.
- Incluye actividades regulares de dirección y supervisión y, otras acciones que el personal realiza para desempeñar sus tareas.
- Un proceso de ERM debe estructurarse para permitir que él mismo sea monitoreado.
- A mayor y más efectivo monitoreo continuo menor la necesidad de evaluaciones separadas.
- Consiste en análisis de variaciones, comparación de información con diferentes fuentes, y diligenciar con hechos no esperados.
- Normalmente ejecutado por la línea operacional del negocio o gerentes de soporte funcional.
- Hace énfasis en las inconsistencias, implicaciones relevantes, relaciones preestablecidas, etc.

Revisiones separadas

- Mientras las evaluaciones continuas proveen un importante “feedback” de la efectividad de la gestión de riesgos, puede ser útil que se haga de vez en cuando una mirada fresca de la gestión del proceso.
- Esto es posible si el foco de la revisión es comprobar directamente la efectividad del proceso de gestión de riesgos.

Alcance y Frecuencia

- Varían dependiendo de cada empresa, la importancia de los riesgos y la efectividad de los controles organizacionales relacionados.
- El foco es hacia los riesgos más significativos (probabilidad-impacto-efectividad de respuesta).
- Es más práctico si se dirige a los objetivos de la entidad: estratégicos, operacionales, de cumplimiento y reporte.

Quién reporta?

- Coordinadores de riesgo.
- Auditoría interna.
- La gerencia.

A quién se reporta?

- Comité de auditoria y/o riesgo.
- Alta gerencia.
- Dueños de controles o procesos.

Qué reportar?

- Exposiciones brutas y netas.
- Status y efectividad en implementación de alternativas de tratamiento al riesgo.
- Reportes de pérdidas operacionales históricas y esperadas.
- Resumen de incidencias o deficiencias.
- Comparación departamental, productos, divisiones, subsidiarias o procesos.

A magnifying glass with a black handle and a silver frame is shown in a close-up, low-angle shot. The lens is positioned over a small, dark, cylindrical object, which is the focus of the magnification. The background is a light, neutral color, and the lighting creates soft shadows and highlights on the glass and metal surfaces.

Caso Práctico – Monitoreo y supervisión

Caso Práctico

Indique el tipo de monitoreo (permanente o independiente) para las actividades de monitoreo que realiza la organización ABC y que listamos a continuación:

- La Gerencia financiera realiza revisiones de rendimientos comparándolos con los índices de riesgos a través de partidas de conciliación y balances.

a. Permanente

- Se establecieron nuevas estrategias para promocionar los productos de planes de ahorros a los asociados y por consiguiente se realizará una evaluación y seguimiento al comportamiento de los planes de ahorros.

a. Independiente

Caso Práctico #2

Indique la metodología que usted considera la más adecuada en una evaluación independiente:

- Dentro del alcance de una evaluación se incluye comprender y documentar las inconsistencias en el diseño del proceso de compras.
 - a. Benchmarking
 - b. Cuestionarios
 - ☒ c. Diagramas y matrices
- Los directores de un banco tienen como objetivo de negocio tener una participación en el mercado sobre los préstamos hipotecarios del 30%.
 - a. Sesiones moderadas
 - ☒ b. Benchmarking
 - c. Cuestionarios

GRACIAS

Auditoría Financiera basada en Evaluación de Riesgo

Contraloría General de la República de Panamá

Abril 2010

Facilitadores:

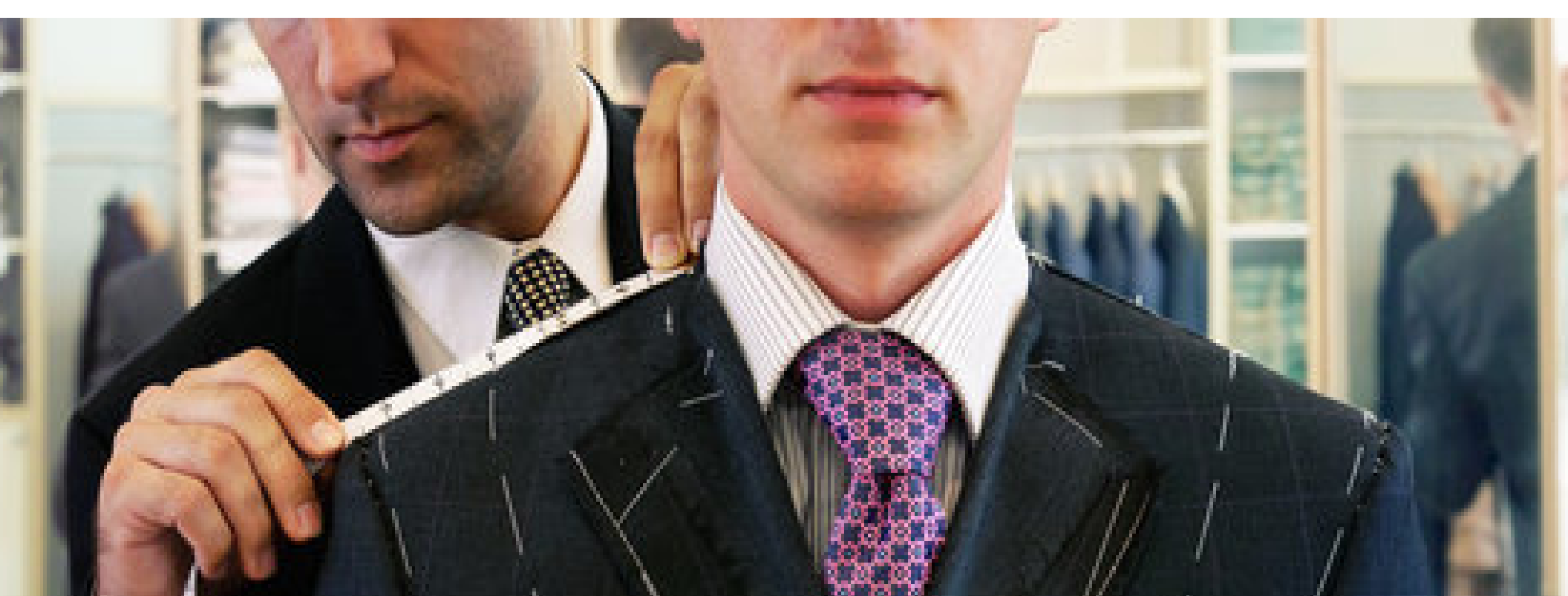
Julio R. Jolly Moore

Oswaldo Lau C.

Suhhel Nuñez

Román Poveda

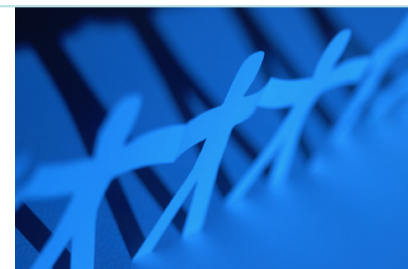




Auto-Evaluaciones de Riesgos y Controles

Definiciones

Es una técnica para el monitoreo de control en la cual se integra al proceso de evaluación de riesgos y controles a los responsables del proceso.



- 1. “Es un proceso a través del cual se examina y evalúa la efectividad del control interno. Su objetivo es entregar una garantía razonable de que se cumplirán los objetivos de una organización.”**

Fuente: Institute of Internal Auditors (IIA) – “Una perspectiva sobre Auto-Evaluación de Control” 1998.

- 2. “Proceso formal documentado, en el cual la gerencia y/o equipo de trabajo envuelto en la función de negocio: juzgan la efectividad del proceso llevado a cabo y deciden si la probabilidad de alcanzar alguno o todos los objetivos del negocio son razonablemente seguras.”**

Fuente: Control Self Assessment: Making the Choice, Glenda Jordan, 1995

Beneficios

- Mejora el entendimiento y crea mayor **responsabilidad** sobre la administración riesgos y controles.
- Mayor enfoque en los **riesgos significativos** porque los expertos en el proceso (*es decir los responsables por su ejecución diaria*) evalúan sus propios riesgos y controles.
- Las acciones correctivas son más eficientes porque los equipos de trabajo son **dueños y responsables** por los resultados de la Auto-Evaluación.
- Aumenta el nivel de **conciencia** sobre un ambiente de control efectivo a lo largo de toda la organización.
- Mejora el nivel de **comunicación** interna.

Responsabilidades

- Mediante un enfoque basado en Auto-Evaluaciones de Riesgos y Controles (CSA por sus siglas en inglés), algunas responsabilidades dentro de la organización cambian en relación al **enfoque tradicional** de auditoría.

Responsabilidad	Enfoque Tradicional	Enfoque CSA
Establecer objetivos de negocio	Alta Gerencia	Alta Gerencia
Establecer niveles de riesgo aceptable	Alta Gerencia	Alta Gerencia
Mantener el ambiente de control	Alta Gerencia	Alta Gerencia
Evaluar riesgos y controles	Auditores	Equipo de Trabajo
Reportar riesgos y controles	Auditores	Equipo de trabajo
Validar resultados de evaluaciones	Auditores	Auditores

Tipos de Auto-Evaluaciones

- Talleres de trabajo
- Cuestionarios
- Análisis de la Gerencia



Talleres (Tipos de Auto-Evaluaciones)

Los talleres son sesiones de trabajo dirigida por el auditor interno (o un experto) para evaluar los riesgos y controles de un objetivo o proceso de negocio.

CARACTERÍSTICAS

- Grupos de 5 a 10 personas
- Requieren mucha coordinación
- Pueden ser basados en:
 1. Objetivos
 2. Riesgos
 3. Controles
 4. Proceso

BENEFICIOS

- Mayor consenso de un grupo
- Permite una lluvia de ideas

Cuestionarios (Tipos de Auto-Evaluaciones)

Los cuestionarios (o encuestas) son una técnica que consta de una serie de preguntas simples y directas para identificar áreas de mejora, incumplimientos en políticas o debilidades o ineficiencias en los controles existentes.

CARACTERÍSTICAS

- Preguntas directas
- Respuestas simples (Sí o No)
- Escrito en lenguaje del dueño del proceso.
- Puede ser confidencial.

BENEFICIOS

- Resultados más rápidos.
- Menor costo.
- Es una guía para el auditor.
- Más familiar para el auditor y el equipo de trabajo.

Análisis de Gerencia (Tipos de Auto-Evaluaciones)

El análisis de la gerencia se refiere a un estudio de un proceso o del negocio mediante una combinación de fuentes de información como por ejemplo entrevistas o reportes del negocio.

CARACTERÍSTICAS

- Dirigido por la gerencia
- Puede ser cualitativo o cuantitativo

BENEFICIOS

- Respuesta rápida a una preocupación o preguntas
- Análisis más profundo del proceso

Auto-Evaluaciones en el Gobierno

- Deben permitir un ambiente de apertura que permitan al dueño del proceso reportar riesgos y reportar sobre la eficiencia de controles sin el temor a castigos o llamados de atención.
- Deben ser una solución de rápida respuesta y de costo relativamente bajo.





Cuestionarios de Auto-Evaluación

Ejemplo

Taller – Cuestionarios



Resumen



GRACIAS

Auditoría Financiera basada en Evaluación de Riesgo

Contraloría General de la República de Panamá

Abril 2010

Facilitadores:

Julio R. Jolly Moore

Oswaldo Lau C.

Suhhel Nuñez

Román Poveda





Guía para el desarrollo de un programa de Auditoría Interna basada en Riesgos

¿Qué es Auditoría Interna?

Definición del Instituto Internacional de Auditores:

Auditoría Interna es una actividad independiente, aseguradora objetiva y consultoría diseñada para agregar valor y mejorar las operaciones de una organización. Ayuda a una organización a cumplir con sus objetivos mediante un enfoque sistemático y disciplinado para evaluar y mejorar la gestión de riesgo, controles y procesos de goberabilidad.



¿Por qué contar con Auditoría Interna?

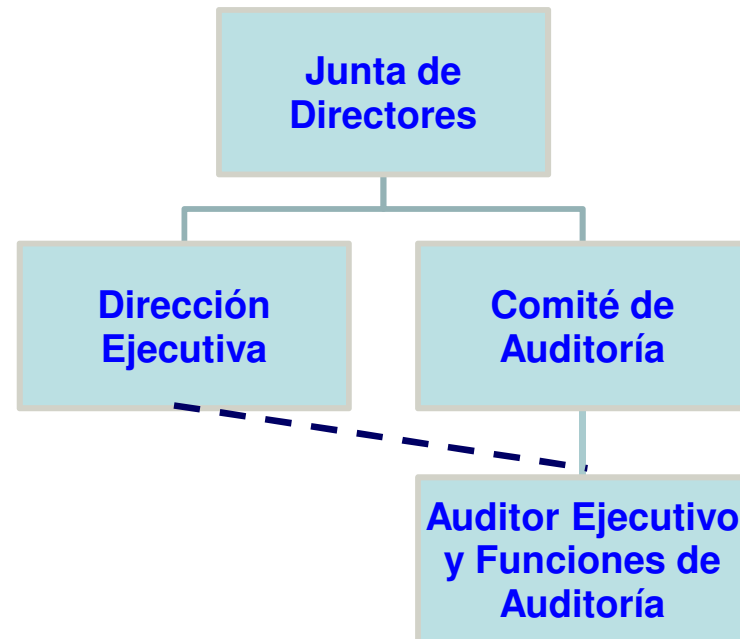
Desarrollar eficientemente las funciones de auditoría interna beneficiará a la organización a:

- Cumplir con sus objetivos estratégicos
- Mantener, validar, y mejorar controles internos
- Identificar oportunidades y mejorar procesos de negocio
- Mejorar la gobernabilidad

Valor ↑ *Costo y Riesgo* ↓

Independencia

Estructura de AI



Independencia

Definición del Instituto de Auditoría Interna:

Los auditores internos son independientes cuando realizan opiniones imparciales y objetivas durante la realización de su auditoría. Para asegurar su independencia, existen mejores prácticas que sugieren que el Auditor Ejecutivo debe reportar al Comité de Auditoría o su equivalente.



Objetividad

Definición del Instituto de Auditoría Interna:

Objetividad es una actitud mental que auditores internos deben mantener durante el desarrollo de su trabajo.

Para mantener la objetividad, auditores internos no deben estar involucrado de manera personal o profesional con el área auditada; y deben mantener una mentalidad imparcial con respecto a todas sus auditorías.



Instituto de Auditores Internos (IIA)

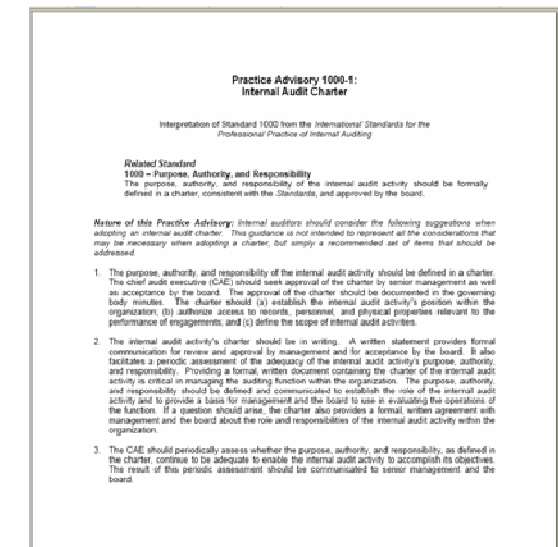
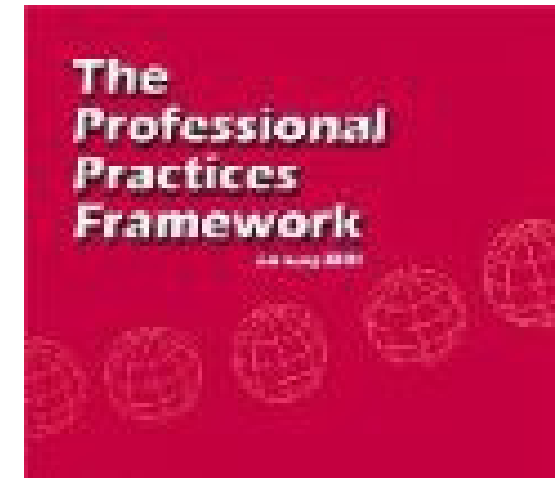
- El IIA provee una guía completa para la ejecución de Auditorías Internas y también provee una guía para la evaluación, mantenimiento y mejora de la calidad de las auditorías internas
 - Marco para las prácticas profesionales voluntarias (Estándares)
 - Código de Ética, Asesoría Práctica, Papeles de la Posición, Guías Prácticas
- Cumplimiento con los Estándares y Código de Ética es obligatoria para todos los miembros del IIA and Auditores Internos Certificados (CIAs)

<http://www.theiia.org/>



Instituto de Auditores Internos (IIA)

- Estándares IIA
 - Mandatoria (si es miembro de IIA)
 - Principios
 - Estándares de Atributos, Desempeño, e Implementación
- Asesorías Prácticas
 - Guía de IIA aprobadas en mejores prácticas
 - No obligatorias pero bien útiles
- Desarrollo y prácticas guías
 - Investigaciones, libros, seminarios, etc.





FASE 1 – Entendimiento del Negocio

Fase 1: Entendimiento del Negocio

Actividad 1.1 Entienda su mercado y negocio

Actividades

- Entienda el ambiente
- Entienda los procesos de negocio importantes
- Evalúe la Estructura Organizacional y Ubicaciones Importantes
- Evalúe Planes estratégicos y objetivos
- Evalúe los Sistemas de Información
- Entreviste a los encargados de administración
- Documente información recopilada

Plantillas:

Guía para entrevista

Referencias:

N/A

Estándares IIA :

Estandar de Desempeño 2010

Entregables:

Resumen Ejecutivo del ambiente del negocio

Fase 1: Entendimiento del negocio

Entender el mercado y operaciones

- Leer Estados Financieros del cliente
- Investigación puede incluir:
 - Información pública
 - Publicaciones

Fase 1: Entendimiento del negocio

Entender el mercado y operaciones

- **Entrevistar a:**
 - Alta Dirección (Operaciones, TI, RRHH, Legal, etc.)
 - Directiva / Comité de Auditoría
 - Auditoría Externa
- **Cuáles son sus:**
 - Objetivos estratégicos
 - Planes de negocios futuros
 - Bases de ingresos del negocio

Fase 1: Entendimiento del negocio

Entender el mercado y operaciones

- Establecer colaboraciones con los expertos de procesos
 - Técnicas para establecer colaboraciones
 - Calcule el valor de AI
 - Oportunidades para reducir costos
 - Sacar provecho a oportunidades existentes
 - Mejora de procesos
 - Capacidades de AI
- “Un puesto en la mesa” para AI (asentarse en actualizaciones regulares de gestión, comités para apoyar proyectos, etc.)

Fase 1: Entendimiento del Negocio

Actividad 1.2 Desarrollar el universo de Auditoría Interna

Tareas

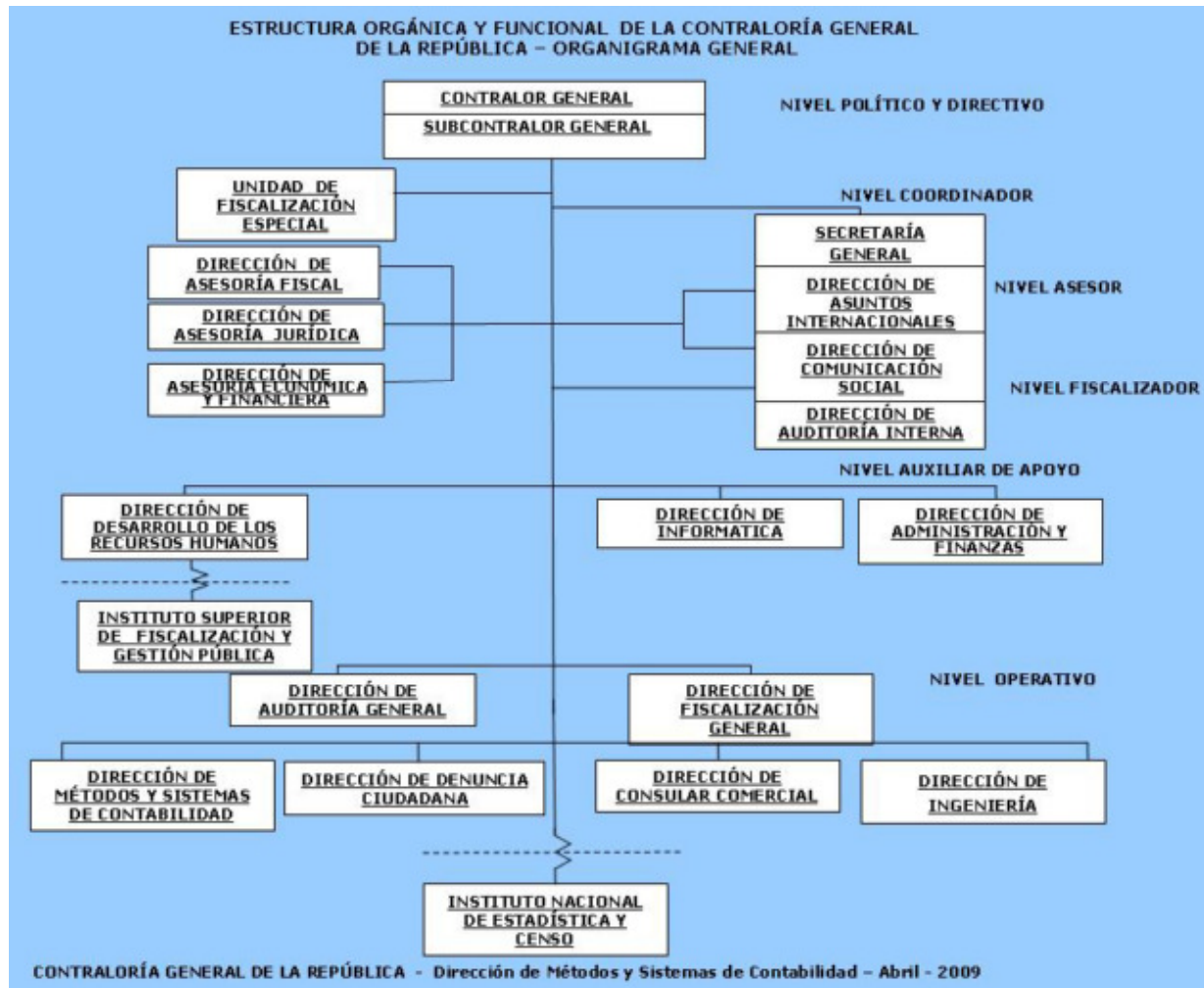
- Desarrollar el universo de Auditoría Interna

- El universo de AI es un resumen de las entidades de auditoría de la organización que serán incluidas en el análisis de riesgo anual y utilizado para desarrollar el Plan Anual de Auditoría.
- Una entidad de auditoría es un área de la organización que es lo suficientemente discreta para ser el sujeto de una auditoría interna.

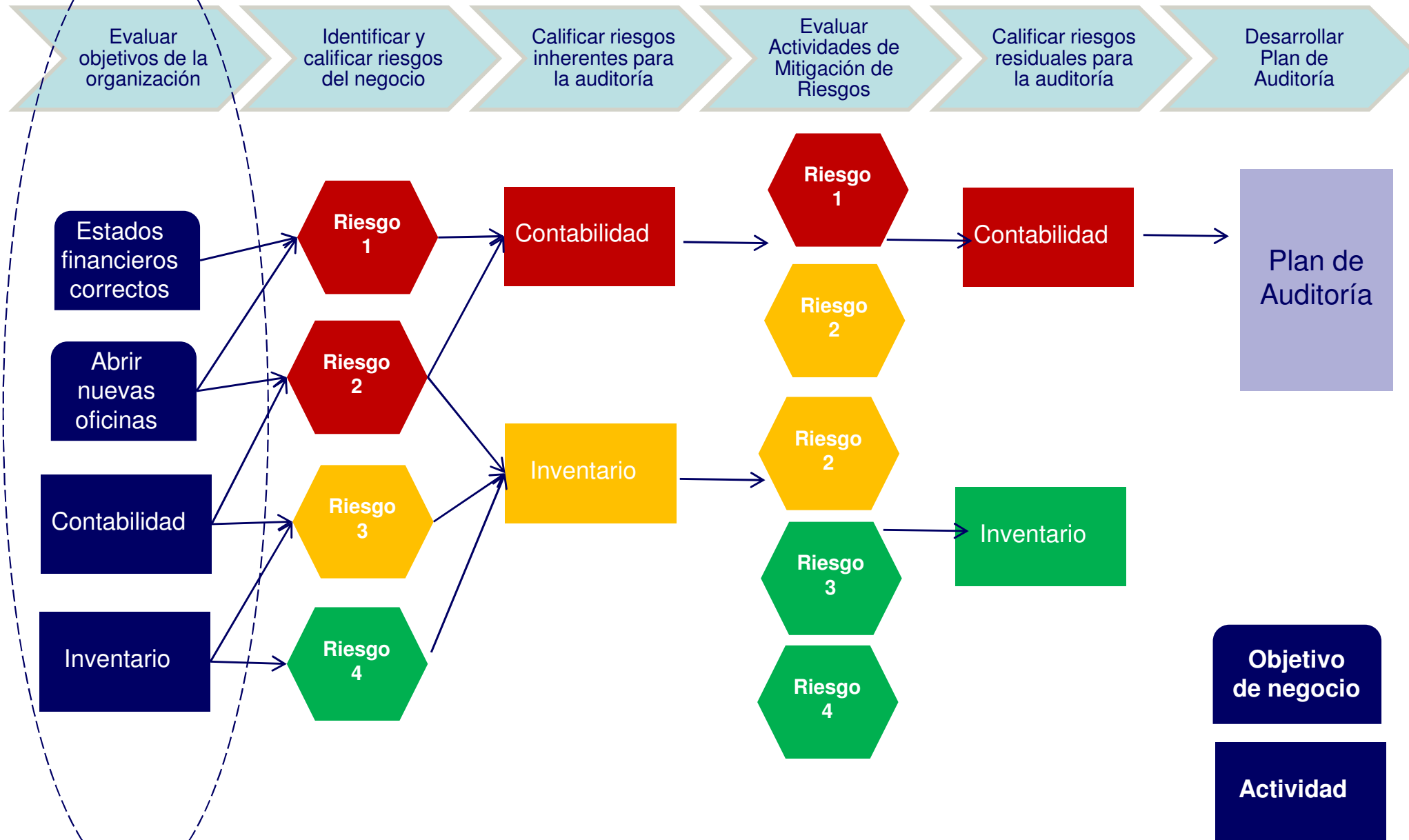
Fase 1: Entendimiento del negocio

Desarrollo del Universo de Auditoría

Las entrevistas realizadas e información recopilada anteriormente serán útiles en esta tarea.



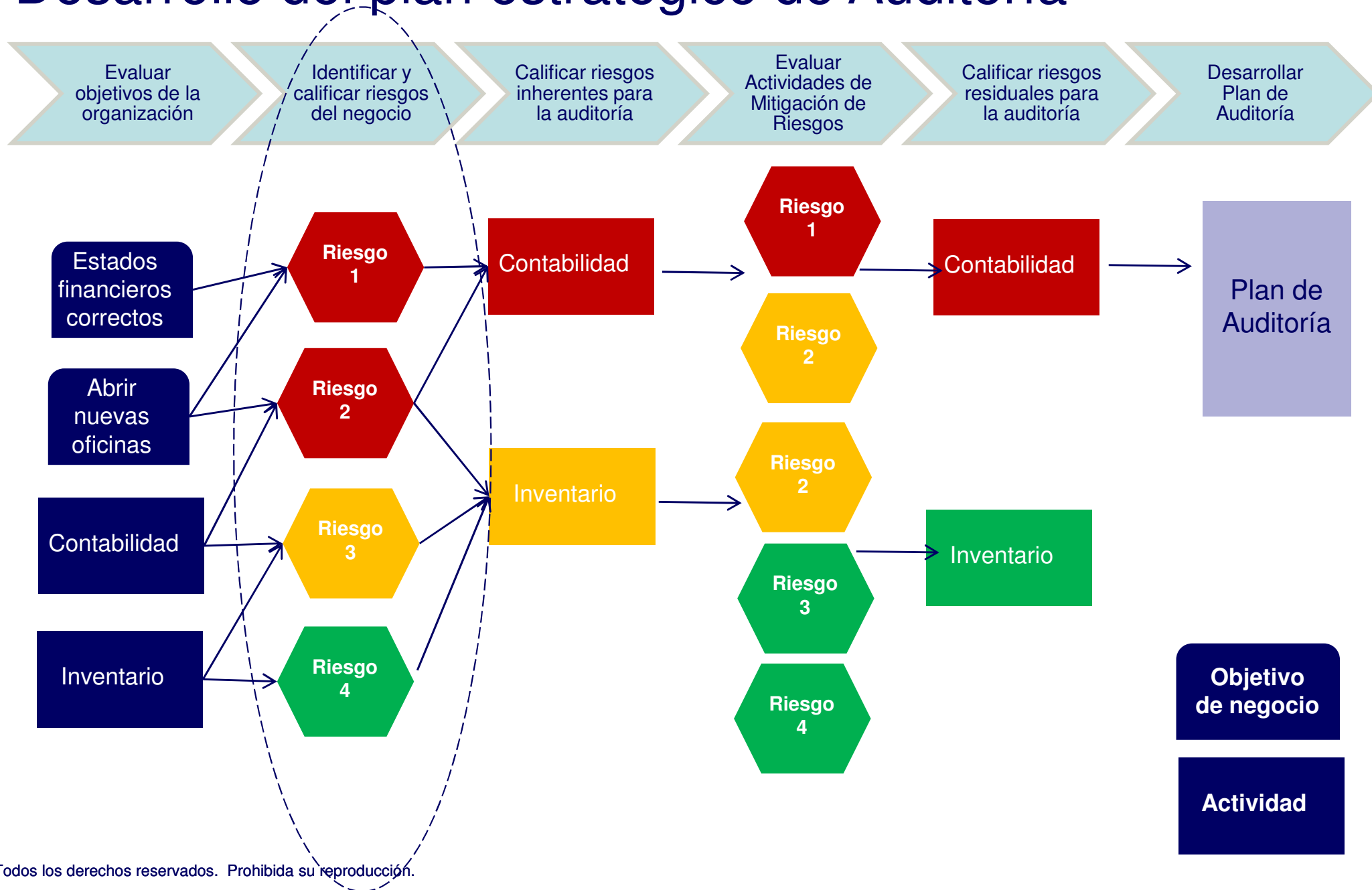
Desarrollo del plan estratégico de Auditoría





FASE 2 – Análisis de Riesgo y Desarrollo del Plan de Auditoría

Desarrollo del plan estratégico de Auditoría



Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Actividad 2.1 Identificar y Categorizar Riesgos del Negocio

Tareas

- Revisar objetivos de la organización
- Revisar métricas de riesgo y categorización
- Desarrollar y realizar encuestas
- Realizar entrevistas
- Identificar y categorizar riesgos

Plantillas:

Encuesta de Análisis de Riesgo
Guía de entrevistas
Presentación para educar a los participantes

Referencias:

Manual de COSO ERM
Estándares de Auditoría Interna
Manual de Políticas de Contraloría

Estándares IIA:

Estándar de desempeño 2010

Entregables:

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

¿Qué es Riesgo de Negocio?

- Cualquier evento o circunstancia que puede afectar a una organización para cumplir sus estrategias y objetivos.
- Categorías de riesgo
 - Estratégico
 - Operativo
 - Cumplimiento
 - Financiero

Riesgo de negocio es cualquier evento o acción que puede afectar la habilidad de una organización para sobrevivir y competir en el mercado, como también mantener su fortaleza financiera, imagen pública positiva y calidad general de su personal y servicios.

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Categoría de Riesgo

Estratégico	Operativo	Cumplimiento	Financieros
Riesgos relacionados con la implementación de estrategias de negocio equivocadas.	Riesgos relacionados a la operación diaria del negocio.	Riesgos relacionados a violar legislaciones relevantes y obligaciones contractuales.	Riesgos relacionados a gestionar, controlar y reportar riesgos financieros y de crédito de mercado.

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Riesgo Estratégico

- Pérdida de clientes claves
- Inhabilidad de responder a los ciclos críticos de negocio
- Mala investigación del mercado
- Competencia fuerte en el mercado
- Inhabilidad de responder a eventos externos

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Riesgo Operativo

- Pérdida de personal clave
- Manejo inadecuado de activos
- Demora en Proyectos
- Mala gestión de ingresos
- Mal servicio al cliente
- Falla de sistemas de TI y pérdida de información
- Acceso no autorizado a equipo de TI

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Riesgo de Cumplimiento

- Inhabilidad de cumplir con regulaciones vigentes
- Incapacidad de incumplir con licencias requeridas
- Malas practicas de privacidad de datos
- Inhabilidad de responder a solicitudes de entidades reguladoras
- Reformas legislativas
- Incapacidad de cumplir con prácticas de Salud y Seguridad Laboral
- Malas regulaciones para manejo de regalos al personal

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Riesgo Financiero

- Fraude o errores en los estados financieros
- Inhabilidad de mantenerse actualizado con prácticas financieras
- Inhabilidad de generar los estados financieros en el tiempo adecuado
- Mala categorización de riesgos al negocio
- Seguros inadecuados

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

¿Qué es el análisis de Riesgo del Negocio?

- Es un procesos que evalúa la posición de la empresa con respecto a los potenciales riesgos a través de áreas operativas y áreas clave de apoyo al negocio.
- Elemento clave del marco de Control Interno de COSO.
- Elemento clave en el Modelo COSO ERM. El modelo define riesgo y gestión de riesgo, proporciona las categorías, componentes, principios y otros elementos para un marco de referencia completo.

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Identificar el Riesgo del Negocio

- Sesión de concientización
- Encuestas
 - Herramientas en Internet
 - Plantillas de Encuestas
- Entrevistas
 - Preguntas
 - Máximo dos entrevistados
 - A quién se entrevista
 - Recolectar y compilar información
 - Para dueños de procesos su función es crítica
 - Manejar retroalimentación individual como parte del negocio
- Sesiones de trabajos dirigidas

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Realizar entrevista

Al realizar el análisis de riesgo el equipo debe estar formado por:

- Miembros de la Directo y Comité de Auditoría
- Directores Ejecutivos
- Contralor Financiero
- Jefe de RRHH y Jefe de TI
- Auditores Externos

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Puntos a considerar en la entrevista

- Preparar
 - Roles de los participantes
 - Preguntarse qué puede salir mal
 - Realizar preguntas abiertas
 - Planifique seguimientos necesarios
- Considere distribuir a los participantes los puntos a evaluar en la entrevista

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Identificar y Categorizar el Riesgo

- Riesgos son factores que pueden prevenir que una organización cumpla sus objetivos estratégicos.
- Basado en las entrevistas y encuestas, se debe capturar la siguiente información para cada riesgo. Esta información debe documentarse en un Excel o una aplicación para gestión de riesgo.
 - Vínculo con los objetivos de la organización (un riesgo puede vincularse a varios objetivos)
 - Descripción del riesgo
 - Consecuencias y probabilidades del riesgo
 - Relación con Fraudes (S/N)

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Identificar y Categorizar el Riesgo

- Se debe registrar
 - Categoría de Riesgo (Estratégico, Operacional, Cumplimiento, Financiero)
 - Causa del Riesgo (factores contribuyentes)
 - Fuente del riesgo (e.j., Director, Jefe de RRHH).

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Ejemplo – Categorías de Riesgos

Riesgo	Categoría
Mercados globales no producen el crecimiento deseado	Estratégico
Reporte financiero inexacto de las unidades de negocio	Financiero
Plan de Compensación de bonos diferidos no está conforme con requerimientos recientes.	Financiero

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Escalas de Categorización de Riesgos

Riesgo Inherente

Consecuencia

El impacto a las operaciones del negocio y su habilidad para cumplir objetivos estratégicos.

Bajo	Bajo impacto a las operaciones y la habilidad para cumplir con los objetivos estratégicos.
Moderado	Impacto considerable a las operaciones y la habilidad para cumplir con los objetivos estratégicos.
Alto	Alto impacto a las operaciones y la habilidad para cumplir con los objetivos estratégicos.

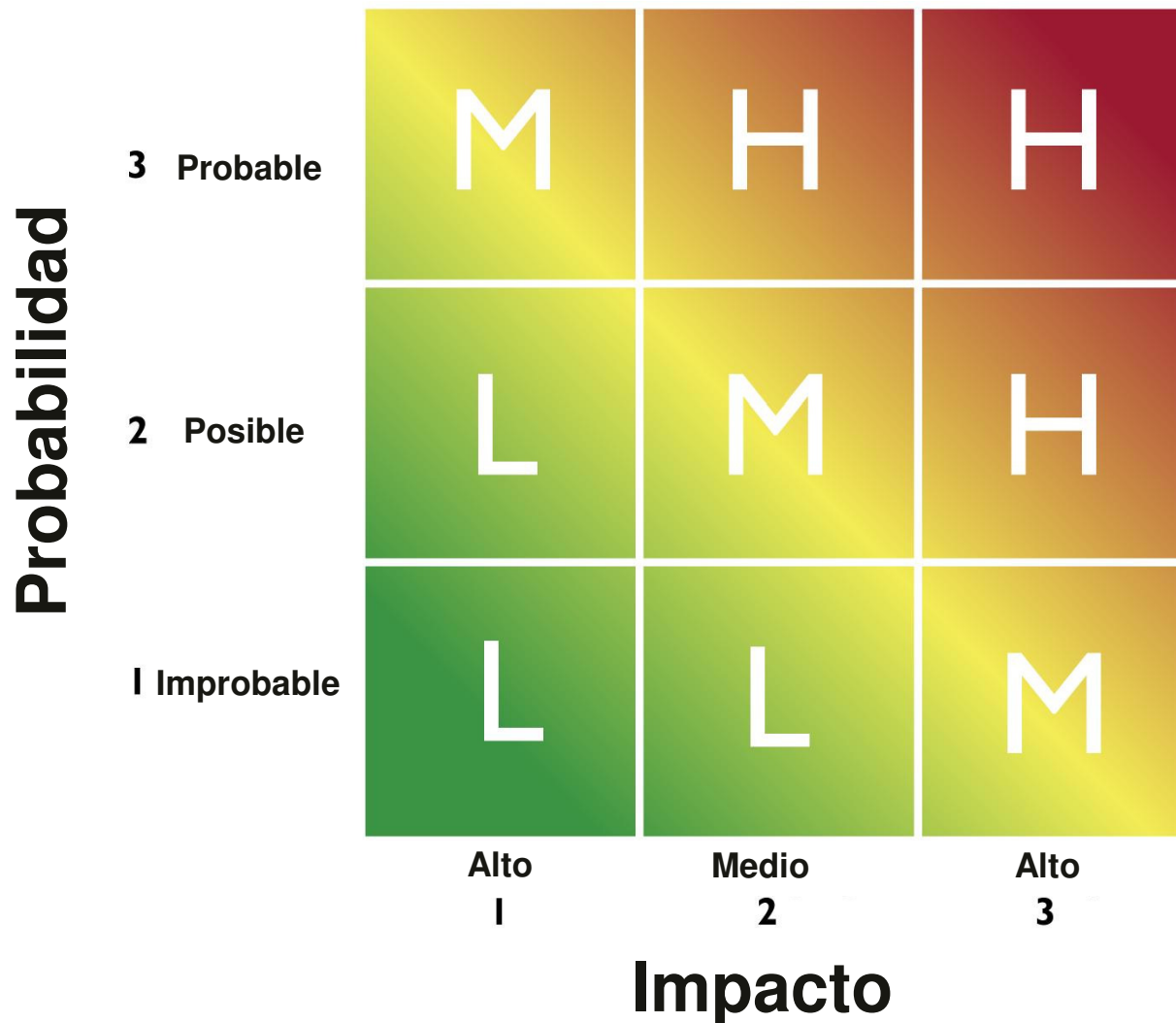
Probabilidad

Posibilidad de que el evento ocurra en los siguientes 1 a 3 años

Baja	Baja probabilidad de que ocurra en los siguientes 1 - 3 años.
Media	Probabilidad media de que ocurra en los siguientes 1 - 3 años.
Alta	Alta probabilidad de que ocurra en los siguientes 1 - 3 años.

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Mapa de Riesgo Inherente



Escala de Categorización

Consecuencia:

El impacto a las operaciones del negocio y la habilidad de cumplir con los objetivos estratégicos.

Probabilidad:

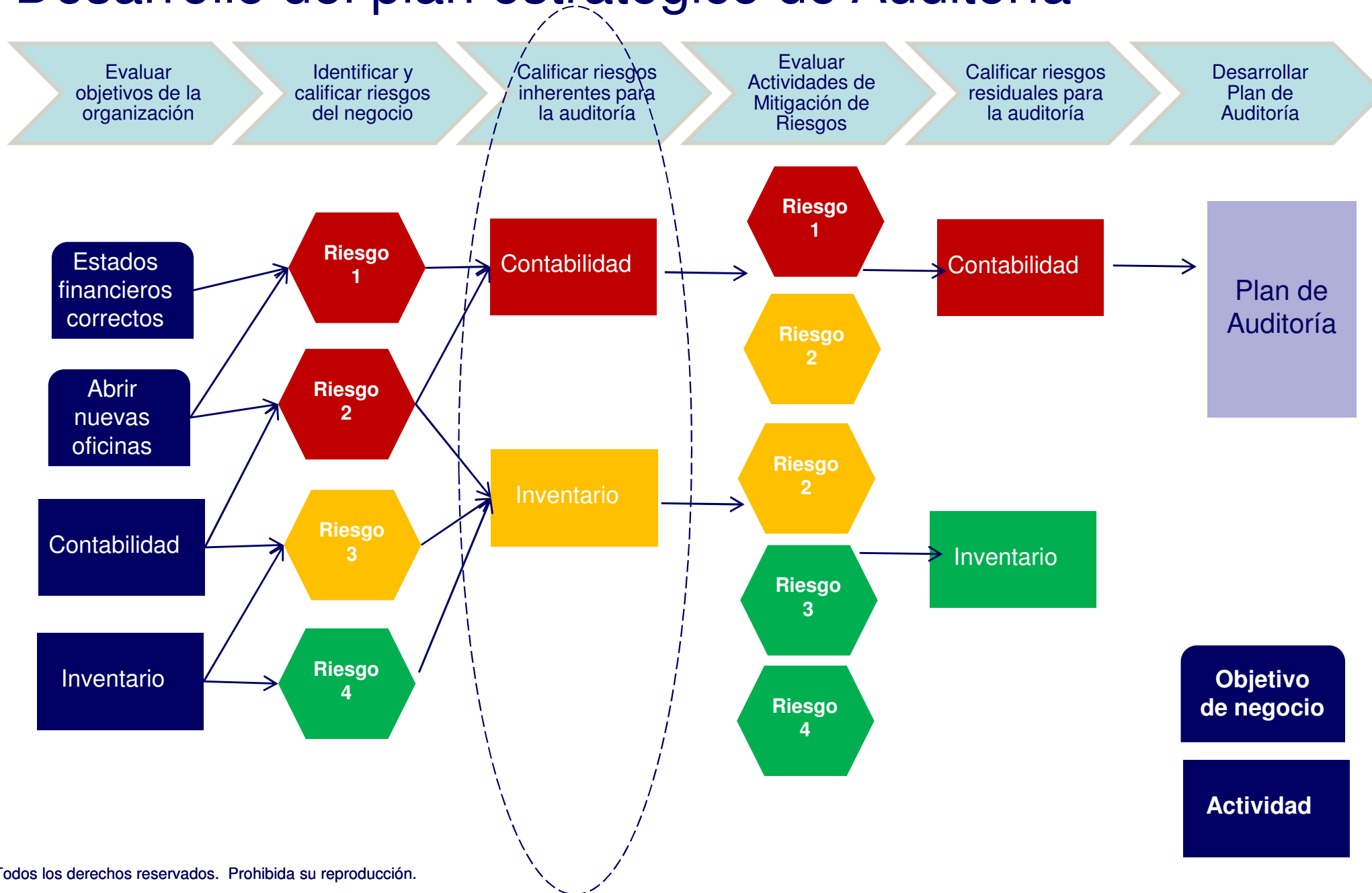
Posibilidad de que el evento ocurra en 1 a 3 años

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Definiciones de priorización de riesgos

Alta	Los riesgos en esta categoría son significantes en consecuencias y amenazan la habilidad de la organización para cumplir sus objetivos estratégicos y son de alta probabilidad de ocurrencia.
Medio	Los riesgos en esta categoría pueden tener altas consecuencias pero son menos probables de que ocurran. Alternativamente, pueden tener bajas consecuencias pero con más probabilidad de ocurrencia.
Bajo	El riesgo en esta categoría tendrá consecuencias limitadas para que la organización cumpla sus objetivos estratégicos y son poco probables de que ocurran.

Desarrollo del plan estratégico de Auditoría

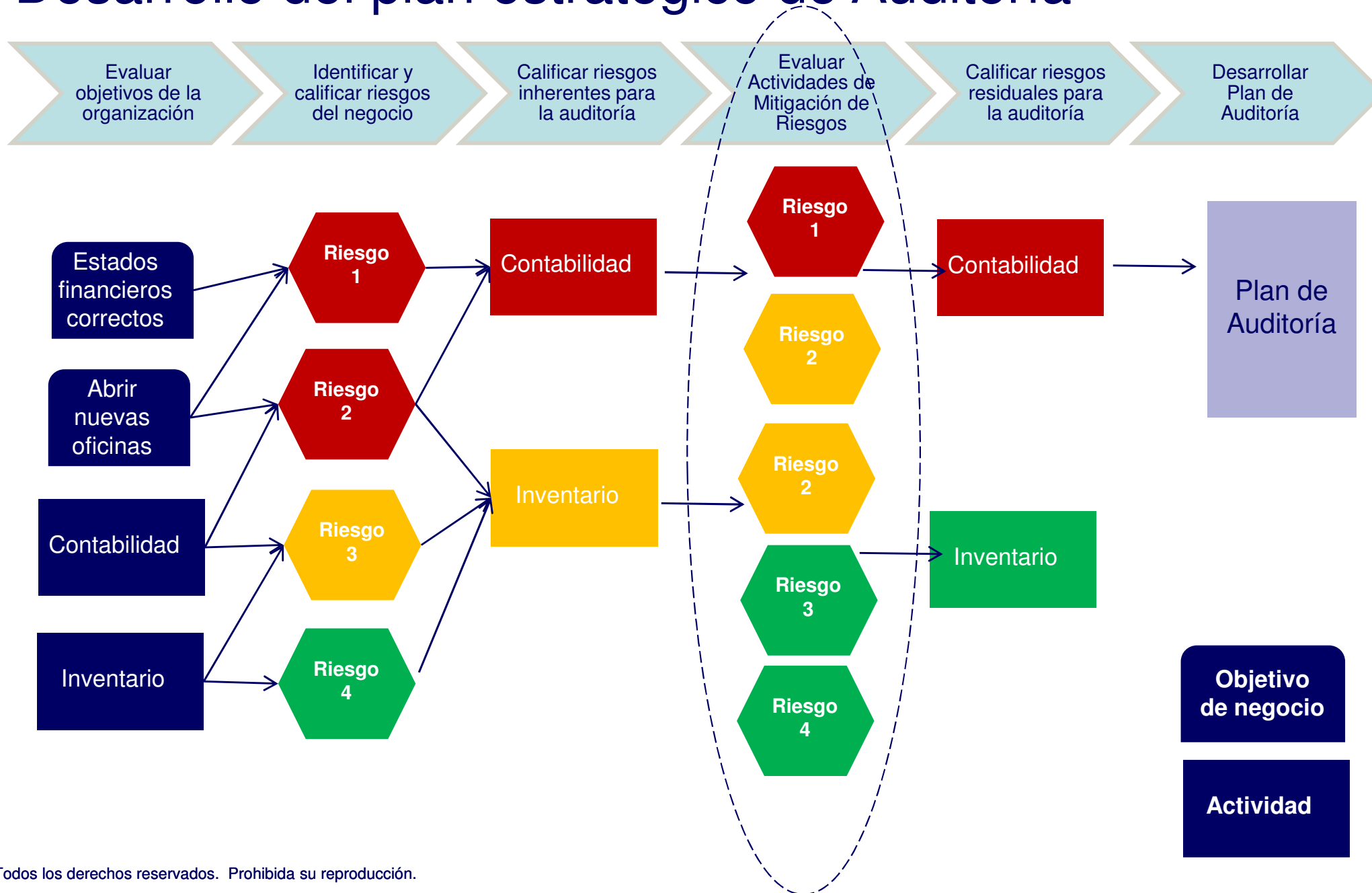


Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Riesgo Inherente por área de Auditoría

Alto	Los riesgos en esta categoría tienen una consecuencia significativa, amenazan la habilidad de la compañía para cumplir los objetivos estratégicos y tiene alta probabilidad de ocurrencia.
Medio	Los riesgos en esta categoría pueden tener altas consecuencias pero son menos probables de que ocurran. Alternativamente, pueden tener bajas consecuencias pero con más probabilidad de ocurrencia.
Bajo	El riesgo en esta categoría tendrá consecuencias limitadas para que la compañía cumpla sus objetivos estratégicos y son poco probables de que ocurran.

Desarrollo del plan estratégico de Auditoría



Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Identificar/Evaluar estrategias de mitigación

ACEPTAR	Una decisión informada basada en la aceptación de riesgo porque el costo o nivel de atención necesaria para gestionar el riesgo puede exceder la consecuencia esperada por la ocurrencia del riesgo.
REDUCIR	Conocimiento del riesgo y esfuerzos formalizados para reducirlo a un nivel aceptable mediante procesos de control interno.
TRANSFERIR	Transferir una porción o mayoría del riesgo a otra entidad (e.j. políticas de seguro o contratos con clientes, proveedores o socios).
ELIMINAR	Se evitan la actividad que expone a la organización al riesgo (e.j. retirar un producto del mercado, no realizar negocios en zonas determinadas).

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Eficiencia en las estrategias de mitigación

Eficiencia en la estrategia de Mitigación de Riesgo

Necesita mejora	La estrategia se considerada ineficiente para prevenir la ocurrencia de riesgos inherentes o reducir el impacto a un nivel aceptable.
Moderada	La estrategia es algo eficiente en prevenir la ocurrencia del riesgo inherente o reducir su impacto.
Fuerte	La estrategia es totalmente eficiente y se espera la prevención total del riesgo inherente o substancialmente reducir su impacto.

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Determinar la efectividad de la mitigación

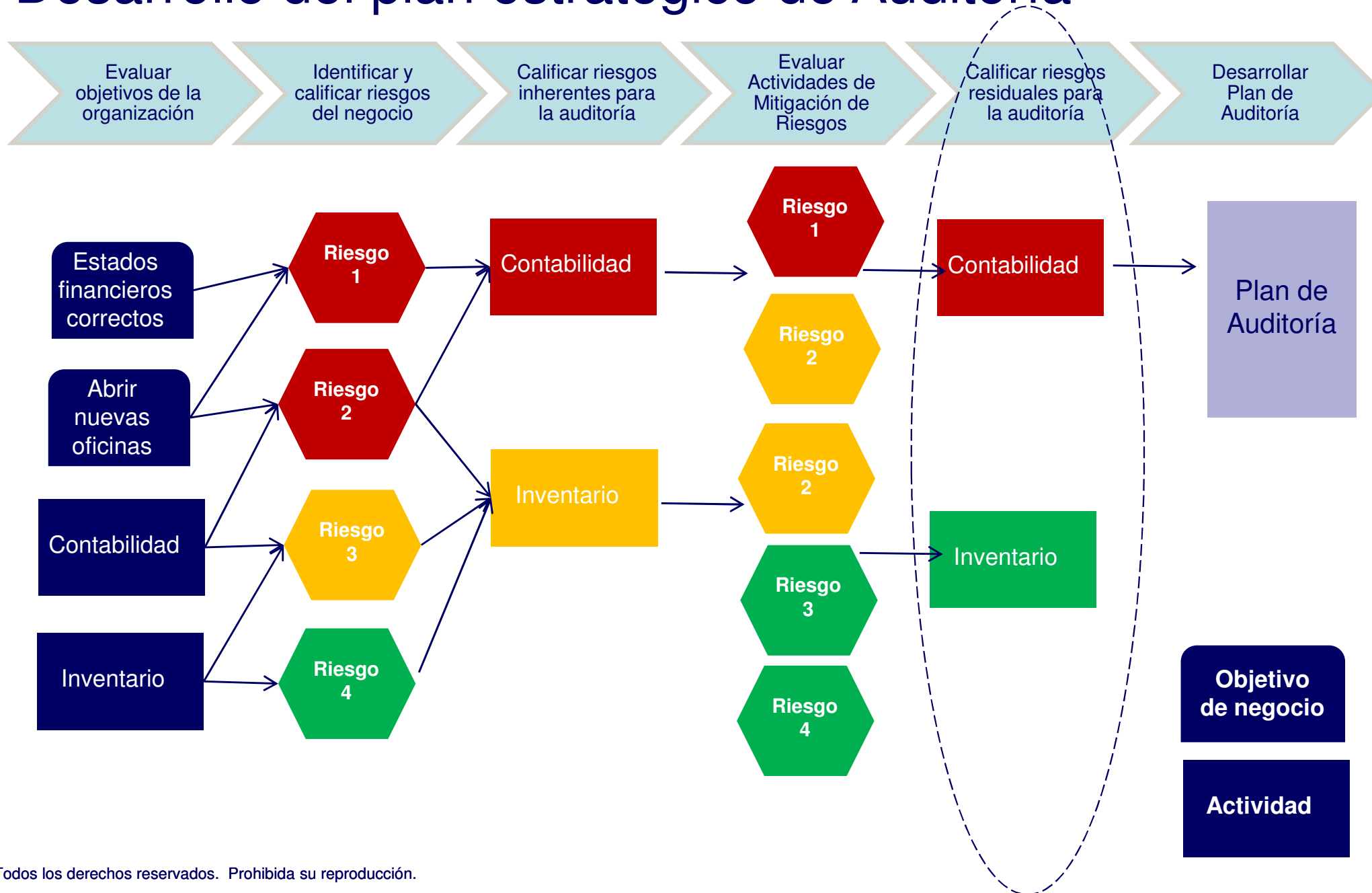
- Basado en el nivel del riesgo inherente (Alto, Medio, Bajo) ¿Se ha implementado métodos de respuesta adecuados para reducir el riesgo inherente a un nivel aceptable?
- ¿Hace cuánto tiempo los métodos de control han sido creados?
¿Se han establecido correctamente o se han implementado recientemente?
- El alcance de cambio en el área (nuevo personal, procesos o tecnología)
- ¿Se han documentado y entendido apropiadamente actividades de control?
- ¿Se han probado los controles por una entidad independiente?
(por ejemplo auditores internos, auditores externos, consultores de seguridad de TI, etc.)

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

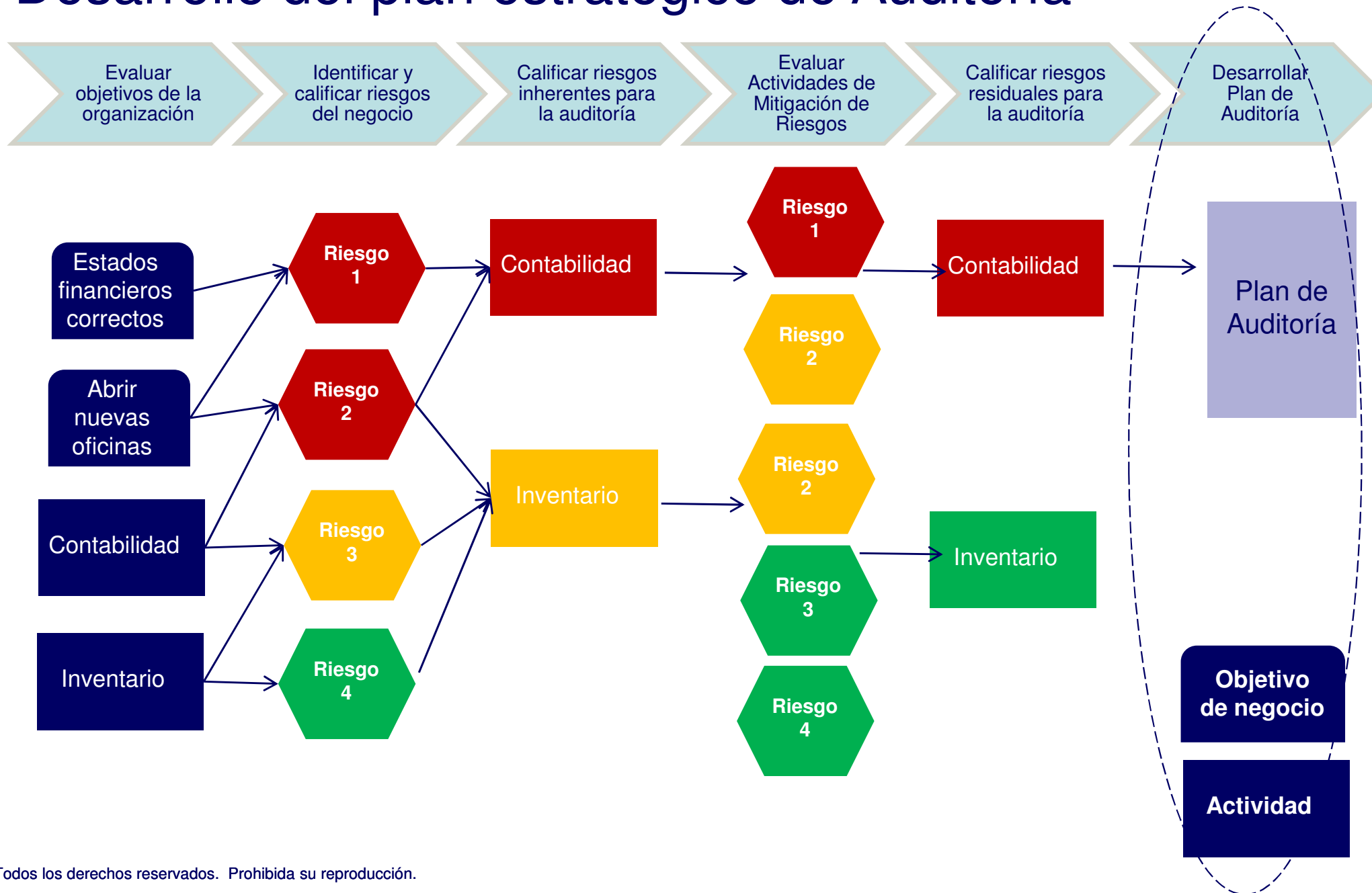
Consideraciones para un mapa de riesgos

- Los mapas de riesgo se deben desarrollar y evaluar por la Alta Dirección. Los mapas pueden ser desarrollados en numerosos niveles dependiendo del tamaño y complejidad de la organización:
 - Mapa de riesgo inherente y residual para cada área auditada (mostrando el riesgo para cada categoría de riesgo)
 - Mapa resumen de riesgo inherente y residual para la empresa para cada área auditada.
 - Mapas de riesgo inherente o residual para cada unidad de negocio.
 - Mapa resumen de todos los riesgos inherentes y residuales.

Desarrollo del plan estratégico de Auditoría



Desarrollo del plan estratégico de Auditoría



Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Identificar Auditorías Individuales

Debe considerar los siguientes aspectos para auditorías individuales:

- Áreas de alto riesgo inherente y bajo riesgo residual para asegurar que los controles son efectivos.
- Áreas donde los procesos de negocios son nuevos (e.j., adquisiciones, nuevos sistemas).
- Áreas de alto riesgo residual.
- Áreas que han experimentado errores o fallas en el control.
- Complejidad del área.
- Nivel de cambio.
- Riesgo de fraude.

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Identificar Auditorías Individuales

- Áreas que son críticas para la implementación de los objetivos estratégicos de la organización (e.j., nuevos servicios, nueva ubicación).
- Resultados de auditorías internas previas particularmente donde existieron hallazgos que no se resolvieron a tiempo.
- Auditorías de proyectos especiales (e.j., implementación de nuevos sistemas).
- Solicitudes de la Dirección Ejecutiva.

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Identificar Auditorías – Próximos pasos

- Categorizar la prioridad de auditar en Alto / Medio / Bajo basado en la categorización de los riesgos cubierta por la auditoría.
- Considere la dependencia de las áreas en TI.
- Planifique aproximadamente un 20% del presupuesto de auditoría para proyectos especiales futuros.
- Considere una mezcla apropiada de las cuatro categorías de riesgo mencionadas anteriormente. La combinación dependerá de la naturaleza y objetivos estratégicos de la organización.

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Identificar Auditorías – Próximos pasos

- La Metodología de Auditoría Interna basada en riesgo:
 - Evaluar el no acercamiento a ciclos para planificar auditorías
 - Todas las áreas auditadas son reevaluadas anualmente
 - Las áreas de mayor riesgos son revisadas
 - El número de auditorías dependerán en el nivel del personal y localidades de las áreas auditadas.
- Consideraciones de recursos deben evaluar con la Alta Dirección y el Comité de Auditoría

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Elaboración de un Plan Estratégico

Recomendamos por lo menos considerar lo siguiente:

- Rol de Auditoría Interna
- Resumen del análisis de riesgo
- Mapa de riesgos inherentes o residuales de áreas de riesgo clave (nivel de detalle depende del tamaño de la organización)
- Resumen de las auditorías propuestas por unidad de negocio
- Resumen de proyectos especiales
- Niveles de recursos

Fase 2: Análisis de Riesgo y Desarrollo del Plan de Auditoría

Actividad 2.4 Evaluar Análisis de Riesgo y Plan de Auditoría con el Comité de Auditoría

Tareas

- Evaluar Análisis de Riesgo y Plan de Auditoría con el Comité de Auditoría

Plantillas:

Plan de Auditoría Interna

Referencias:

Estándares IIA:

Estándares de Desempeño 2020, 2030, 2600

Entregables:



FASE 3 – Ejecución de la Auditoría

Fase 3: Ejecución de la Auditoría

Enfocada en

- Desarrollar fuertes relaciones con la Alta Dirección para maximizar nuestra efectividad mientras mantenemos la auditoría robusta e independiente.
- Crear valor durante el proceso como en los reportes
- Entender las causas principales de las debilidades y proporcionar recomendaciones que:
 - Agreguen valor al proceso
 - Son efectivas
 - Son razonables para implementar

Fase 3: Ejecución de la Auditoría

Actividad 4.1 Planificación de la Ejecución

Tareas

- Discutir el alcance y objetivo de la auditoría
- Entender el proceso
- Comunicar el alcance y objetivos de la auditoría

Plantillas:

Memo de Planificación de Auditoría Interna

Referencias:

Estándares IIA:

Estándar de Desempeño 2200

Entregables:

Memo de Planificación de Auditoría Interna

Fase 3: Ejecución de la Auditoría

Discutir el alcance y objetivo de la auditoría

- Reunión de inicio con la Alta Dirección
 - Preocupaciones y áreas de interés de la Alta Dirección
 - Errores pasados, quejas de clientes y fallos de controles
 - Objetivos de negocio del área y cómo se relacionan con los objetivos estratégicos
 - Cambios recientes en los procesos, personal o sistemas
 - Introducción al equipo de auditoría
 - Discusión del proceso de auditoría (expectativas)
 - Planificación del trabajo de campo de la auditoría y reporte

Fase 3: Ejecución de la Auditoría

Documentación para reunión de inicio

- Actas de Reunión deben documentarse y retenerse con los papeles de trabajo.
- Se deben documentar como mínimo los participantes, fecha y áreas claves.
- Para eficiencia, deben ser notas manuales y luego escaneadas a un documento electrónico.

Fase 3: Ejecución de la Auditoría

Entender el proceso

- **Recopilar material incluyendo:**
 - Papeles de trabajo de AI del año anterior
 - Riesgos identificados durante análisis de riesgo anual
 - Documentación de políticas y procedimientos
 - Planes Estratégicos Institucionales
 - Diagramas Organizacionales
 - Reportes gerenciales de monitoreo (KPI - Indicadores)
 - Reportes de auditores externos, incluyendo cartas de gerencia
 - Reportes periódicos
 - Otra información

Fase 3: Ejecución de la Auditoría

Memo del plan

- Enviar memo del plan al encargado del área y Alta Dirección antes del inicio del trabajo de campo.
- Como mínimo, el memo debe mostrar:
 - Resumen del área a auditar
 - Objetivos
 - Alcance, incluyendo localidades y aspectos fuera del alcance.
 - Fechas, hora y participantes de la reunión de inicio.
 - Contactos claves de auditoría interna
 - Duración de la auditoría

Fase 3: Ejecución de la Auditoría

Actividad 3.2 Documentación del Proceso

Tareas

- Identificar riesgos claves y controles
- Realizar prueba de recorrido
- Evaluar eficiencia del diseño
- Confirmar con el cliente

Plantillas:

Matrices de riesgos y controles
Plantilla de diagrama de flujo
Plantilla de narrativa
Plantilla de prueba de recorrido

Referencia:

Estándares IIA:

Estándar de Desempeño 2300

Entregables:

Matriz de riesgo y controles
Documentación de otros procesos
Documentación de prueba de recorrido

Fase 3: Ejecución de la Auditoría

Identificar y categorizar riesgos y controles de procesos

- Los riesgos y controles de los procesos pueden identificarse con una combinación de:
 - Entrevistas con la Dirección y personal responsable de procesos o transacciones.
 - Inspección de políticas y procedimientos departamentales
 - Evaluar papeles de trabajo de auditorías internas de años anteriores

Fase 3: Ejecución de la Auditoría

Identificar y categorizar riesgos y controles de procesos

- Cuando se identifican los riesgos usted debe discutir lo siguiente con el auditado:
 - ¿Qué prevendrá al área alcanzar los objetivos operacionales? Cuáles son los objetivos estratégicos?
 - ¿Qué podría salir mal?
 - ¿Existen maneras de mejorar la eficiencia de los procesos?
 - ¿Han tenido alguna pérdida / errores / quejas en el último año?
 - ¿Cómo te podemos ayudar?

Fase 3: Ejecución de la Auditoría

Identificar y categorizar riesgos y controles de procesos

Categorías de Riesgo

Alto	Los riesgos en esta categoría tienen una consecuencia significativa, amenazan la habilidad de la organización para cumplir los objetivos estratégicos y tiene alta probabilidad de ocurrencia.
Medio	Los riesgos en esta categoría pueden tener altas consecuencias pero son menos probables de que ocurran. Alternativamente, pueden tener bajas consecuencias pero con más probabilidad de ocurrencia.
Bajo	El riesgo en esta categoría tendrá consecuencias limitadas para que la organización cumpla sus objetivos estratégicos y son poco probables de que ocurran.

Guía de Auditoría Interna basada en Riesgos

Fase 3: Ejecución de la Auditoría

Identificar y categorizar riesgos y controles de procesos

La documentación puede incluir la combinación de:

- Matrices de riesgos y controles (* requerido)
- Diagramas de flujo
- Narrativas

Division and Location:		<Division>	<Location>			
Cycle:						
Performed by:		<Name>	<Date>			
Reviewed by:		<Name>	<Date>			
The following individuals were interviewed during the walkthrough:						
<Names, Titles>						
Control #	Control Description	Documents Reviewed	Responsibility	Walk-Through Description	Test Results (pass or fail)	Issue # (per Issue Log)
201	The Controller performs a detailed review of the expense accruals and prepaid accounts. The Controller verifies the accrual and prepaid journal entries to the underlying assumptions and calculations. The Controller's review is evidenced by a sign-off on the journal entry sheet.	Journal Entry with supporting documentation and Account Reconciliation Copy of GL balance Monthly Closing Checklist	Kathryn (last name), Controller	Agreed balance per account reconciliation to balance per GL; Agreed Journal Entry by Account Reconciliation. Reviewed supporting documentation for journal entries. Through inquiry, verified that the Controller performed her review. The Monthly Closing Checklist for August 2007 was subsequently signed by the Controller.	Pass	
<Name of Company>				Sarbanes-Oxley Process Doc		
<Name of Process/Cycle>						

Employees involved in the Process:

<List Functional Title, and Name of each employee involved in the process>

Financial Statement Line Items and General Ledger Accounts Affected by the Process

[illegible]

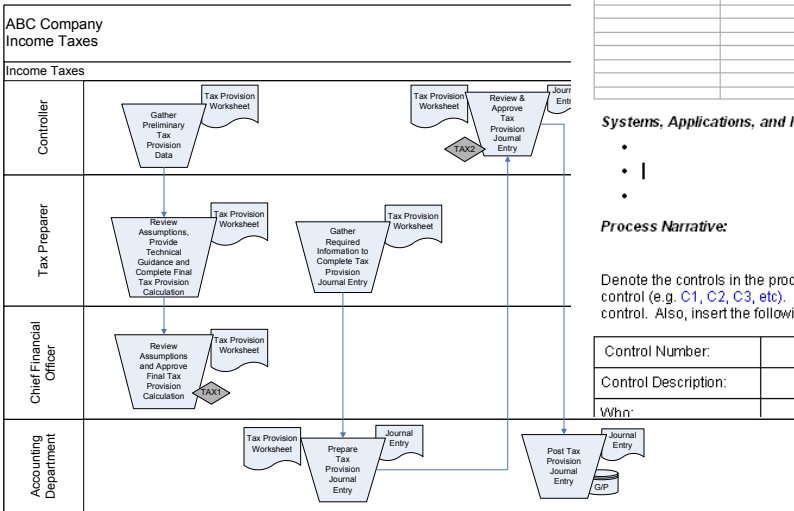
Systems, Applications, and IT Processes:

- •
•

Process Narrative:

Denote the controls in the process with the letter "C" and sequentially number each control (e.g. C1, C2, C3, etc). Place the designation before the sentence describing the control. Also, insert the following table after each control:

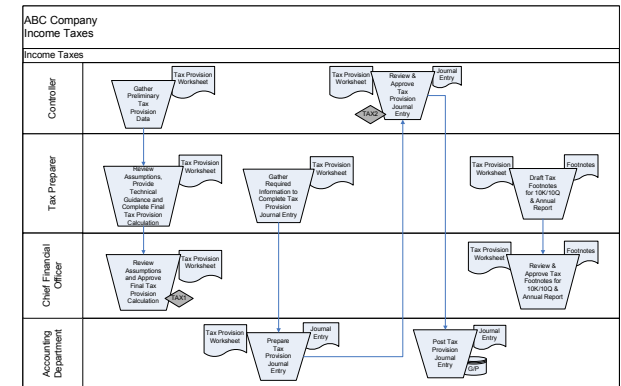
Control Number:	
Control Description:	
When:	



Fase 3: Ejecución de la Auditoría

Diagramas de flujo

- Herramienta que ayuda documentar y evaluar controles internos
 - Diagramas de flujo pueden resaltar debilidades en control
 - Diagramas de flujo con carriles puede resaltar hallazgos de segregación de funciones.
 - Un diagrama de flujo puede comunicar procedimientos, controles visualmente y la secuencia en la que ocurren.
 - Diagramas de flujo se entienden fácilmente y en menos tiempo que una narrativa.
 - Diagramas de flujo son fáciles de actualizar



Fase 3: Ejecución de la Auditoría

Recorrido

- Después de documentar el proceso, una prueba de recorrido se realiza para:
 - Confirmar el entendimiento del proceso
 - Confirmar que los controles han sido implementados
 - Identificar controles faltantes
 - Identificar dónde los controles no son adecuados
 - Confirmar que el personal entiende lo que es requerido de ellos

Fase 3: Ejecución de la Auditoría

Evaluar la eficiencia del diseño

- Después de completar la documentación y la prueba de recorrido utilice su juicio para determinar la efectividad general del diseño como:
 - Efectivo
 - Inefectivo



Fase 3: Ejecución de la Auditoría

Evaluar la eficiencia del diseño

Considere:

- La autoridad y competencia de la persona que ejecuta el control.
- Si el control puede prevenir el riesgo especificado.
- Si el control puede prevenir efectivamente o detectar errores o fraudes que resultarían en estados financieros erróneos.
- Si los controles están diseñados adecuadamente para asistir a la organización a cumplir sus objetivos estratégicos.
- Si el control está diseñado eficientemente.

Fase 3: Ejecución de la Auditoría

Confirme con el auditado

Antes de probar:

- Revise la documentación de los controles (matrices de riesgos y controles, diagramas de flujo, narrativas) con la Alta Dirección para confirmar nuestro entendimiento.
- Evalúe y presente alguna debilidad en el diseño

Fase 3: Ejecución de la Auditoría

Actividad 3.3 Prueba

Tareas

- Diseño de estrategia de prueba
- Ejecutar la prueba
- Discutir hallazgos con clientes
- Identificar causas y oportunidades de mejora

Plantillas:

Plan de Prueba

Referencias:

Estándares IIA:

Estándar de Desempeño 2300

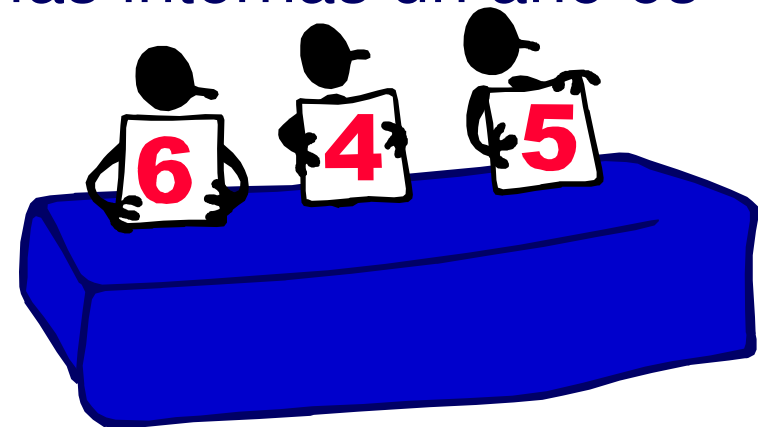
Entregables:

Plan de Prueba
Documentación de Prueba

Fase 3: Ejecución de la Auditoría

Diseñar la estrategia de pruebas

- Se debe recopilar evidencia de acuerdo al nivel del riesgo del control probado (entre mayor es la probabilidad de ocurrencia más evidencia se debe recopilar).
- La estrategia de la prueba puede ser basada en juicio personal, sin embargo debe vincularse al análisis de riesgo.
- Las pruebas deben diseñarse para confirmar que el control opera efectivamente en un periodo apropiado de tiempo. Para la mayoría de auditorías internas un año es un periodo apropiado.



Fase 3: Ejecución de la Auditoría

Diseñar la estrategia de pruebas

Naturaleza de la Prueba	Aplicabilidad
Prueba de recorrido	Control de bajo riesgo
Prueba detallada – rediseño del control y compararlo con los resultados actuales y esperados	Controles de alto o mediano riesgo
Análisis de Data – utilizado con grandes cantidades de data. Puede realizarse para identificar tendencias, anomalías estadísticas o excepciones a políticas de la organización. Se realiza con herramientas como IDEA, MS Access, etc.	Altamente eficiente con cantidades grandes de data.

Fase 3: Ejecución de la Auditoría

Tamaño de la muestra

- El tamaño apropiado de la muestra puede basarse en los objetivos de la auditoría y el riesgo asociado al control.

Población	Riesgo		
	Alto	Medio	Bajo
Diario	20-30	10-20	1-10
Mensual	3-5	2	1
Bimestral	2-3	2	1
Semanal	5	2-3	1
Anual	1	1	1
Periódico	10-15	5-10	1-5
Automático	1	1	1

Fase 3: Ejecución de la Auditoría

Documentación de papeles de trabajo

- Si el auditor determina que la operación del control no es efectiva, un hallazgo debe documentarse en los papeles de trabajo y el reporte de auditoría interna.

Estándar IIA 2320:

“Auditores Internos deben basar sus conclusiones y resultados del trabajo en un análisis y evaluación apropiado”

- La prueba debe referenciarse a la matriz de riesgo y controles para asegurar que todos los controles han sido probados.
- Para excepciones de la prueba que no resulten en un hallazgo de la auditoría se debe documentar la razón en los papeles de trabajo.
- Copias de las excepciones de la prueba deben mantenerse en los papeles de trabajo.

Fase 3: Ejecución de la Auditoría

Discutir hallazgos

- Reporte excepciones potencial de alto riesgo a la Alta Dirección durante la auditoría para tomar acción.
- Discuta hallazgos preliminares durante y al final del trabajo de campo. Esto se puede realizar antes de documentar el reporte establecido como un reporte borrador que sólo liste los hallazgos.
- Si se eliminan hallazgos del reporte se debe pedir colaboración del área auditada y documentarse en los papeles de trabajo.

Fase 3: Ejecución de la Auditoría

Asistir a la Dirección en la resolución de hallazgos

- Mientras auditoría debe evitar desarrollar las funciones de la Dirección, puede involucrarse en:
 - Investigar la causa del hallazgo
 - Identificar controles alternativos
 - Apoyar en el diseño de nuevos controles para implementar
 - Proporcionar entrenamiento a la Dirección y el personal
- Auditoría interna debe evitar realizar decisiones gerenciales con respecto a la implementación de los controles apropiados.

Fase 3: Ejecución de la Auditoría

Documentar hallazgos

- **Descripción** – ¿Cuál es el hallazgo? Esto debe basarse en hechos y ser libre de interpretación.
- **Causa** – ¿Cuál es la causa del problema?

Fase 3: Ejecución de la Auditoría

Documentar hallazgos

- **Impacto** – ¿Cuál es el impacto a la organización? Puede considerar:
 - ¿Cuál es el riesgo?
 - ¿Por qué la Alta Dirección debe preocuparse?
 - ¿Se puede impactar el cumplimiento con los objetivos estratégicos?
 - ¿Puede llevar a la elaboración de estados financieros erróneos?
 - ¿Puede llevar esto a la pérdida de reputación?

Fase 3: Ejecución de la Auditoría

Categorizar hallazgos

Los hallazgos deben categorizarse para ayudar a la unidad auditada a entender la importancia relativa de los hallazgos y consistencia en los reportes.

Alto	El control es débil o no existe control para prevenir el cumplimiento con los objetivos estratégicos. Puede tener un impacto financiero, operativo o regulatorio. Se espera atención inmediata hacia la corrección del hallazgo. Alternativamente, mejoras significativas en la eficiencia pueden notarse y pueden tener un impacto material financiero. Estos hallazgos representan un riesgo moderado o alto a la organización.
Moderado	El control es débil pero no existe impacto mayor en el cumplimiento con los objetivos estratégicos. Se espera atención hacia la corrección del hallazgo a mediano plazo. Alternativamente, mejoras significativas en la eficiencia pueden notarse y pueden tener un impacto financiero. Esos hallazgos representan un riesgo moderado a la organización.
Bajo	Existen hallazgos menores de control o pequeñas mejoras de la eficiencia que tendrá un impacto operativo o financiero insignificante. La Dirección decide priorizar los hallazgos dentro de sus planes actuales. Los hallazgos presentan un bajo riesgo a la organización.

Fase 3: Ejecución de la Auditoría

Elaborar el plan de acción

Planes de acción acordadas vs. recomendaciones

- Recomendaciones – dictaminadas por AI
- Planes de acción acordados – desarrollados en conjunto con la Alta Dirección



FASE 4 – Reportes de Auditoría Interna

Fase 4: Reportes de Auditoría Interna

Diseño de reportes

- **Requerimientos para el Reporte:**
 - Contenido del Reporte
 - Recomendaciones / Conclusiones
 - Qué no debe incluirse
 - Formato establecido
 - Revisión del Reporte
 - Firmas del Reporte
 - Reporte electrónico
- Discuta y acuerde el formato y contenido de los reportes de AI con la Alta Dirección y el Comité de Auditoría. Las plantillas del reportes pueden proporcionarse a la unidad auditada.

Fase 4: Reportes de Auditoría Interna

Contenido de reportes

Elementos requeridos:

- Descripción del trabajo realizado
- Resultados/Observaciones (prioridad es opcional, pero recomendado)
- Lenguaje cauteloso y restringido
- Protección legal es importante dado que la distribución del reporte una vez presentado no se puede controlar.

Fase 4: Reportes de Auditoría Interna

Contenido de reportes

Categorización del Reporte

- No es recomendable proporcionar una evaluación general a la unidad de negocio evaluada.
- El uso de evaluación generales puede tomar demasiado tiempo para acordar con la Alta Dirección y perdiendo el objetivo de mejorar el ambiente de control interno.
- La evaluación de los controles se realiza con la fecha de la auditoría.
- El uso de un sistema de categorización implica el aseguramiento de la efectividad del diseño u operación de los controles.



Consideraciones de Auditorías de TI basadas en Riesgos

Aspectos Generales

- Identificar los objetivos de negocios del plan estratégico de la organización que tengan dependencia con los procesos relacionados al entorno de TI.
- Documentar y evaluar el ambiente tecnológico, los procesos de TI y los procedimientos operativos asociados que soportan cada una de los procesos del negocio (Unidades de Negocio).
- Identificar riesgos que puedan impedir la consecución de los objetivos.

Aspectos Generales – Cont.

- Evaluar el impacto y la probabilidad de dichos riesgos.
- Seleccionar los riesgos significativos.
- Identificar los principales controles existentes.
- Desarrollar un programa de auditoría de sistemas, a través de pruebas de confirmación de la efectividad de los controles identificados, priorizando las áreas de mayor riesgo.

Desarrollo de Matrices de Riesgos de TI

Las matrices de riesgos de TI deben incluir:

- Objetivos del negocio (*estratégicos según metodología presentada*) y procesos de TI que soportan dichos objetivos
- Factores de riesgo
 - Descripción
 - Impacto
 - Probabilidad
 - Tipo de Riesgo

Desarrollo de Matrices de Riesgos de TI

Las matrices de riesgos de TI deben incluir:

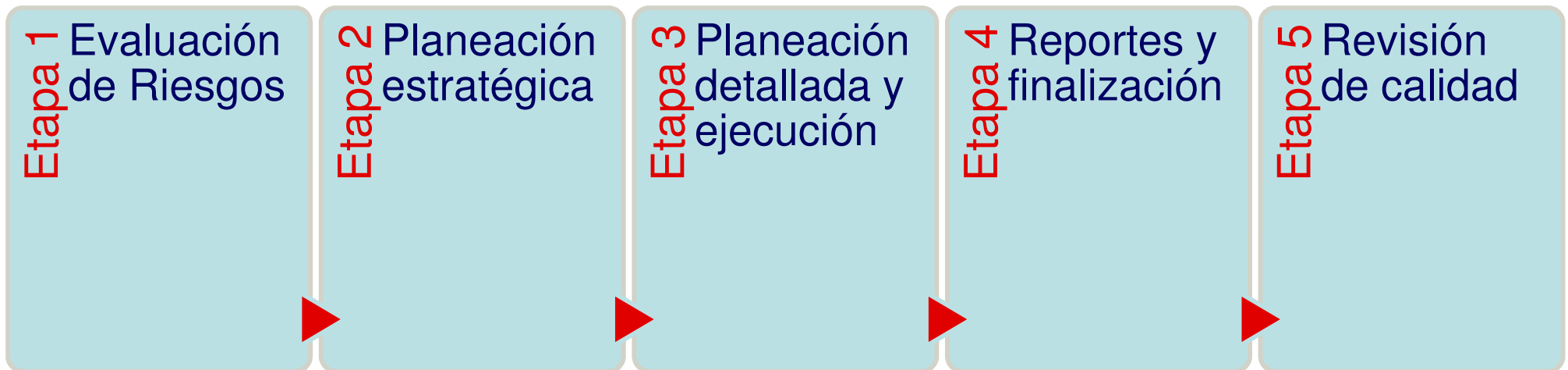
- Objetivos de control:
 - Cobit
 - ISO 27001
 - ITIL
- Controles:
 - Descripción de controles existentes
 - Tipo de Control
 - Automático o Manual
 - Preventivo, Detectivo o Correctivo

Desarrollo de Matrices de Riesgos de TI

Las matrices de riesgos de TI deben incluir:

- Diseño de pruebas detalladas para medir la efectividad de los controles existentes, apoyándonos en los marcos de referencias y las mejores prácticas para el entorno de TI.

Etapas - Auditoría de TI basada en Riesgo



Etapas - Auditoría de TI basada en Riesgo

Etapas 1 Evaluación de Riesgos

Acciones a realizar:

- Identificar y entender los objetivos del negocio soportados por TI.
- Documentar y evaluar los procesos de TI que soportan el negocio.
- Identificar y entender los riesgos que pueden impedir la consecución de los objetivos.
- Evaluar el impacto y probabilidad de los riesgos.
- Utilizar un marco de referencia para la evaluación de los controles que permitan administrar y mitigar los riesgos.
- Desarrollar matrices de riesgos.

Etapas - Auditoría de TI basada en Riesgo

Etapas 2 Planeación estratégica

Acciones a realizar:

- Desarrollar la Planeación Estratégica del programa de auditoría de sistemas a partir en las matrices de riesgo y enfocadas a las áreas de mayor riesgo.



Etapas - Auditoría de TI basada en Riesgo

Etapas
3 Planeación
detallada y
ejecución

Acciones a realizar:

- Desarrollar planes y programas de auditoría.
- Evaluar la eficiencia de los controles existentes e identificar puntos de mejora.
- Desarrollar planes de acción para la Alta Dirección.

Etapas - Auditoría de TI basada en Riesgo

Etapas 3 Planeación
detallada y
ejecución

Para ejecución de la auditoría de sistemas se debe contemplar por lo menos los siguientes aspectos de acuerdo a la organización que se esté evaluando y el marco de referencia utilizado:

- Estructura Organizacional de TI
- Seguridad Física y Lógica
- Operaciones
- Desarrollo y Mantenimiento de SI
- Comunicaciones

Etapas - Auditoría de TI basada en Riesgo

Etapas 4 Reportes y finalización

Acciones a realizar:

- Preparar un informe con la matriz de deficiencias por objetivo de negocio y el proceso de tecnología de información que lo soporta presentando la clasificación de los mismos de acuerdo al nivel de impacto y la probabilidad, tipo de riesgo y marco de referencia relacionado.
- Preparar y emitir reportes finales del trabajo de auditoría de TI.

Etapas - Auditoría de TI basada en Riesgo

Etapas 5 Revisión de calidad

Acciones a realizar:

- Preparar reportes ejecutivos sobre la efectividad de los controles para informar a la Alta Dirección y al Comité de Auditoría.

Conclusiones

- Las Auditorías de Sistemas basadas en riesgo están enfocadas al logro de los objetivos negocio a través de la adecuada administración de los riesgos relacionados al entorno TI.
- Los procesos de TI respaldan efectivamente los objetivos de negocio.
- Se eliminan controles innecesarios (No claves) de los procesos del negocio.
- Adoptar el uso de un marco de referencia (CobiT, ISO, ITIL) de acuerdo al negocio permitirá un alineamiento entre las áreas Auditoría, Tecnología y la Alta Dirección.

GRACIAS

Auditoría Financiera basada en Evaluación de Riesgo

Contraloría General de la República de Panamá

Abril 2010

Facilitadores:

Julio R. Jolly Moore

Oswaldo Lau C.

Suhhel Nuñez

Román Poveda



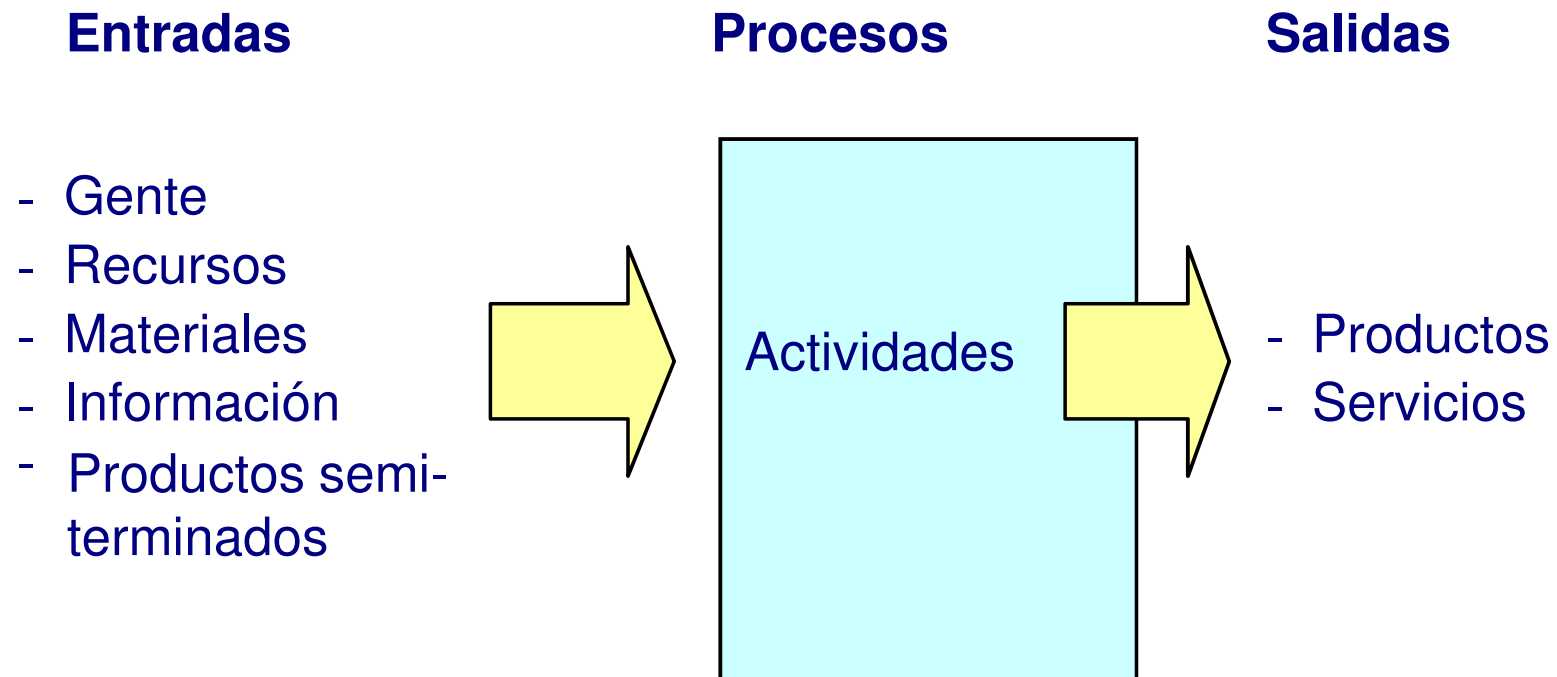


Narrativas, procesos y matrices de riesgo dentro de la Auditoría Interna

¿Qué es un proceso?

- Un proceso es una serie de actividades ordenadas que generan una salida específica como un resultado de una entrada específica.
- Los procesos son el vínculo entre los funcionamientos de la organización y funcionamientos de individuos.
- Una organización es tan eficaz como sus procesos.

¿Cómo reconocemos un proceso?



Ejemplos de proceso de negocios

- Ventas
- Compras
- Planilla
- Inventario
- Procesamiento de Reclamos
- Reporte Financiero
- Desarrollo de Productos
- Producción

Procesos vs. Control

Los procedimientos son necesarios para procesar datos. Se componen de tareas, tales como:

- Capturar datos de entrada.
- Selección y fusión de datos.
- Hacer cálculos.
- Actualización de las transacciones y archivos maestros.
- Generación de transacciones.
- Resumir y mostrar los datos o informes.

En contraste con los controles, los procedimientos y tareas no previenen o detectan errores o inexactitudes.

¿Qué es un ciclo de negocios?

- Grupo de procesos de negocio interrelacionados con el propósito de completar transacciones de principio a fin.
- Siempre involucra un equipo de personas de multiples departamentos haciendo decisiones basadas en un día/semana/mes.

Ejemplos de Ciclos de Negocios

1. Ciclo de Recursos Humanos

- Reclutamiento
- Movimientos de Planilla
- Salidas de Personal
- Actualización de registros

2. Ciclo de compras

- Requerimientos
- Orden de compras
- Selección de Proveedor
- Compras
- Desembolsos

3. Ciclo de Inventario

- Recepción de Mercancía
- Almacenamiento
- Salida de Mercancía
- Depreciación

Pasos en la Evaluación de Ciclos

- Identificar los componentes significativos para alcanzar una comprensión minuciosa del proceso, objetivos de control y controles.
- Identificar los objetivos de control a nivel de negocios, operacional y de sistemas.
- Identificar los puntos fuertes y débiles de control para evaluar el impacto en los objetivos de negocios.
- Probar los controles para asegurar su funcionalidad y su eficacia de acuerdo al objetivo de control.
- Evaluar los controles generales en las áreas de planificación de tecnología, administración de operaciones, administración de seguridad, administración de mantenimiento y desarrollo.

Etapas en la Evaluación de Ciclos de Negocios

- **Etapas 1:** Entendimiento del Proceso y Levantamiento de Información
- **Etapas 2:** Documentación y Evaluación de Controles
- **Etapas 3:** Preparación de Informes

Beneficios de una Evaluación de Ciclo de Negocio

- Verificación de la eficacia y eficiencias de los controles existentes a través de los procesos.
- Determinar ausencias de controles en los procesos.
- Permite una visión panorámica de las operaciones o de la entidad.
- Identificar inadecuada segregación de funciones o duplicidad de actividades.
- Identificación de riesgos principales del ciclo de negocio, que pueden afectar el logro de los objetivos.
- La Gerencia elabora estrategias de negocios alineadas a la realidad de la organización.

Etapas 1: Entendimiento del Proceso y Levantamiento de Información

En la etapa de entendimiento del proceso es necesario considerar los siguientes aspectos:

- Expectativas de la Alta Dirección
- Responsabilidades de los involucrados
- Actividades del negocio
- Prácticas financieras
- Estructura operativa
- Sistemas de información
- Ambiente de control

Etapa 1: Entendimiento del Proceso y Levantamiento de Información

Métodos utilizados:

- Entrevistas
- Encuestas
- Gremios profesionales
- Sector asociado



Etapa 1: Entendimiento del Proceso y Levantamiento de Información

Algunas consideraciones al momento de las entrevistas:

1. Apertura

- Proponer una agenda para la entrevista (comunicación previa).
- Presentarse usted mismo y su propósito.
- Proponer el tiempo estimado que necesita.
- Establecer buena voluntad.
- Explicar como será usada la información recopilada.

Etapa 1: Entendimiento del Proceso y Levantamiento de Información

2. Identificarse con el cliente

- Empatía – Valorar perspectivas diferentes.
- Credibilidad – Reconociendo experiencia.
- Confianza – Construyendo buena voluntad mutua.
- Transparencia – Compartiendo toda la información relevante.

Etapa 1: Entendimiento del Proceso y Levantamiento de Información

3. Facilitar la entrevista

- Guiar la entrevista – no dominar o interrumpir
- Organizar puntos clave.
- Ser flexible.
- Focalizarse en objetivos.
- Manejar desviaciones.
- Dedicarse a tomar buenas notas.
- Demostrar atención y escuchar activamente.
- Escuchar los hechos y emociones
- Resumir
- Realizar preguntas de sondeo

Etapa 1: Entendimiento del Proceso y Levantamiento de Información

4. Elaboración de preguntas

- Preguntas con finalidad abierta
 - Qué piensas de.....?
 - Cuéntame acerca de.....
- Preguntas de Sondeo
 - Puede usted hacer memoria sobre?
- Preguntas con finalidad cerrada (sí, no o cantidades)
 - Usted quiere decir esto ...?
 - Cuál fue su total de ingresos del último año?
- Preguntas de verificación
 - Lo que usted quiere decir es...?
 - Para aclarar, yo entendí que...?

Etapa 1: Entendimiento del Proceso y Levantamiento de Información

5. Comunicación “No Verbal”
 - Calidad, claridad y proyección vocal
 - Gestos y posturas
 - Contacto visual

Etapa 1: Entendimiento del Proceso y Levantamiento de Información

6. Significado del Lenguaje Corporal

- Los brazos cruzados = se sienten amenazados, crean una barrera.
- Inclinandose lejos de usted = establece distancia, sugiere arrogancia/confidencia.
- El mismo lenguaje corporal que usted = amistoso.
- Cabeza apoyada en la palma de la mano = fatiga/aburrimiento.
- Mano que se frota en mejilla = análisis/evaluación.
- Barbilla que frota ligeramente = duda, sensaciones negativas.
- Manos abrochadas, codos en la tabla = frustración, pensando.

Etapas 1: Entendimiento del Proceso y Levantamiento de Información

7. Cierre de la entrevista

- Revisar Notas.
- Resumir y aclarar información.
- Programar próximas entrevistas (si es necesario).
- Definir contacto para próximas entrevistas.
- Discutir siguientes pasos.
- Agradecer al auditado (dueño del proceso) el tiempo invertido.

Etapa 1: Entendimiento del Proceso y Levantamiento de Información

Práctica #1

Usted está a cargo de realizar una evaluación del ciclo de negocio de Compras. El Ministro y el Director del departamento de compras se encuentran de gira por los centros regionales y mantienen una agenda ocupada.

¿Cuál sería el método de recolección de información más adecuado para conocer los aspectos generales del proceso de compras?

a. Entrevista

☒ b. Encuesta

c. Consulta a los auditores externos

¿Por qué documentar los controles?

- Normas Internacionales para el Ejercicio Profesional de la Auditoría Interna (Normas) del IIA recomiendan una evaluación periódica de la suficiencia de los sistemas de control de las organizaciones.
- Requisitos regulatorios, las pautas profesionales y los mandatos de las empresas son buenas razones para que los auditores internos desarrollen habilidades específicas para documentar los controles.

Actividades en la Documentación de Controles

Para llevar a cabo una adecuada documentación de controles se deben abarcar las siguientes actividades :

- Identificar los controles
- Identificar los objetivos de control
- Comprender y documentar los controles

Identificar los Controles

Para poder identificar el control dentro de un proceso, los auditores pueden reunir información a través de:

- Entrevistas.
- Sesiones dirigidas.
- Encuestas.
- Revisión de documentos.
- Procedimientos analíticos.
- Observaciones.

La información recabada servirá de base para identificar, documentar y medir la importancia de cada control en forma precisa. Es por ello que la documentación debe estar organizada y consistente.

Identificar los Objetivos de Control

Para poder identificar mejor los objetivos de control, los auditores internos deben abarcar algunos objetivos de procesamiento de información tales como:

- Integridad: ¿Qué impide que el sistema duplique los asientos contables?
- Exactitud: ¿Qué asegura que el ingreso de datos sea correcto?
- Veraz: ¿Qué impide la realización de transacciones no autorizadas?
- Acceso restringido: ¿Qué asegura la confidencialidad de los datos?

Además, los objetivos de control deben considerar riesgos organizacionales específicos, como los relacionados con la estrategia, las operaciones, los informes y el cumplimiento.

¿Cómo se documentan los controles?

QUIÉN

realiza el control?

QUÉ

hace (entrada/proceso/salida)?

CUÁNDO

son aplicados los controles?

DÓNDE

son ejecutados los controles?

CÓMO

solucionan las excepciones?

CUÁLES

son las evidencias de que los controles son aplicados?

Recursos para la documentación de Controles

Recursos necesarios para identificar los objetivos de control:

Internos:

- Visión y Misión del negocio
- Planes estratégicos
- Planes de negocios
- Presupuestos

Externos:

- Normas regulatorias
- Organismos de control
- Organismos Internacionales (www.theiia.org, www.auditnet.org, www.isaca.org)

Comprender y Documentar los Controles

Para una comprensión efectiva de los controles dentro de un proceso, el auditor debe comprender el flujo de las transacciones desde su inicio, registro, autorización, procesamiento e información mediante el uso de diferentes tipos de documentación.

Tipos de Documentación

Actualmente, no existe ningún formato en particular de documentación y el alcance del mismo está sujeto a la complejidad del área o ciclo a evaluar.

Entre los tipos de documentación más comunes se encuentra:

- Narrativas
- Diagramas de Flujo
- Matrices de Riesgos y Control
- Manuales de Políticas y Procedimientos

Narrativas de Procesos

Son utilizados para describir de manera escrita el flujo de actividades a través de un proceso.

Las narrativas son utilizadas como complemento de los diagramas de flujos detallando las prácticas existentes así como la reducción de posibles inconsistencias o dudas en alguna actividad de control.

Diagramas de Flujos

Son utilizados para describir el flujo de actividades a través de un proceso, así como también la documentación relacionada.

Los beneficios del diagrama de flujos para el auditor:

- Comprender mejor los procesos de negocios
- Ahorro de tiempo en comunicación
- Facilidad de identificar riesgos y controles
- Detectar deficiencias en los procesos o controles
- Facilitar y agilizar el proceso de revisión

Consideraciones en la elaboración de los Diagramas de Flujos

Para que los diagramas de flujos se preparen adecuadamente, deben:

- Ser claros, simples y concisos.
- Demostrar la secuencia cronológica de eventos.
- Identificar controles claramente.
- Indicar claramente quien está realizando los controles (para determinar la división de tareas).
- Hacer uso sensato de la narrativa, con las referencias debidas para ampliar la información.
- Utilizar los símbolos estándar de manera correcta.

Algunos símbolos utilizados en los Diagramas de Flujo

Algunos símbolos utilizados



Práctica #2

Ordene en una secuencia lógica los siguientes procesos y prepare un diagrama de flujo del proceso:

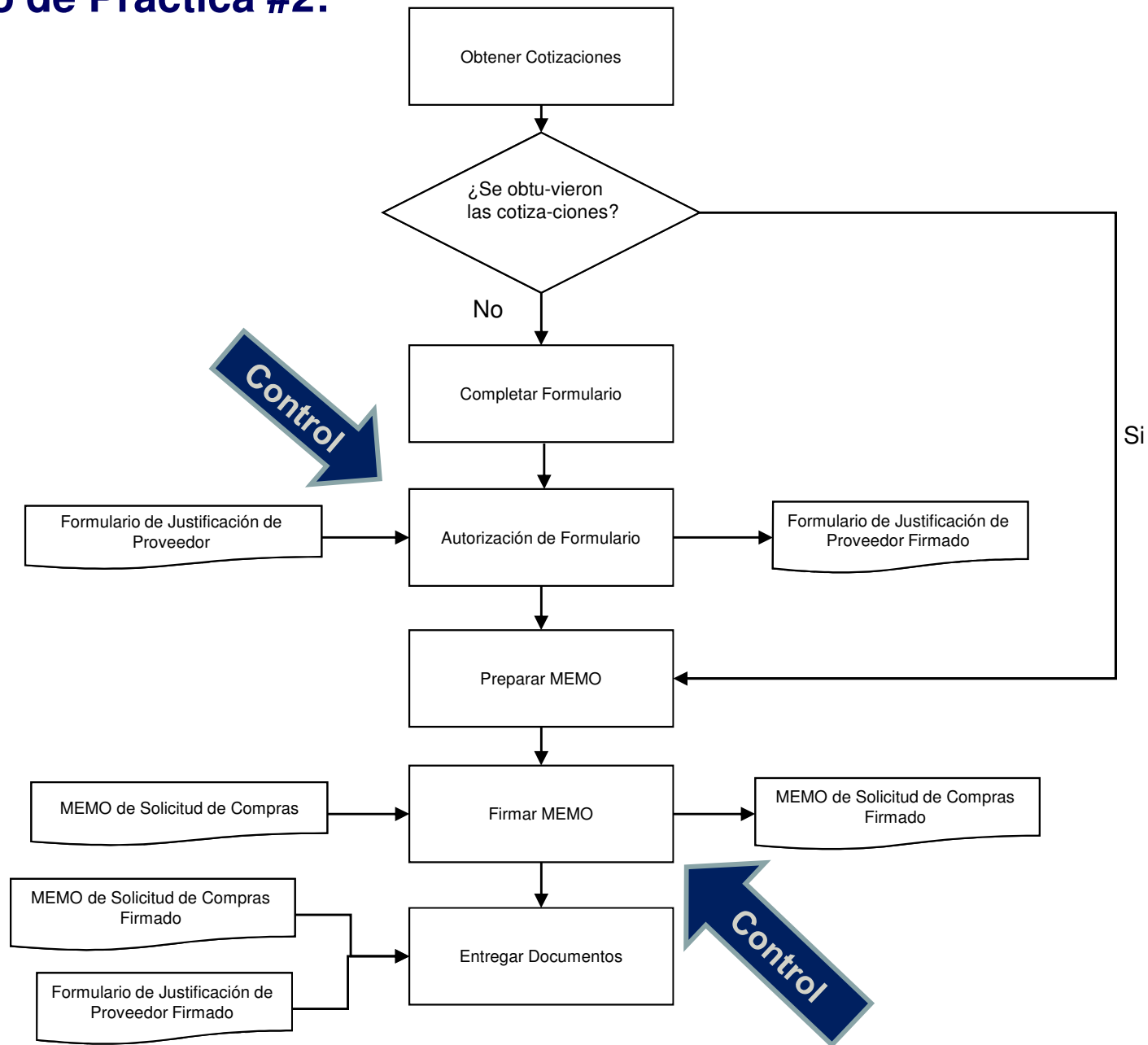
Actividades	Orden
Preparar MEMO: La Secretaria prepara el MEMO de Solicitud de Compras de acuerdo a lo solicitado por el Jefe de Area.	
Completar Formulario: Posteriormente, la persona que solicita la compra completa el formulario denominado “Justificación de Selección de Proveedor” en el cual detalla fecha, proyecto que solicita la compra, personal solicitante, descripción del artículo, cotizaciones de los tres proveedores y justificación del proveedor seleccionado debido a precio.	
Obtener Cotizaciones: La persona que solicita la compra solicita a diferentes proveedores cotizaciones para la compra del activo. Se deben presentar por lo menos tres cotizaciones de diferentes proveedores. Se seleccionará la de menor precio.	
Firmar MEMO: El Jefe de Area firma el MEMO de Solicitud de Compras como constancia de su revisión y aprobación.	
Autorización de Formulario: La persona que solicita la compra debe obtener la firma de aprobación en el formulario “Justificación de Selección de Proveedor” del Jefe de Area.	
Entregar Documentos: El Solicitante le entrega a la Gerente de Compras el MEMO de Solicitud de Fondos y el formulario “Justificación de Selección de Proveedor”.	

Resultado Práctica #2

Actividades	Orden
Preparar MEMO: La Secretaria prepara el MEMO de Solicitud de Compras de acuerdo a lo solicitado por el Jefe de Area.	4
Completar Formulario: Posteriormente, la persona que solicita la compra completa el formulario denominado “Justificación de Selección de Proveedor” en el cual detalla fecha, proyecto que solicita la compra, personal solicitante, descripción del artículo, cotizaciones de los tres proveedores y justificación del proveedor seleccionado debido a precio.	2
Obtener Cotizaciones: La persona que solicita la compra solicita a diferentes proveedores cotizaciones para la compra del activo. Se deben presentar por lo menos tres cotizaciones de diferentes proveedores. Se seleccionará la de menor precio.	1
Firmar MEMO: El Jefe de Area firma el MEMO de Solicitud de Compras como constancia de su revisión y aprobación.	5
Autorización de Formulario: La persona que solicita la compra debe obtener la firma de aprobación en el formulario “Justificación de Selección de Proveedor” del Jefe de Area.	3
Entregar Documentos: El Solicitante le entrega a la Gerente de Compras el MEMO de Solicitud de Fondos y el formulario “Justificación de Selección de Proveedor”.	6

Narrativas, procesos y matrices de riesgo

Resultado de Práctica #2:



Matrices de Riesgo y Control

Las matrices de riesgo y control relacionan los controles identificados con los objetivos de control y los riesgos relacionados. Son útiles para documentar los riesgos y controles, y para facilitar la evaluación del diseño y eficacia del sistema de control.

Para los auditores, las matrices de riesgo y control le permite identificar las debilidades entre los controles reales y los objetivos y riesgos de los controles específicos.

Modelo de Matriz

[illegible]

Tipos de Controles

Preventivo

- Previene que un evento que detona un riesgo ocurra.

Detectivo

- Identifica desviaciones antes de concluir un proceso.

Correctivo

- Identifica desviaciones ya concluido el proceso y actúa para corregirlo.

Ejemplo - Control Preventivo

- Se autorizan nuevos ingresos al maestro de nómina.
- El sistema compara el número de empleado de la nómina con la lista de los empleados activos para garantizar que el empleado permanece activo.
- El sistema verifica que el cliente se encuentra en la lista de clientes aprobados antes de procesar las órdenes.
- El sistema no acepta entradas de diario con fechas anteriores a la actual.

Ejemplo - Control Detectivo

- El Asistente de contabilidad concilia las cuentas bancarias con el balance en libro.
- El Jefe de Contabilidad revisa las conciliaciones bancarias.
- El sistema compara las compras de clientes con el límite de crédito aprobado. Si el límite es excedido el crédito se pasa al Gerente General.

Ejemplo - Control Correctivo

- La suma es incorrecta.
- El registro corresponde a otra partida.
- El apellido no corresponde.
- La recuperación de un archivo dañado a partir de las copias de seguridad.

Aseveraciones Financieras

Integridad	Las transacciones, eventos o circunstancias ocurridos, que debieron haber sido reconocidos, hayan sido registrados contablemente en dicho periodo.
Valor Correcto	Las transacciones sean registradas por el monto correcto y en la cuenta correcta.
Corte	Las transacciones sean registradas en el periodo adecuado.
Existencia	Los activos, pasivos e inversión de los accionistas existan a una fecha determinada.
Ocurrencia	Las operaciones registradas representen eventos que realmente ocurrieron durante el periodo en cuestión.
Valuación	Los activos, pasivos, ingresos y egresos hayan sido registrados de acuerdo con los principios de contabilidad generalmente aceptados y que dichas transacciones sean matemáticamente correctas y adecuadamente registradas.
Derechos y Obligaciones	Los activos son reales existencias y derechos y los pasivos sean veraces las obligaciones de la compañía a una fecha determinada.
Presentación	Las partidas de los Estados Financieros estén adecuadamente clasificadas, detalladas, descritas y presentadas.

Ejercicio Práctico

#	Actividad	P	D	C
1	La supervisora verifica que el documento cuente con las dos firmas requeridas.	★		
2	Existen programas de capacitación al personal. Además, la compañía cuenta con manuales de políticas y procedimientos.	★		
3	Las facturas de pago a proveedores son comparadas con el documento de orden de compra y bienes recibidos antes del pago al proveedor.	★		
4	Se efectúan conciliaciones de las cuentas bancarias.		★	★
5	Se realizan auditoría internas y externas dentro de la compañía.		★	

Ejercicio Práctico

#	Actividad	C	A	V	R
1	La orden de pedido corresponde a un cliente real.				
2	Las facturas solamente pueden ingresarse al sistema para su procesamiento una sola vez.				
3	Los acceso al sistema ingresos están debidamente restringidos.				
4	Las facturas de ventas son registradas por el monto correcto.				
5	Los campos claves son revisados, para detectar valores vacíos, caracteres alfabéticos, ausencia de datos, entre otros.				

Plan de Pruebas

Al culminar con la etapa de documentación y entendimiento de los controles, podemos realizar las evaluaciones de los controles eficazmente. Para ello es necesario tomar en cuenta las siguientes consideraciones:

- Asegurar cubrir todos los objetivos a evaluar y que sean tenidos en cuenta todos los objetivos de control pertinentes sobre los cuales deseamos obtener seguridad de auditoría.
- Considerar los tipos de pruebas que deben ser usados.
- Considerar si una prueba debe comprender observación, indagación, examen de evidencia, o una combinación de todo lo anterior.
- Ser tan específico como fuere posible al diseñar la prueba de tal modo que sea adaptada al proceso.

Tipos de Pruebas

Prueba de Observación

- Observar los procesos de planilla.
- Observar las actividades relacionadas a la recepción de materiales.
- Observar cómo se actualiza el Mayor General.

Permite una visión panorámica de las operaciones o de la entidad.

- Cuantificación de montos grandes de transacciones (es decir todas las órdenes de compra por el año).
- Identifique las tendencias o afloramientos.
- Seleccione las muestras para la prueba manual.

Prueba Manual

- Revisión de firmas apropiadas en facturas.
- Revisión de deducciones apropiadas a empleados en los registros de planilla.
- Realizar conteo de inventario en la bodega.

Beneficios de las Pruebas

A través de la realización de pruebas podemos obtener los siguientes beneficios:

- Validar que los controles identificados están funcionando eficazmente para alcanzar los objetivos y metas de negocio.
- Cuantificar la exposición financiera de identificar “gaps” de control.
- Apoyar “issues” o hallazgos de auditoría interna.
- Medir el desempeño del negocio.
- Identificar tendencias y variaciones inesperadas.

Etapa 3: Evaluación de Controles

Oportunidades de Mejora o Hallazgos:

Los “issues” pueden ser generalmente categorizados como hallazgos de control u oportunidades de mejora de proceso.

Hallazgos de Control:

- Deficiencia del Diseño: Falta el control o el control existente no fue diseñado apropiadamente.
- Deficiencia Operativa: El control existe pero no esta operando como fue diseñados o la persona que realiza el control no lo está realizando eficazmente.

Oportunidades de Mejoras de Procesos:

- Oportunidades de mejorar la eficiencia.
- Ineficacia causada por un ambiente sobre-controlado.

Etapa 3: Evaluación de Controles

Componentes de los Hallazgos:

- Estado del hallazgo – Simple y conciso transmite la esencia global de el “issue”.
- Identifique la causa del hallazgo (si es posible).
- Sustente el hallazgo – Incluya análisis y la cuantificación de prueba donde sea posible.
- Represente el riesgo total a la organización.

Etapa 3: Evaluación de Controles

Clasificación de los Hallazgos:

Los tipos de hallazgos se clasifican de acuerdo a las mejores prácticas de la siguiente forma:

Alto:

Son aquellos cuya condición afectan totalmente el cumplimiento de uno o más objetivos de negocios.

Medio:

Son aquellos cuya condición afectan parcialmente el cumplimiento de uno o más objetivos de negocios.

Bajo:

Son aquellos cuya condición afectan la eficiencia de uno o varios procesos de negocios.

Presentación de Informes de Evaluación de Ciclos de Negocios

El éxito de una auditoría muchas veces puede depender de la calidad de sus comunicaciones escritas...

Revista Internal Auditor, febrero 2003

Presentación de Informes de Evaluación de Ciclos de Negocios

Algunas Consideraciones al preparar el Informe:

- Definir claramente el mensaje a comunicar.
- Establecer aspectos que sustenten y corroboren el mensaje principal.
- Inicie colocando las ideas generales en el papel (Síndrome del papel en blanco).
- No intente escribir y corregir a la vez.
- Escribir en primera persona (yo, nosotros).
- Evaluar el tono de voz (activa o pasiva).
- Evitar el uso de palabras técnicas.
- Intente mitigar la impaciencia del lector.
- Describir el riesgo o la consecuencia.
- Recomendaciones alineadas a la realidad del negocio.
- Separe un espacio para los planes de acción de la Gerencia.

Modelos de redacción de Informes

Evitar utilizar

- Nuestra revisión de los registros fue una parte importante de la auditoría.
- Hice un reembolso a todos los participantes.
- Las condiciones del negocio fueron superiores en el tercer trimestre.
- El negocio fracasó debido a una concatenación de eventos.

Sugerencia

- Nuestra revisión de las transacciones de cuentas por pagar reveló varias discrepancias.
- Reembolsé a todos los participantes.
- El ingreso neto se ha incrementado 15 por ciento en el tercer trimestre.
- El negocio fracasó debido a una serie de eventos relacionados.

GRACIAS

Auditoría Financiera basada en Evaluación de Riesgo

Contraloría General de la República de Panamá

Abril 2010

Facilitadores:

Julio R. Jolly Moore

Oswaldo Lau C.

Suhhel Nuñez

Román Poveda





Pruebas de Auditoría Analíticas y Sustantivas Asistidas por Computador

Pruebas de Auditoría

Las pruebas de auditoría son técnicas o procedimientos que utiliza el auditor para la obtención de evidencia comprobatoria.

Las pruebas pueden ser de tres tipos:

- Pruebas de Control
- Pruebas Analíticas
- Pruebas Sustantivas

Pruebas Sustantivas

Los procedimientos sustantivos están relacionados con montos. El propósito de los procedimientos sustantivos es obtener evidencia de auditoría para detectar errores importantes en los estados financieros. Son generalmente aplicados a grandes volúmenes de transacciones que tienden a ser predecibles a través del tiempo.

Pruebas Analíticas

- Los procedimientos analíticos consisten en el análisis de índices y tendencias significativas incluyendo la investigación resultante de fluctuaciones y relaciones que son inconsistentes con otra información relevante o que se desvían de los montos pronosticados.
- Las pruebas analíticas se utilizan haciendo comparaciones entre dos o más estados financieros o haciendo análisis de las razones financieras de la entidad para observar su comportamiento.

Técnicas de Recopilación de Evidencias

- Observación: ver el desarrollo del levantamiento del inventario físico.
- Inspección física: examinar el estado de los vehículos.
- Confirmación: confirmar saldos de las cuentas por cobrar.
- Indagación o consulta al personal.
- Análisis documental.
- Procedimientos analíticos.
- Recálculo o desempeño.

Observación

- Presencia física de cómo se realizan ciertas operaciones o hechos.
- El auditor se cerciora de la forma como se realizan ciertas operaciones, dándose cuenta ocularmente de la forma como el personal de la empresa las realiza.

Inspección

- Examen físico de los bienes materiales o de los documentos, con el objeto de cerciorarse de la existencia de un activo o de una operación registrada o presentada en los estados financieros.
- Puede comprobarse la autenticidad del saldo de la cuentas, de la operación realizada o de la circunstancia que se trata de comprobar, mediante el examen físico de los bienes o documentos que amparan el activo o la operación.

Confirmación

- Obtención de una comunicación escrita de una persona independiente de la empresa examinada y que se encuentre en posibilidad de conocer la naturaleza y condiciones de la operación y por lo tanto confirmar de una manera válida.
- Esta técnica se aplica solicitando a la empresa auditada que se dirija a la persona a quien se pide la confirmación, para que conteste por escrito al auditor, dándole la información que se solicita.

Investigación

- Obtención de información, datos y comentarios de los funcionarios y empleados de la propia empresa.
- Con esta técnica, el auditor puede obtener conocimiento y formarse un juicio sobre algunos saldos u operaciones realizadas por la empresa.

Ejemplos – Pruebas Analíticas

- Comparar los saldos por grupo de bienes al inicio y al cierre.
- Comparar las cuentas de gastos y reparación entre ejercicios consecutivos.
- Cotejar los presupuestos por compra y gastos efectuados por la empresa con las transacciones ocurridas durante el ejercicio.
- Pruebas globales sobre las depreciaciones y amortizaciones aplicando las proporciones correspondientes a cada tipo de bien.

Ejemplos – Pruebas Sustantivas

Ingresos

- Registros duplicados de facturas
- Detección de omisiones de facturas
- Excepciones en valores de ventas inusuales
- Comprobar cálculos de precios y descuentos
- Analizar e identificar las entradas de caja por códigos establecidos para la conciliación.
- Revisión de Morosidad.
- Identificación de balances negativos
- Muestreos aleatorios, sistemáticos y aleatorios estratificados.

Ejemplos – Pruebas Sustantivas

Compras

- Detección de facturas y pagos duplicados
- Identificar compras de mercancía o productos inusuales
- Detectar proveedores duplicados en el archivo principal
- Identificar notas de recepción de mercancía o productos faltante.
- Analizar coincidencias cruzadas de beneficiarios de cheques y cuentas bancarias vs. el archivo maestro de empleados

Ejemplos – Pruebas Sustantivas

Inventario

- Búsqueda de artículos obsoletos o de lento movimiento
- Selección de una muestra para observación física
- Recálculo de balances
- Valuación del inventario (LIFO, FIFO, Costo Promedio, etc.)
- Análisis de transacciones de inventario inusuales



Muestreo

Técnicas de Muestreo

Se utiliza la técnica de muestreo ante la imposibilidad de efectuar un examen a la totalidad de los datos. Por tanto esta técnica consiste en la utilización de una parte de los datos (muestra) de una cantidad de datos mayor (población o universo).

Métodos de Muestreo Estadísticos

- **Aleatorio:** cuando todos los datos tienen la misma oportunidad de ser escogidos o seleccionados. Ejemplo: se tiene una lista de 1,000 clientes y se van a examinar 100 de ellos.
- **Sistemático:** se escoge al azar un número y luego se designa un intervalo para los siguientes números. Ejemplo: se tiene un alista de 1,000 clientes, entre los primeros 20 se escoge al azar uno de ellos. Si resulta el 12, se puede designar los siguientes 4 números de la lista con intervalos de 50.

Métodos de Muestreo No Estadístico

- **Juicio o discrecional:** cuando se coloca un desvío en la selección de la muestra. Ejemplo: selección de unidades superiores a determinado valor, todas las que cumplan un cierto tipo de excepción, todas las negativas, todos los nuevos usuarios, etc.

Diseño de la Muestra

- **Unidad de la Muestra:** Dependerá del propósito del muestreo. Para pruebas de cumplimiento de controles (muestreo por atributos, por ejemplo: autorizaciones) y para pruebas sustantivas (muestreo variable o por estimación, por ejemplo: unidad monetaria).
- **Objetivos de la auditoría:** Tener en cuenta los objetivos de auditoría específicos que deben alcanzarse y los procedimientos de auditoría que más probablemente alcanzarán los mismos.

Diseño de la Muestra

- **Población:** Es la totalidad del conjunto de datos de los cuales se desea obtener una muestra con el fin de obtener una conclusión sobre el conjunto.
- **Estratificación:** Permite dividir la población en sub poblaciones con características similares explícitamente definidas, de forma tal que cada unidad de la muestra pueda pertenecer a un único estrato.
- **Tamaño:** Se debe tener en cuenta el riesgo de la muestra (o riesgo debido al muestreo), el error tolerable y el error esperado.

Diseño de la Muestra

- **Riesgo de la muestra** (o Riesgo debido al muestreo) - El riesgo debido al muestreo surge de la posibilidad de que la conclusión del auditor sea distinta de aquella a la que se llegaría si se sometiera a toda la población al mismo procedimiento de auditoría. Existen dos tipos de riesgo debido al muestreo:
- **Riesgo de aceptación incorrecta:** es el riesgo de se juzgue que un error importante es poco probable, cuando en realidad la población tiene errores importantes.
- **Riesgo de rechazo incorrecto:** es el riesgo de que se juzgue que un error importante es probable, cuando en realidad la población no tiene errores importantes.

Riesgo y Tamaño de Muestra

El nivel de riesgo de muestreo que el auditor está dispuesto a aceptar afecta el tamaño de la muestra.

- **Error tolerable:** máximo error en la población que los auditores están dispuestos a aceptar y aún así concluir que el objetivo de auditoría se ha alcanzado.
- **Error esperado:** si se cree que existen errores en la población, se deberá examinar una muestra mayor que cuando cree que no existen errores y su conclusión es que el error real en la población es inferior al error tolerable planeado. Los tamaños de muestra más pequeños sólo se justifican cuando se cree que la población no tiene errores.

In God we trust...
...all others must bring data

W. Edwards Deming(Estadístico)

The top half of the slide features an abstract background with various shades of blue. Overlaid on this are several white, hand-drawn style lines that crisscross the area, creating a sense of movement and data flow.

Análisis de Datos

¿En qué consiste el Análisis de Datos?

- Análisis de datos es la actividad de transformar un conjunto de datos con el objetivo de poder verificarlos muy bien dándole al mismo tiempo una razón de ser o un análisis racional.

Aspectos a considerar para el Análisis de Datos

- Verificar que los datos están completos.
- Verificar que los tipos de datos son correctos.
- Verificar la consistencia entre las variables.

Metodología para el Análisis de Datos

Para realizar un análisis de datos debemos realizar una planificación previa, antes de realizar cualquier prueba.



Beneficios del Uso del Análisis de Datos

- Toma de decisiones basadas en la información y conocimiento.
- Disminución del tiempo y aumento de la calidad sobre la toma de decisiones.
- Establece esquemas para la recopilación, análisis y estructura de la información.
- Facilita la identificación temprana de las desviaciones en las metas establecidas y permite aprovechar oportunidades.
- Apoyo en el cumplimiento o logro de los objetivos del plan estratégico de la empresa.

Filtros

- Se utilizan para extraer datos específicos según criterios definidos.

- Por ejemplo:

Extraer de la base de datos todas con las facturas pagadas este mes, aquéllas con fecha mayor a 30, 60 o 90 días antes de este mes.

Organizar

- Permite poner la data en un orden que facilite su análisis.
- Por ejemplo:

Para un análisis de Cuentas por pagar, éstas se pueden ordenar según los siguientes criterios:

- por nombre del vendedor;
- por la dirección del vendedor;
- por el número de teléfono del vendedor;

Estadística

Utiliza fórmulas estadísticas para analizar datos: Valor promedio, desviación estándar, valor mayor o menor, etc.

Por ejemplo:

- Muestra todos los pagos a vendedores que son más que 2 desviaciones estándar de la media.
- Muestra cada precio por unidad para X producto que es más que 1 desviación estándar de la media.

Expresiones y cálculos

Pueden ser usadas para realizar pruebas y detectar errores en softwares de contabilidad.

Sin embargo, también pueden ser utilizadas para detectar intervención externa a un sistema, por lo demás bien.

- Recalcular: $UNIDAD \times PRECIO \text{ POR } UNIDAD$
- Y mostrar los casos en los cuales el resultado no concuerde con el campo de MONTO.
- Recalcular la acumulación de vacaciones para cada transacción de planilla y mostrar los casos en los que el resultado difiera del registro.

Clasificación

Esta función es utilizada para contar el número de valores únicos en un campo de caracteres seleccionado y los correspondientes totales para otros campos numéricos

Por ejemplo:

Muestra cuantos procedimientos de apendicitis han sido realizados por sexo:

- Femenino: 127
- Masculino: 3
- [campo en blanco]: 12

Sumarización

- Similar a la clasificación, se utiliza para ordenar los datos por un campo específico y proporcionar una lista detallada de información de las transacciones para todos los registros en esa clasificación.

Por ejemplo:

- Muestra todas las transacciones para los Vendedores A, B, C
- Muestra todas las transacciones de planilla para los empleados A, B, C
- Muestra todas las transacciones de gastos de empleador para los empleados A, B, C

Estratificación

- Agrupar transacciones en rangos especificados de valores (o estratos)

Por ejemplo:

- Muestra número de contratos dentro de ciertos estratos:
 - \$0 - \$45,000: 27
 - \$45,001 - \$49,000: 12
 - \$49,001 - \$50,000: 425
 - \$50,001 - \$100,000: 5
 - \$100,001 - \$1,000,000: 3

Uniones y definición de relaciones

Las Uniones (o JOINS) combinan data de dos diferentes bases de datos a una sola base de datos.

La definición de relaciones permite especificar el tipo de relación que nos interesa obtener.

Por Ejemplo:

- Muestra reclamos de gastos de empleados quienes estuvieron de vacaciones/licencia el día en que se incurrió en el gasto.

Análisis de Datos para el Área de Ingresos

- **Análisis de la composición de ingresos por tipo de venta o líneas de productos o servicios**
- **Clasificación de ventas por área y vendedor**
- **Análisis de tendencia de ingresos**
- **Estacionalidad de los ingresos**
- **Pronóstico de ingresos por líneas de producto o servicio, departamento o sucursal y en general.**
- **Segmentación de la cartera de clientes por montos de compra**
- **Segmentación de la cartera de clientes por frecuencia de compra**
- **Identificación de períodos de mayor movimiento de ingresos (meses y días)**
- **Correlación de ingresos vs. gastos**
- **Segmentación de las cuentas por cobrar (clientes, antigüedad y saldos)**

Análisis de Datos para el Área de Compras

- **Segmentación de las cuentas por cobrar (clientes, antigüedad y saldos)**
- **Segmentación de la cartera de proveedores por frecuencia de compra**
- **Segmentación de la cartera de proveedores por montos de compra**
- **Identificación de variaciones de costos significativas**
- **Identificación de compras recurrentes por tipo de productos**
- **Análisis de la composición de compras por línea de productos**
- **Análisis de cumplimiento de los períodos de entrega prometidos por proveedores**
- **Segmentación de las cuentas por pagar (proveedores, antigüedad y saldos)**

Análisis de Datos para el Área de Inventario

- **Análisis de la composición del inventario por productos**
- **Cálculo del período de la mercancía en stock (entrada vs. salida)**
- **Análisis de productos rentables y de mayor movimiento**
- **Análisis de productos menos rentables y de lento movimiento**
- **Realización de muestreos estadísticos**

Análisis de datos orientados a la detección de fraude

El uso de la Ley de Benford para realizar análisis de tendencias en los datos.

Por ejemplo:

- Exceso de números en cualquier rango.
- Montos justo por debajo de los niveles de autorización.

Las áreas más comunes para el análisis de datos orientado al fraude son:

- Compras
- Fraudes de Nómina
- Fraudes Bancarios

Algunos Análisis Sugeridos

NÓMINA

- Identificar empleados duplicados en el archivo de nómina.
- Detección de empleados “fantasmas”.
- Verificar en el archivo de nómina la existencia de empleados cesantes como activos.
- Identificar incremento inusual de su salario.

Cálculo

- Hay partidas en la contabilidad que son resultados de cálculos realizados sobre bases predeterminadas. El auditor puede cerciorarse de la corrección matemática de estas partidas mediante el cálculo independiente de las mismas



Documentación

Papeles de Trabajo

- Son los archivos o legajos que maneja el auditor y que contienen todos los documentos que sustentan el trabajo efectuado durante la auditoría.

Papeles de Trabajo

- Los papeles de trabajo son utilizados para:
 - Registrar el conocimiento de la entidad y sus sistema de control interno.
 - Documentar la estrategia de auditoría.
 - Documentar la evaluación detallada de los sistemas, las revisiones de transacciones y las pruebas de cumplimiento.
 - Documentar los procedimientos de las pruebas de sustentación aplicadas a las operaciones de la entidad.
 - Mostrar que el trabajo de los auditores fue debidamente supervisado y revisado.
 - Registrar las recomendaciones para el mejoramiento de los controles observados durante el trabajo.

Papeles de Trabajo

- Importancia de los papeles de trabajo:
 - Facilitar la preparación del informe
 - Comprobar y explicar en detalle las opiniones y conclusiones resumidas en el informe.
 - Proporcionar información para la preparación de declaraciones tributarias e informe para los organismos de control y vigilancia del estado.
 - Coordinar y organizar todas las fases del trabajo.
 - Proveer un registro histórico permanente de la información examinada y los procedimientos de auditoría aplicados.
 - Servir de guía en revisiones subsecuentes.
 - Cumplir con las disposiciones legales.



Herramientas

Uso de Herramientas Informáticas

Hoy en día es indispensable la utilización de la computadora como una herramienta para mejorar la eficiencia en la revisión de la información y le permita:

- ampliar el alcance del examen,
- utilizar muestreo estadístico para la selección de transacciones y
- utilizar paquetes informáticos estandarizados para el análisis de datos.

Herramientas de Análisis de Datos

- Estas herramientas le permiten acceder a diversos archivos de almacenamiento de datos para poder realizar sus análisis, utilizando muestreo o revisando el cien por ciento de los registros, entre los archivos que puede revisar, se encuentran: hojas de cálculo (*.xls), bases de datos (*.mdf, *.dat), archivos planos (*.txt, *.dbf), entre otros.

Consideraciones de una Herramienta

- Facilita el acceso a los datos de los archivos y bases de datos sujetas a auditoría, sin depender del personal de sistemas.
- Su aplicación no requiere de avanzados conocimientos en el diseño de sistemas de información o el procesamiento electrónico de datos.
- Capacidad para acceder a un gran volumen de datos.
- Presentar características de interés sobre los campos que componen las tablas examinadas.

Consideraciones de una Herramienta

- Capacidad de importar y exportar archivos en diversos formatos.
- Generación automática de ciertos papeles de trabajo estandarizados.
- Generación de informes automáticos.

¿Qué es un CAAT?

- Técnicas de Auditoría Asistida por Computadoras (Computer Assisted Audit Technique)
- Uso de aplicaciones para realizar auditorías y alcanzar los objetivos de auditoría.
- Herramientas computarizadas que permiten a los auditores incrementar su productividad personal, así como la de la función de auditoría. [CAATTs & Other BEASTS for Auditors, by David G. Coderre; 1998, Global Audit Publications]

Categorías de CAATs

- Software de Análisis de datos.
- Software o herramientas para la evaluación de la seguridad de la red.
- Software o herramientas para la evaluación de la seguridad del sistema operativo y sistemas de administración de base de datos.
- Herramientas para pruebas sobre software y código fuente.

Consideraciones básicas de los CAATs

- Conocimiento, pericia y experiencia del equipo de auditoría del ambiente de Tecnología de Información.
- Confirmar que no se han realizado cambios en el sistema antes de repetir un CAAT.
- Disponibilidad de CAATs e instalaciones adecuadas de computación.
- Imposibilidad de pruebas manuales.
- Efectividad y eficiencia.
- Oportunidad.
- Registrar el trabajo.

¿Por qué utilizar pruebas CAATs?

- Validar reportes e información financiera
- Auditoría Interna
- Investigación de fraude
- Revisión de seguridad informática
- Transferencia de archivos
- Combinar archivos
- Generar reportes
- Monitoreo Continuo

CAAT en el Proceso de la Auditoría

- Pruebas de Cumplimiento
- Pruebas Sustantivas
- Procedimientos de Auditoría para obtener evidencia
 - Cálculo
 - Procedimientos analíticos
- Pruebas de Sistema/Seguridad Informática

A través de los CAAT se pueden obtener gran porcentaje de toda la evidencia de auditoría, por ello se debe planificar adecuadamente su uso.

Algunas actividades que realizamos mediante el uso de CAATs

- Evaluar la consistencia que presentan los sistemas de información; a través, de realizar simulaciones en paralelo de los procesamiento de información, desde el inicio hasta el final de una transacción de prueba.
- Selección de muestras de un conjunto indeterminado de transacciones de forma rápida y efectiva, en base a diferentes parámetros: estadísticos o contables.
- Análisis de datos de un universo de transacciones para verificar la integridad, consistencia y confiabilidad de la información presentada a través de los sistemas de información.

Algunas actividades que realizamos mediante el uso de CAATs

- Conciliación entre los datos presentados a través de consultas y reportes, con los datos almacenados en los sistemas de información para verificar la exactitud y confiabilidad del procesamiento de datos.
- Importación de datos desde las bases de datos hasta la computadora del auditor, para que este pueda realizar sus pruebas y análisis, sin importar la plataforma en la que se encuentren los sistemas de información.

Alicia: ¿Qué camino debo tomar?

Gato: Eso dependerá en gran medida de adónde quieras llegar.

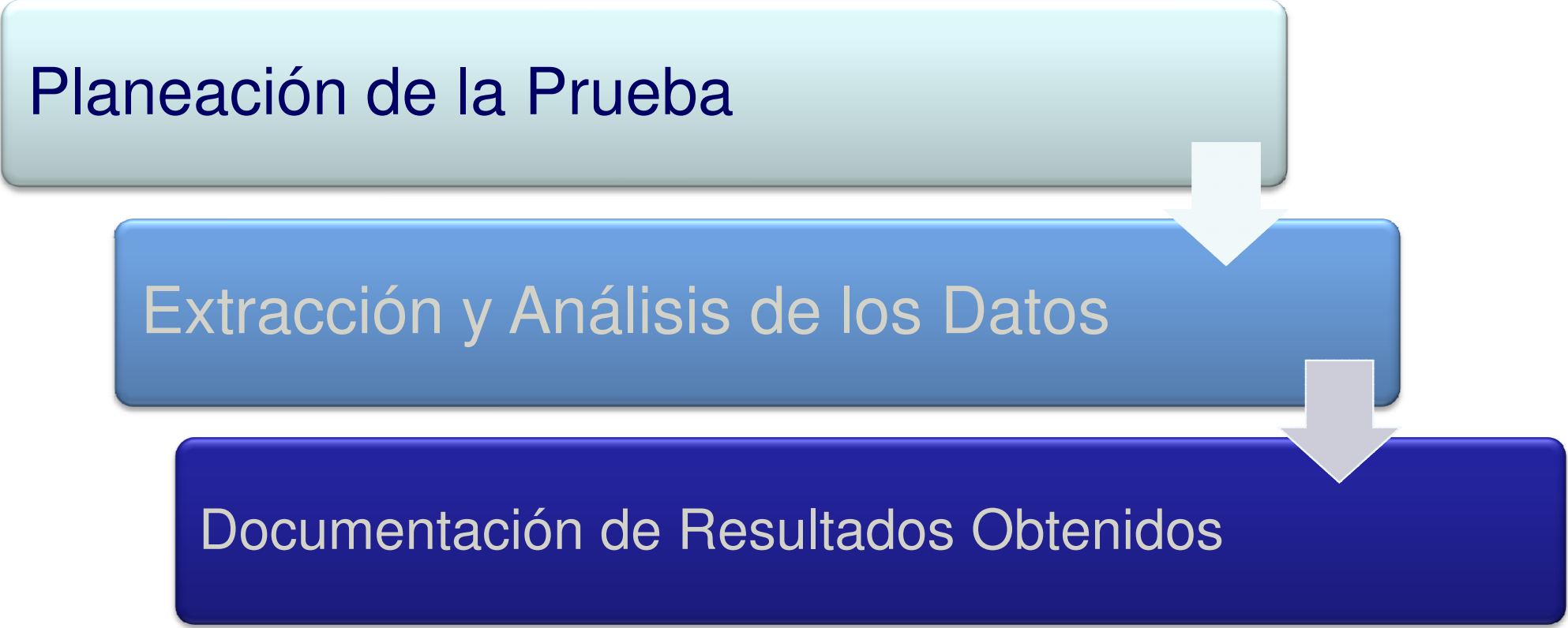
Alicia: No sé...

Gato: Entonces cualquier camino es bueno.



Metodología para la Aplicación de CAAT

Planeación de la Prueba



```
graph TD; A[Planeación de la Prueba] --> B[Extracción y Análisis de los Datos]; B --> C[Documentación de Resultados Obtenidos];
```

Extracción y Análisis de los Datos

Documentación de Resultados Obtenidos

Metodología para la Aplicación de CAATs

Planeación de la Prueba

- Establecer objetivo de las pruebas
- Definir listado de pruebas a realizarse
- Determinar mecanismos para obtención de la información (accesibilidad, disponibilidad, entre otros).
- Identificar los campos de los archivos o bases de datos a revisarse
- Comprender la relación entre las tablas de datos
- Definir los requerimientos de datos de salida
- Identificar al personal que puede participar que participará en el CAAT
- Estimación de tiempo y costo

Metodología para la Aplicación de CAATs

Extracción y Análisis de los Datos

- Definir el formato requerido para los archivos
- Solicitar información para la prueba
- Importar los datos a la herramienta
- Conciliar los datos a usarse en el CAAT con los registros contables
- Realizar la aplicación del CAAT
- Evaluar los resultados

Documentación de los CAAT

Planeación

- Objetivos del trabajo
- Consideración del CAAT específico que se va a usar
- Personal, tiempo, y costo

Ejecución

- Preparación del CAAT
- Detalles de las pruebas realizadas
- Detalles de datos de entrada, procesamiento y datos de salida
- Información técnica relevante

Evidencia de Auditoría

- Datos de salida proporcionados
- Descripción del trabajo de auditoría desarrollado en los datos de salida
- Conclusiones y recomendaciones

Presentación de Resultados y Representaciones Gráficas

- Las representaciones gráficas tienen gran importancia y utilidad en el proceso de análisis de datos y presentación de resultados.
- Existen gran cantidad de programas que pueden apoyarnos en la elaboración de gráficos, incluso tridimensionales, permitiendo grandes cambios en su apariencia.

Presentación de Resultados y Representaciones Gráficas

Barras / Columnas	Se utiliza para comparar datos entre diferentes segmentos (sectores, empresas, periodos de tiempo...).
Líneas	Permiten ver la evolución de los datos. Por lo general se usan para mostrar un mismo tipo de dato y su evolución (numero de ventas y precio).
Diagrama de Sectores Circulares	Ayuda a visualizar la contribución de cada parte a un total. Este gráfico se puede utilizar de forma creativa comparando el tamaño de las sectores entre si y el contenido de las mismas.

Presentación de Resultados

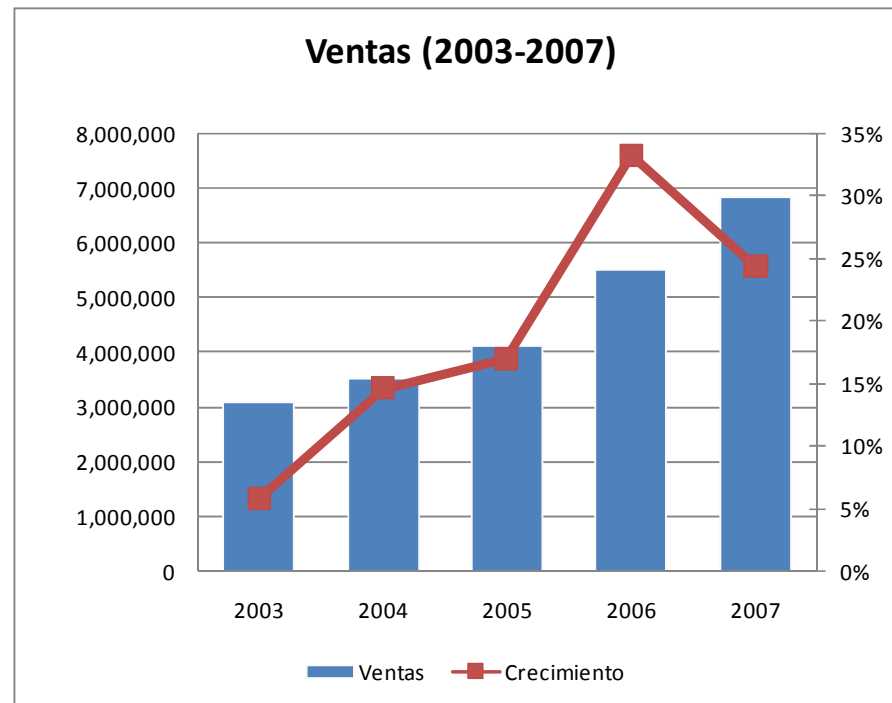
Cuadro Comparativo

Gastos	Crecimiento	2006	2005
Salarios	109%	80,652	38,510
Comisiones	384%	24,532	5,073
Publicidad	7%	36,589	34,345
Electricidad y Teléfono	46%	27,939	19,128
Reparación y mantenimiento	19%	8,406	7,035
Honorarios y asesoramiento	-1%	248,627	251,218
Alquiler	14%	20,536	18,000
Materiales y equipo de oficina	78%	14,491	8,150
Impuestos	-19%	3,628	4,499
Depreciación	106%	6,102	2,958
Otros	238%	80,517	23,822
Total	34%	Bl. 552,020	Bl. 412,739

Presentación de Resultados

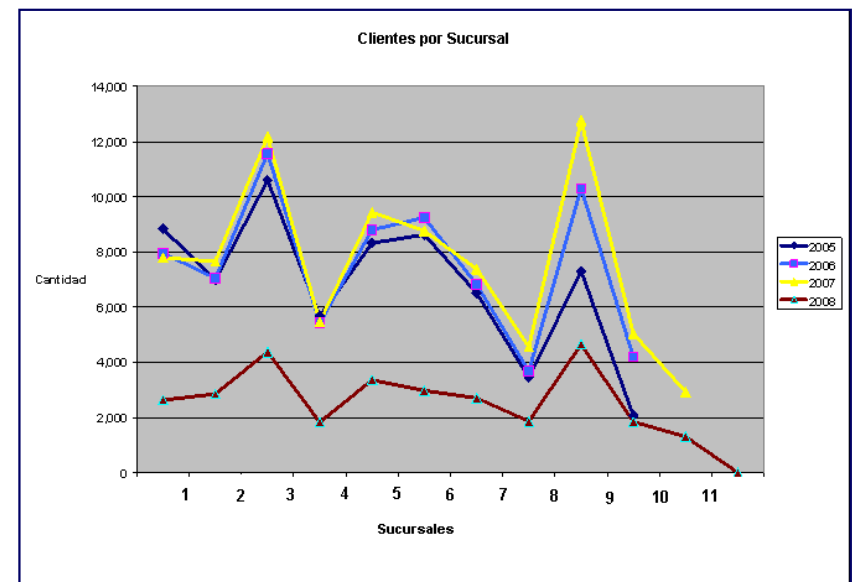
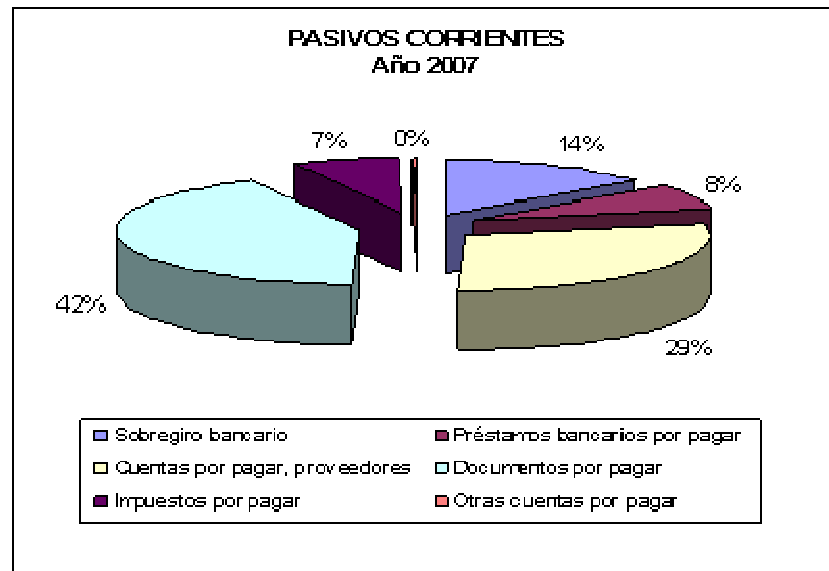
Representaciones Gráficas

Empresa, S.A.		
Años	Ventas	Variación %
2002	2,901,357.00	
2003	3,070,149.00	6%
2004	3,518,119.00	15%
2005	4,113,964.00	17%
2006	5,482,071.00	33%
2007	6,817,031.00	24%



Presentación de Resultados

Representaciones Gráficas





Presentación de Informes

Presentación de Informes de Evaluación de Ciclos de Negocios

El éxito de una auditoría muchas veces puede depender de la calidad de sus comunicaciones escritas...

Revista Internal Auditor, febrero 2003

Presentación de Informes de Evaluación de Ciclos de Negocios

Algunas Consideraciones al preparar el Informe:

- Definir claramente el mensaje a comunicar.
- Establecer aspectos que sustenten y corroboren el mensaje principal.
- Inicie colocando las ideas generales en el papel (Síndrome del papel en blanco).
- No intente escribir y corregir a la vez.
- Escribir en primera persona (yo, nosotros).
- Evaluar el tono de voz (activa o pasiva).
- Evitar el uso de palabras técnicas.
- Intente mitigar la impaciencia del lector.
- Describir el riesgo o la consecuencia.
- Recomendaciones alineadas a la realidad del negocio.
- Separe un espacio para los planes de acción de la Gerencia.

Modelos de redacción de Informes

Evitar utilizar

- Nuestra revisión de los registros fue una parte importante de la auditoría.
- Hice un reembolso a todos los participantes.
- Las condiciones del negocio fueron superiores en el tercer trimestre.
- El negocio fracasó debido a una concatenación de eventos.

Sugerencia

- Nuestra revisión de las transacciones de cuentas por pagar reveló varias discrepancias.
- Reembolsé a todos los participantes.
- El ingreso neto se ha incrementado 15 por ciento en el tercer trimestre.
- El negocio fracasó debido a una serie de eventos relacionados.

GRACIAS

Auditoría Financiera basada en Evaluación de Riesgo

Contraloría General de la República de Panamá

Abril 2010

Facilitadores:

Julio R. Jolly Moore

Oswaldo Lau C.

Suhhel Nuñez

Román Poveda

